

## **Anlage 3 - Leistungsbeschreibung**

Version 1.2 vom 18.08.2026

**Inhaltsverzeichnis**

|          |                                                        |          |
|----------|--------------------------------------------------------|----------|
| <b>1</b> | <b>Ausgangssituation und Ziele</b>                     | <b>6</b> |
| <b>2</b> | <b>Allgemeine Anforderungen an die Serviceprozesse</b> | <b>7</b> |
| 2.1      | Betriebsmodell                                         | 7        |
| 2.1.1    | Rollen der AG                                          | 7        |
| 2.1.2    | Rollen des AN                                          | 8        |
| 2.1.3    | Betriebsverantwortlichkeiten                           | 8        |
| 2.2      | Service Desk 2 <sup>nd</sup> -Level                    | 9        |
| 2.2.1    | Anforderungen an den Service Desk 2nd-Level:           | 10       |
| 2.2.2    | Anforderungen an das Ticketsystem                      | 10       |
| 2.2.3    | Leistungen des Service Desk des AN                     | 12       |
| 2.2.4    | Benutzeridentifikation                                 | 13       |
| 2.2.5    | Erstlösung                                             | 13       |
| 2.3      | Incident Management                                    | 14       |
| 2.3.1    | 1st-Level-Support                                      | 14       |
| 2.3.2    | 2nd-Level-Support                                      | 15       |
| 2.3.3    | 3rd-Level-Support                                      | 15       |
| 2.3.4    | Escalation Management                                  | 16       |
| 2.3.5    | Crisis Management / Major Incident Prozess             | 17       |
| 2.4      | Event Management / Monitoring                          | 19       |
| 2.5      | Request Fulfillment (IMACD)                            | 20       |
| 2.6      | Access Management                                      | 22       |
| 2.7      | Problem Management                                     | 22       |
| 2.8      | IT Operations Control                                  | 23       |
| 2.9      | Change Management                                      | 24       |
| 2.9.1    | Rollen im Change Management                            | 24       |
| 2.9.1.1  | Change Manager                                         | 24       |
| 2.9.1.2  | Change Advisory Board (CAB)                            | 25       |
| 2.9.2    | Verantwortlichkeiten im Change Management              | 25       |
| 2.9.3    | Emergency-Change                                       | 26       |
| 2.9.4    | Wartungsfenster                                        | 26       |
| 2.9.5    | Aufgaben des AN im Change Management                   | 26       |

|          |                                                                        |           |
|----------|------------------------------------------------------------------------|-----------|
| 2.9.6    | Beistellungen und Mitwirkungspflichten der AG                          | 27        |
| 2.10     | Release- und Deployment Management                                     | 27        |
| 2.11     | Asset- und Configuration Management                                    | 28        |
| 2.11.1   | Lizenz Management                                                      | 29        |
| 2.11.2   | Systemdokumentation                                                    | 29        |
| 2.11.3   | Betriebshandbuch                                                       | 30        |
| 2.12     | Knowledge Management                                                   | 30        |
| 2.13     | Service Level Management                                               | 32        |
| 2.13.1   | Beschwerdemanagement                                                   | 32        |
| 2.13.2   | Reporting                                                              | 32        |
| 2.13.3   | Service Review Meeting                                                 | 34        |
| 2.14     | Capacity Management                                                    | 34        |
| 2.15     | Availability Management                                                | 35        |
| 2.16     | IT Service Continuity Management                                       | 35        |
| 2.17     | Information Security Management                                        | 36        |
| 2.17.1   | Datenschutz                                                            | 36        |
| 2.17.2   | Sicherheitsüberprüfung und Stresstest der Plattform                    | 37        |
| 2.18     | Financial Management                                                   | 38        |
| 2.19     | Mitwirkungspflichten                                                   | 38        |
| <b>3</b> | <b>Allgemeine System- und Leistungsanforderungen</b>                   | <b>39</b> |
| 3.1      | Allgemeine Vorbemerkungen                                              | 39        |
| 3.2      | Vorbemerkung zu Virtual Private Cloud / Sovereign Cloud / Public Cloud | 39        |
| 3.3      | KRITIS Anforderungen                                                   | 40        |
| 3.4      | Anforderungen an das Rechenzentrum (Virtual Private Cloud)             | 49        |
| 3.4.1    | Qualitätsanforderungen an das RZ                                       | 49        |
| 3.4.1.1  | A-Kriterien Qualitätsanforderungen an das RZ                           | 49        |
| 3.4.1.2  | B-Kriterien Qualitätsanforderungen an das RZ                           | 49        |
| 3.4.2    | Performance-Anforderungen                                              | 50        |
| 3.4.3    | Anforderungen an die Server-Infrastruktur                              | 51        |
| 3.4.4    | Verfügbarkeiten                                                        | 51        |
| 3.4.5    | Sicherheitsanforderungen an das RZ                                     | 52        |
| 3.4.6    | Notfallvorsorge                                                        | 53        |
| 3.4.7    | Anforderungen Virenschutz                                              | 53        |

|          |                                                        |            |
|----------|--------------------------------------------------------|------------|
| 3.5      | Innovationsklausel                                     | 54         |
| <b>4</b> | <b>Leistungsbeschreibung Managed Services</b>          | <b>55</b>  |
| 4.1      | Basis Infrastrukturdienste                             | 55         |
| 4.1.1    | Konnektivität                                          | 55         |
| 4.1.2    | Active Directory                                       | 59         |
| 4.1.3    | Logging und Monitoring                                 | 62         |
| 4.1.4    | Self-Service-Portal                                    | 64         |
| 4.2      | Netzwerkdienste                                        | 65         |
| 4.2.1    | Basis-Netzwerkdienste                                  | 65         |
| 4.2.2    | Netzwerk-Segmentierung                                 | 66         |
| 4.2.3    | Cloud Firewall Services                                | 67         |
| 4.2.4    | Load-Balancer                                          | 68         |
| 4.2.5    | Site-to-Site VPN-Services                              | 71         |
| 4.2.6    | Internet Anbindung                                     | 72         |
| 4.3      | IaaS-Dienste in der Virtual Private Cloud              | 72         |
| 4.3.1    | Hypervisor / VM-Services                               | 74         |
| 4.3.2    | Hypervisor am Standort der AG                          | 76         |
| 4.3.3    | Storage-Services                                       | 77         |
| 4.3.4    | Terminal Services - VDA Infrastruktur                  | 81         |
| 4.3.5    | Fileservices                                           | 81         |
| 4.3.6    | Backup-Services                                        | 82         |
| 4.3.6.1  | Backup-Services für M365 Workloads                     | 85         |
| 4.3.7    | Appliances/Housing                                     | 87         |
| 4.4      | SaaS-Dienste in der Virtual Private Cloud              | 88         |
| 4.4.1    | Exchange Services                                      | 88         |
| 4.4.2    | PKI-Infrastruktur                                      | 91         |
| 4.4.3    | Kubernetes Plattform                                   | 92         |
| 4.4.4    | Database Services (DBaaS)                              | 95         |
| 4.5      | Öffnungsklausel für zusätzliche XaaS-Leistungen des AN | 98         |
| <b>5</b> | <b>Bezug von Public Cloud Services</b>                 | <b>99</b>  |
| <b>6</b> | <b>Professional Services</b>                           | <b>101</b> |

**Änderungshistorie**

| Version | Verweis                                    | Änderung                                                                     |
|---------|--------------------------------------------|------------------------------------------------------------------------------|
| 1.0     | Gesamtes Dokument                          | Erste Version für den Teilnahmewettbewerb                                    |
| 1.1     | 4.3.6.1 Backup Services für M365 Workloads | Ergänzung M365 Backup                                                        |
| 1.2     | 4.1.1 Konnektivität                        | Anforderung an Peering zur Herstellung der Konnektivität zum SD-WAN-Provider |
|         |                                            |                                                                              |
|         |                                            |                                                                              |
|         |                                            |                                                                              |

## 1 Ausgangssituation und Ziele

Die BundesInnungskrankenkasse Gesundheit – kurz BIG direkt gesund (im Folgenden auch BIG oder Auftraggeberin/AG genannt) – ist Deutschlands erste gesetzliche Direktkrankenkasse und bundesweit geöffnet. Gegründet wurde die BIG 1996 von der Bundesinnung der Hörgeräteakustiker. Aktuell betreut die BIG deutschlandweit rund 490.000 Versicherte (Stand Ende 2025). Die BIG ist - wie alle gesetzlichen Krankenkassen - eine Körperschaft des öffentlichen Rechts. Über 950 Mitarbeiter arbeiten in der Hauptverwaltung in Dortmund, dem Rechtssitz in Berlin, dem Standort in Aachen und den Kundencentern. Als IKK-Landesverband vertritt die BIG zudem die Interessen der Versicherten der Innungskrankenkassen in Berlin. In diesem Rahmen nimmt sie allein oder gemeinsam mit den Kassenverbänden der Orts-, Ersatz- und Betriebskrankenkassen zahlreiche Aufgaben der Interessentenvertretung wahr. Weitere Informationen siehe <https://www.big-direkt.de>.

Neben den in der sog. GKV-spezifischen Infrastruktur verarbeiteten Daten (Bestandssystem BITMARCK\_21c|ng), die durch ein Rechenzentrum der BITMARCK betrieben werden, werden derzeit alle Nicht-GKV-spezifischen Systeme in einer Private Cloud bei einem Managed-Service-Provider betrieben.

Eine detaillierte Übersicht der IST-Situation und der Bestandssysteme ist in der „Anlage Bestandsinformation“ aufgeführt.

Kennzahlen der BIG direkt gesund:

- Die Anzahl der Mitarbeiter im Unternehmen beträgt ca. 950
- Die Homeoffice-Quote beträgt ca. 60%

BIG direkt gesund ist derzeit an folgenden Standorten ansässig:

- Hauptstandort:
  - BIG direkt gesund, Hörder-Bach-Allee 1-3, 44263 Dortmund
- Nebenstandorte:
  - Berlin (Rechtssitz),
  - Aachen, Bergisch-Gladbach, Düren, Düsseldorf, Elsdorf, Eschweiler, Hameln, Jülich, Köln, München, Stolberg und Wuppertal (Kundencenter)

### Ziele der BIG direkt gesund für diese Ausschreibung

BIG direkt gesund verfolgt das Ziel Flexibilität und Skalierbarkeit ihrer IT-Infrastruktur zu erhöhen. Ziel ist es, durch kürzere Markteinführungszeiten und verbesserte Geschäftsprozesse die Effizienz zu steigern und Innovationen zu fördern.

BIG direkt gesund sucht daher einen Partner (im Folgenden: „Auftragnehmer/AN“), der zunächst den Betrieb der Nicht-GKV-spezifischen IT-Infrastruktur übernimmt und schrittweise BIG direkt gesund bei ihrer weiteren Entwicklung begleitet und unterstützt.

## 2 Allgemeine Anforderungen an die Serviceprozesse

Nachfolgend sind die seitens des AN zu realisierenden Serviceprozesse beschrieben, die übergreifend über alle Managed Services zum Management, Betrieb und Support der Managed Services erforderlich sind. Die Beschreibung der Serviceprozesse orientiert sich an den Standards der ITIL (IT Infrastructure Library), entsprechend gelten die Definitionen und das Vokabular von ITIL.

Der AN muss sicherstellen, dass gesetzl. Vorgaben und Richtlinien für gesetzliche Krankenkassen (GKV) nach dem Fünften Buch Sozialgesetzbuch (SGB V) und für Pflegekassen nach SGB XI eingehalten werden. Die BIG ist mit derzeit 490.000 Versicherten knapp unter dem derzeitigen Schwellwert von 500.000 der Deutschen KRITIS Regulierung und muss daher als KRITIS-relevant eingestuft werden, so dass jederzeit die KRITIS Anforderungen erfüllt werden können. Somit muss der AN sicherstellen, dass die daraus resultierenden Anforderungen erfüllt werden (siehe Punkt 3.3 KRITIS Anforderungen).

Ergänzend wird darauf hingewiesen, dass entsprechend der Beschaffungsrichtlinien der AG Nachhaltigkeitsaspekte bei einer Beschaffung berücksichtigt werden müssen. Dementsprechend muss der AN Nachhaltigkeitsaspekte erfüllen und nachweisen können (siehe Punkt 3.4.1.2 ).

Spezifische Ausprägungen, Abweichungen oder Besonderheiten der Serviceprozesse für die jeweiligen Managed Services sind in den jeweiligen Leistungsbeschreibungen (siehe Punkt 3.5) aufgeführt.

Das Verrechnungsmodell und die Preisbildung für die Serviceprozesse sind im *Preisblatt* beschrieben (Im Folgenden als „*Anlage Preisblatt*“ benannt), das im Laufe des Verhandlungsverfahrens noch abzustimmen ist und entsprechend angepasst werden kann.

Anforderungen an die Servicequalität der Serviceprozesse sind in der „*Anlage Service Level Agreements*“ beschrieben.

Darüber hinaus erbringt der AN Leistungen zur Service Transition zur Inbetriebnahme der Serviceprozesse wie in der „*Anlage Transition*“ beschrieben und zur Beendigungsunterstützung, wie in der „*Anlage Beendigungsunterstützung*“ beschrieben.

### 2.1 Betriebsmodell

#### 2.1.1 Rollen der AG

Auf Seiten der AG sind für den Betrieb folgende Rollen vorgesehen

- Melder
- 1st Level Service Desk
- 1st Level Onsite Support
- IT-Verantwortlicher

- Geschäftsführung (Eskalationsstufe 3)
- Change Advisory Board
- Lead Crisis Manager

### 2.1.2 Rollen des AN

Der AN hat entsprechend seiner Zuständigkeiten und Betriebsorganisation, sowie in den interdisziplinären Betriebsprozessen mit der AG die entsprechenden Rollen bereitzustellen und mit für die jeweilige Rolle qualifiziertem Personal und Kapazitäten zu besetzen.

### 2.1.3 Betriebsverantwortlichkeiten

Der Betrieb der Fachanwendungen erfolgt durch BIG und der Betrieb der Infrastrukturen und Dienste erfolgt als Managed Service und IaaS-Services weitgehend durch externe Servicepartner, die von der AG gesteuert werden.

Eine Übersicht der Zuständigkeiten der Betriebsaufgaben zwischen der AG inkl. deren Servicepartnern und dem AN ist als Zielbild in folgender RACI-Matrix dargestellt:

| Funktion/Serviceprozess                                      | Zuständigkeiten (RACI)       |                              |
|--------------------------------------------------------------|------------------------------|------------------------------|
|                                                              | AG                           | AN                           |
| Service Operation                                            |                              |                              |
| 1 <sup>st</sup> -Level Service Desk (Service Desk der BIG)   | A, R                         | C, I                         |
| 2 <sup>nd</sup> -Level Service Desk (Service Desk des AN)    | meldet an AN<br>C, I         | A, R                         |
| Bereitstellung Ticket System                                 | Ticket System der AG<br>A, R | Ticket System des AN<br>A, R |
| Incident Management                                          |                              |                              |
| 1 <sup>st</sup> -Level-Onsite-Support                        | A, R                         | -                            |
| 1 <sup>st</sup> -Level-Remote Support                        | A, R                         | -                            |
| 2 <sup>nd</sup> -Level-Remote-Support                        | CI                           | A, R                         |
| 3 <sup>rd</sup> -Level-Support (Hersteller / Cloud-Provider) |                              | A, R                         |
| Event Management / Monitoring                                | C, I                         | A, R                         |
| Request Fulfillment                                          |                              |                              |
| Self-Service via Service-Portal                              | A, R                         | C                            |
| Service Requests auf Anforderung                             | C, I                         | A, R                         |
|                                                              |                              |                              |
| Access Management                                            | C, I                         | A, R                         |

|                                     |      |      |
|-------------------------------------|------|------|
| Problem Management                  | C, I | A, R |
| IT Operations Control               | C, I | A, R |
| Service Transition                  |      |      |
| Change Management                   | C, I | A, R |
| Release- und Deployment Management  | C, I | A, R |
| Asset- und Configuration Management | C, I | A, R |
| Knowledge Management                | C, I | A, R |
| Service Design                      |      |      |
| Service Level Management            | C, I | A, R |
| Capacity Management                 | C, I | A, R |
| Availability Management             | C, I | A, R |
| IT Service Continuity Management    | A, C | R, I |
| Information-Security Management     | C, I | A, R |
| Service Strategie                   |      |      |
| Financial Management                | C, I | A, R |

R: Responsible (ausführend) / A: Accountable (verantwortlich) / C: Consulted (einzubeziehen) / I: Informed (zu informieren)

**Tabelle 1: Übersicht der Betriebsverantwortlichkeiten**

## 2.2 Service Desk 2<sup>nd</sup>-Level

Der SERVICE DESK des AN wird als zentrale Anlaufstelle im 2<sup>nd</sup> Level für alle IT-bezogenen Anfragen den benannten Meldern, bestehend aus den Mitarbeitern des 1<sup>st</sup>-Level Service Desk und dem IT-Verantwortlichen, bereitgestellt. Alle Aufgaben des AN werden über den SERVICE DESK als Single Point of Contact (SPOC) erfasst und koordiniert.

Der SERVICE DESK des AN nimmt alle IT-relevanten Anfragen entgegen und bearbeitet diese, sofern möglich. Sofern der SERVICE DESK des AN nicht unmittelbar unterstützen kann, leitet er die Anfrage weiter und überwacht die fristgerechte Durchführung und dokumentiert diese.

Im Allgemeinen müssen folgende Anfragen durch den SERVICE DESK des AN bearbeitet werden:

- **Störungen (Incident):** Fehler in einer oder mehreren Komponenten der Infrastruktur, der eine Abweichung von Normalbetrieb zur Folge hat.
- **Service Requests:** Fragen zur Anwendung/Handhabung von IT-Komponenten oder Abruf von vereinbarten Service-Leistungen, die nicht durch Self-Services ausgeführt werden können.
- **Standard Change Requests:** Auftrag zur routinemäßigen Änderung von IT-Komponenten.

**2.2.1 Anforderungen an den Service Desk 2nd-Level:**

Für den SERVICE DESK gelten folgende Anforderungen:

- Bereitstellung eines SERVICE DESK in der EU.
- Der SERVICE DESK ist über eine einheitliche, kostenfreie Rufnummer oder Festnetznummer in Deutschland (keine kostenpflichtige Servicrufnummer) innerhalb der in den SLAs definierten Servicezeiten (*siehe Anlage Service Level Agreements*) erreichbar.
- Zusätzlich zur telefonischen Erreichbarkeit müssen Anfragen von Meldern auch jederzeit per E-Mail oder über ein Webportal zum Ticketsystem des AN entgegengenommen werden. Die Erstellung von Tickets muss 24x7 möglich sein.
- Die Mitarbeiter des SERVICE DESK müssen in Schrift und Sprache in Deutsch kommunizieren können (mindestens Level C2 gemäß *Gemeinsamer Europäischer Referenzrahmen für Sprachen-GER*) und sind hinsichtlich der Belange der AG gesondert geschult.
- Die Mitarbeiter des SERVICE DESK müssen eine Qualifikation als Fachinformatiker (oder vergleichbar) nachweisen können.
- Alle eingehenden Anrufe und E-Mails von der AG werden von einem Mitarbeiter des SERVICE DESK direkt im Ticketsystem dokumentiert.

**2.2.2 Anforderungen an das Ticketsystem**

Alle Incidents und Service Requests (IMACD-Requests), die von benannten Meldern dem AN gemeldet werden sowie alle Incidents, die der AN im Rahmen seiner betrieblichen Aufgaben selbst identifiziert (z. B. aus dem Event Management), müssen in einem Ticketsystem des AN erfasst und die Bearbeitung vollständig dokumentiert werden.

Meldungen der AG müssen auch als E-Mail in einem definierten Format zum AN übermittelt werden können, die dort entweder manuell und unverzüglich durch den SERVICE DESK erfasst werden oder über eine elektronische Schnittstelle direkt ein Ticket im Ticketsystem des AN erzeugen.

Den benannten Meldern wird zusätzlich ein Web-basierter Zugang zum Ticketsystem des AN über ein Serviceportal bereitgestellt. Über das Serviceportal kann die AG Incident Tickets oder Service Requests (IMACD-Requests) für die Bearbeitung durch den AN direkt in das Ticketsystem des AN einstellen, den Status/Bearbeitungsstand aktiver Tickets einsehen und die Historie geschlossener Tickets einsehen, filtern und exportieren.

Die Bearbeitung von Incidents und Service Requests muss vollständig und kontinuierlich im Ticketsystem erfasst werden, so dass jederzeit über das Serviceportal der aktuelle Status und Fortschritt der Störungsbearbeitung oder Bearbeitung von Service Requests für die AG erkennbar ist.

Der Zugriff auf aktive Tickets und die Historie geschlossener Tickets über das Serviceportal muss über eine rollenbasierende Zugriffssteuerung erfolgen, so dass nur die Tickets angezeigt werden, die der Berechtigungsebene der jeweiligen Rolle zugewiesen sind.

Folgende Rollen und Berechtigungen sollten dazu mindestens realisierbar sein:

- Melder: Darf nur Tickets sehen, die er selbst eingestellt oder gemeldet hat
- IT-Verantwortlicher: darf alle Tickets der AG sehen

Die Tickets und die Dokumentation der Störungsbearbeitung werden von beiden Seiten in deutscher Sprache verfasst. Zum Abschluss der Bearbeitung vervollständigt der AN die Beschreibungen der

durchgeführten Aktivitäten und der Lösungsbeschreibung und setzt den Status des Tickets auf „gelöst“. Das Schließen des Tickets erfolgt entweder nach Rückmeldung und Bestätigung des Melders durch den SERVICE DESK oder automatisiert nach Ablauf einer definierten Entstörungsabnahmezeit.

Die Übermittlung von Statusmeldungen und Statusänderungen kann automatisiert aus dem Ticketsystem per E-Mail an den Melder sowie weitere, im Ticket hinterlegte Ansprechpartner der AG erfolgen.

Im Ticketsystem des AN werden für die Assets und Servicekomponenten CIs (Configuration Items) definiert, die bei der Ticketerstellung auswählbar sind. Diese werden für die Kategorisierung von Incidents und für das Reporting verwendet. Der AN wird diese CIs in Zusammenarbeit mit der AG entwickeln und in einer eigenen CMDB verwalten, die mit dem Ticketsystem verknüpft ist.

Für Massenstörungen, die viele Anwender betreffen, sollte das Serviceportal/Ticketsystem in der Lage sein, über eine entsprechende Anzeige (Live Ticker) oder Ansage die Anwender/Melder über solche Ereignisse zu informieren, bevor ein zusätzliches Ticket eröffnet wird.

Wo immer es notwendig und angebracht ist, muss der AN das Ticketsystem für die Schnittstellen zu anderen Prozessen benutzen, insbesondere an der Schnittstelle zu Problem- und Change-Management.

Im Lebenszyklus eines Tickets müssen mindestens folgende Daten erfasst werden können:

#### **Daten bei der Erstellung eines Tickets:**

Bei der Erstellung eines Tickets müssen mindestens folgende Daten erfasst werden können:

- Eindeutige Ticket-ID
- Referenznummer eines anderen Ticketsystems
- Datum/Uhrzeit der Ticketannahme
- Kontaktdaten des Melders und ggf. weitere Ansprechpartner (Name, Telefonnummer, E-Mail) für Rückfragen und Statusmeldungen
- Organisationseinheit, Standort
- Art des Tickets: Incident, Service Request, Change Request (ggf. Problem Ticket)
- Kurzbezeichnung
- detaillierte Beschreibung der Störung oder der Anfrage
- betroffene IT-Komponente oder IT-Service (Auswahl über definierte CIs)
- Produktkategorie der Komponente (ggf. mehrstufig, z. B. „*Computing – Server*“ oder „*Fachanwendung - BITMARCK– Rechnungswesen*“) und
- (initiale) Priorität aus Auswirkung und Dringlichkeit (ggf. abhängig von dem ausgewählten CI und dem für das CI hinterlegte Service Level)

#### **Daten im Verlauf der Ticketbearbeitung:**

- Aktueller Bearbeitungsstatus
- aktueller Bearbeiter
- Änderung der Priorität (in Rücksprache mit dem Melder) und
- Protokoll / Worklog mit Angaben zu Bearbeiter, durchgeführte Aktivitäten und Zeitstempel des Eintrags

#### **Daten bei Ticketabschluss:**

- Datum/Uhrzeit der Lösung (Änderung des Status in „gelöst“)

- Lösungskategorie (z. B. *Reparatur - Austausch* oder *Wiederherstellung - Neustart*)
- Ursachenkategorie (z. B. *Fehler - Anwendung* oder *Fehler - Benutzer*) und
- Datum des Ticketabschlusses (Änderung des Status in „geschlossen“)

#### Daten zur Erfassung der Servicequalität:

Für die Bearbeitung und zur Auswertung der erzielten Service Levels werden im Ticketsystem zwei Zeitangaben festgehalten:

- **Reaktionszeit:** Die Zeitspanne von der Meldung einer Anfrage oder Fehlers bis zur expliziten Annahme der Zuständigkeit und Beginn der Bearbeitung dieses Tickets.
- **Entstörungszeit:** Die Zeitspanne von der Meldung einer Anfrage oder Fehlers bis zur Behebung der Störung oder abschließenden Bearbeitung der Anfrage (Status „gelöst“).

Näheres zu den Service Levels wird in der „**Anlage Service Level Agreements**“ beschrieben.

#### 2.2.3 Leistungen des Service Desk des AN

Der SERVICE DESK des AN erbringt folgende Leistungen:

- Annahme von Störungsmeldungen, Service Requests und Change Requests von berechtigten Meldern der AG.
- Erfassung aller Incidents, Service Requests oder Change Requests die der AN im Rahmen seiner Betriebsaufgaben selbst identifiziert (z.B. aus dem Event Management / Monitoring).
- Prüfung der durch die AG an den AN zugewiesenen Tickets in Hinblick auf die vorgegebene Beschreibung, Kategorisierung, Priorisierung. Die Priorisierung wird nach definierten Regeln und in Abhängigkeit der mit dem Melder abgestimmten Dringlichkeit festgelegt.
- Nach akzeptierter Übernahme eines Tickets hat der SERVICE DESK die Verantwortung für die weitere Bearbeitung („Ownership“) und übernimmt die Koordination aller im Rahmen der Bearbeitung notwendigen Instanzen, bis das Ticket gelöst und geschlossen werden kann. Diese Aufgabe umfasst auch die Koordination und Steuerung etwaiger Supporteinheiten der AG oder externer Dienstleister für Anfragen, die nicht im Rahmen der Erstlösung vom SERVICE DESK abgeschlossen werden können an interne Supporteinheiten des AN (2nd Level), an Supporteinheiten der AG oder an externe Dienstleister der AG, die für die Bearbeitung zuständig sind. Die Zuständigkeiten und Schnittstellen zu externen Supporteinheiten werden im Rahmen der Service Transition mit der AG abgestimmt.
- Qualifizierte Weiterleitung von Rückfragen aus dem 2nd und 3rd Level Support des ANs an die Anwender, etwaige Supporteinheiten der AG oder externe Dienstleister der AG.
- Die aktive Überwachung der Einhaltung der vereinbarten Service Levels, insbesondere Reaktionszeiten und Entstörungszeiten. Das gilt auch, wenn die Tickets von nachgelagerten externen Supporteinheiten bearbeitet werden.
- Die Auslösung der Eskalation gemäß „2.3.4 Escalation Management“ bei Überschreiten der vereinbarten Service Levels.
- Qualitätssicherung der Bearbeitungshistorie und der Statusinformation sowie der Lösungsbeschreibung in den durch den AN bearbeiteten Tickets.
- Mitteilung von Statusänderungen in der Ticketbearbeitung an den Melder bzw. angegebenen Ansprechpartner. Diese können auch automatisiert vom Ticketsystem per E-Mail versendet werden.

- Weiterleiten der qualitätsgesicherten und gelösten Tickets an den Melder bzw. angegebenen Ansprechpartner und einholen einer Rückmeldung zur Bestätigung, dass die Anfrage erfolgreich ausgeführt wurde.
- Schließen des Tickets nach Bestätigung durch den Melder, bzw. Wiedereröffnung des Tickets, wenn die Bearbeitung nicht erfolgreich abgeschlossen wurde, anhand festgelegter Verfahren:
  - **Bestätigung durch den Melder:** Das Schließen von Tickets ist nur nach Bestätigung durch den Melder zulässig. Die Bestätigung kann entweder aktiv durch Rückfrage vom SERVICE DESK eingeholt werden oder per automatisierter Statusmeldung per E-Mail, die vom Melder bestätigt werden muss. Alternativ darf das Ticket automatisiert durch das Ticketsystem nach einer Zeitspanne von mindestens 72 Stunden geschlossen werden, wenn keine Rückmeldung durch den Melder erfolgt ist. Bestätigt der Melder, dass das Ticket nicht gelöst wurde, so muss es wieder in einen Bearbeitungsstatus zurückgesetzt werden und die Zeiten für die Service Levels laufen weiter.
  - **Überprüfung der Lösungskategorie:** Der SERVICE DESK überprüft die korrekte Zuordnung einer vorgegebenen Kategorie für die Lösung im Ticket.
  - **Ursachenkategorisierung:** Der SERVICE DESK überprüft die korrekte Zuordnung einer Kategorie für die Ursache der Störung.
  - **Ticketabschluss (Closing):** Formelles Schließen des Tickets. Das Schließen des Tickets bewirkt, dass der Vorgang endgültig abgeschlossen ist. Ein geschlossenes Ticket kann nicht mehr wiedereröffnet und weiterbearbeitet werden.
- Bereitstellung der für das Reporting benötigten Kennzahlen.

#### 2.2.4 Benutzeridentifikation

Die Benutzeridentifikation erfolgt über das Active Directory / Entra ID der AG bzw. über eine SAML-Schnittstelle zu Entra ID (SAML), mit der für Mitarbeiter des Service Desks die Authentizität des Melders und dessen Berechtigungen sichergestellt wird und einfache Prozesse wie Passwortrücksetzungen im Self-Service sicher abgebildet werden. Dazu ist ein Berechtigungskonzept zu entwickeln und zu pflegen, in dem festgelegt wird, welche Klasse von Service Requests / Standard Changes durch welche Berechtigungsebene autorisiert werden dürfen.

Folgende Berechtigungsebenen sind seitens der AG mindestens vorgesehen:

- Melder und
- IT-Verantwortlicher.

Alle definierten Service Request / Standard Changes sind in einem Change-Katalog zu erfassen und zu kategorisieren, aus dem hervorgeht, welche Berechtigungsebene den Service Request autorisieren darf. Diese Berechtigungsebenen sind mit dem System zur Benutzeridentifikation so zu verknüpfen, dass sichergestellt wird, dass nur autorisierte Service Requests und Change Requests vom SERVICE DESK angenommen und ausgeführt werden.

#### 2.2.5 Erstlösung

Neben den vorab beschriebenen Aufgaben übernimmt der SERVICE DESK zusätzlich auch die sogenannte Erstlösung von Anfragen und Meldungen. Die Mitarbeiter des SERVICE DESK werden versuchen, eine sofortige Lösung für Störungen und Service Requests ohne Weiterleitung an nachgelagerte

Supporteinheiten (2nd- und 3rd-Level) zu finden. Die Qualifikation der Mitarbeiter des Service Desk sowie die unterstützenden Prozesse sind auf eine möglichst hohe Erstlösungsquote auszuliegen.

Für die Beseitigung von Störungen/Anwendungsfragen sind folgende Wege vorgesehen:

- **Erstlösung via Telefon:** Der SERVICE DESK gibt eine telefonische Anleitung zur Störungsbeseitigung bzw. zur Beantwortung der Serviceanfrage.
- **Erstlösung via Remote-Tools:** Der SERVICE DESK greift mit Hilfe von Remote-Tools auf die Systeme des Endanwenders zu bzw. per Sitzungsspiegelung auf Terminalserver Sessions. Die Zustimmung bzw. Freischaltung des Fernwartungszugangs des Endanwenders ist hierzu zwingend erforderlich.
- **Erstlösung via E-Mail:** Der SERVICE DESK teilt die Lösung per E-Mail an den Melder mit.

Die im Rahmen der Erstlösung relevanten Themen sind:

- Alle Störungen im Zusammenhang mit den vereinbarten Services
- alle vereinbarten Services, die keine Genehmigung erfordern
- Unterstützung in der Herstellung von Verbindungen, z. B. VPN und
- Auskunft über Abläufe und Ansprechpartner für alle IT bezogenen Prozesse und Verfahren

### 2.3 Incident Management

Unter „Incident Management“ versteht man den Prozess, der alle auftretenden Incidents behandelt, die entweder über den SERVICE DESK, durch berechtigte Benutzer oder technisches Personal gemeldet werden, oder die durch Monitoring im Rahmen des Event Managements des AN erkannt und berichtet werden. Incidents können Unregelmäßigkeiten sein oder Ausfälle, Störungen, Defekte und Programmfehler. Das primäre Ziel des Incident Management Prozesses ist die schnellstmögliche Wiederherstellung der IT-Services für die Benutzer.

Zu den allgemeinen Aufgaben des AN im Incident Management gehören:

- Die Anwendung des Incident Management Prozesses gemäß Vorgaben der AG, der die Erbringung der Services so schnell wie möglich und mit der kleinstmöglichen Störung des Geschäftsablaufs wiederherstellt, wodurch das bestmögliche Bereitstellungsniveau (die Verfügbarkeit) und die bestmögliche Qualität erreicht werden, was die Zufriedenheit der Berechtigten Benutzer erhöht.
- Alle Mitarbeiter des AN, die aktiv in den Incident Prozess eingebunden sind müssen hierzu geschult sein und die spezifischen Anforderungen der AG berücksichtigen können.
- Bereitstellung eines Incident Managers, der verantwortlich ist für die effektive Durchführung des Incident Management Prozesses und die Schnittstelle zu den beteiligten Support-Einheiten des AN bildet.
- Bei Incidents, die die Kriterien einer Krise gemäß Punkt 2.3.5 Crisis Management erfüllen, muss die AG entsprechend informiert werden.

#### 2.3.11st-Level-Support

Der 1st-Level-Support erfolgt im Regelbetrieb durch die AG. Störungsbeseitigungen an End- oder Anwendersystemen ohne Konfigurationsänderungen an den Backendsystemen werden durch den 1st-Level-Support ausgeführt.

Für alle Störungen, die Konfigurationsänderungen an den Backendsystemen erfordern, ist der AN im Rahmen des 2nd-Level-Supports zuständig.

### **2.3.2 2nd-Level-Support**

Der 2nd-Level-Support liegt in der vollen Verantwortung des AN. Dieser beinhaltet sowohl die remote Entstörung durch Support-Einheiten des AN (Network Operation Center (NOC) / Security Operation Center (SOC)) als auch Entstörungsmaßnahmen durch den Fieldservice vor Ort. Bei Störungen, die nicht eindeutig im alleinigen Verantwortungsbereich des AN liegen, kooperiert der 2nd-Level-Support mit etwaigen Dritten (Supporteinheiten der AG, externe Dienstleister der AG). Bei Problemen, die nicht durch den 2nd-Level-Support des AN gelöst werden können, bezieht dieser den 3rd-Level-Support durch Hersteller/Lieferanten mit ein.

#### **Im 2nd-Level-Support übernimmt der AN folgende Aufgaben:**

- Bereitstellung eines NOC / SOC für den 2nd-Level-Support
- Analyse der Störungsmeldung und Koordination aller Maßnahmen zur Störungsbeseitigung
- Störungsbeseitigung innerhalb der in den SLAs definierten Entstörungszeiten
- Hauptverantwortung für die interdisziplinäre Kooperation bei der Störungsbeseitigung mit den im Betriebsmodell beteiligten Instanzen der AG sowie Einbeziehung von Herstellern im Rahmen der Wartung, sofern diese in die Störungsbeseitigung einbezogen werden müssen.
- Persönliche Kontaktaufnahme mit dem Melder der AG, wenn zusätzliche Informationen zur Klärung für die Störungsbearbeitung oder zur Beschleunigung der Störungsbeseitigung eingeholt werden müssen
- Dokumentation aller Aktivitäten zur Störungsbeseitigung und Kontaktaufnahmen mit anderen Supporteinheiten/Anwendern im Ticketsystem
- Ticket auf Status „gelöst“ setzen und dem Störungsmelder zum Schließen zuweisen
- Erstellung eines zusätzlichen (Problem-)Tickets bei Störungen mit unbekannter Störungsursache und Lösung mittels Workarounds und Zuweisung an das Problem Management des AN

**Wichtig:** Neben einer remote Unterstützung im 2nd-Level-Support inkludiert der Service auch einen Fieldservice des AN für den Fall, dass Services Systemkomponenten an den Standorten der BIG installiert sind, der alle Entstörungsmaßnahmen an den Standorten der BIG durchführt, die nicht remote gelöst werden können.

### **2.3.3 3rd-Level-Support**

Für den 3rd Level Support stellt die AG etwaige Provider- /Herstellerwartungsverträge bei. Der AN übernimmt die folgenden Aufgaben:

- Eskalation von Incidents und Problems an den Provider- /Herstellersupport im Rahmen der Wartung (ggf. im Auftrag der AG), wenn die Störungsbeseitigung nicht mit eigenen Möglichkeiten erfolgen kann
- Zugriff auf die Knowledge-Base der Provider / Hersteller zur Störungsanalyse / Lösungsfindung

- Eröffnen von „Cases“ beim Provider / Hersteller zur Analyse und Lösung von Incidents und Problems
- Zugriff auf Software-Releases der Hersteller zur Beschaffung von Patches im Rahmen der Wartung zur Beseitigung von Incidents und Problems
- Hauptverantwortung für die Koordination von Hardwaretausch und Abwicklung des RMA-Verfahrens mit dem Hersteller/Lieferanten im Rahmen der Wartung

### 2.3.4 Escalation Management

Eine hierarchische Eskalation wird eingeleitet, wenn eine Störung nicht innerhalb der vereinbarten maximalen Entstörungszeit behoben wurde, die Nichteinhaltung der maximalen Entstörungszeit durch den AN frühzeitig absehbar ist oder die AG eine Eskalation ausdrücklich wünscht. Anhand von Prioritätsklassen werden unterschiedliche Fristen zur Eskalation durch die AG vorgegeben. Für die Eskalation gelten folgende Regeln:

- Die Eskalation in die jeweiligen Eskalationsstufen wird eingeleitet, wenn die maximale Entstörungszeit, um die für die jeweilige Eskalationsstufe vereinbarte Zeit überschritten wurde.
- Die AG erhält zu jeder hinzugeschalteten Eskalationsstufe umgehend eine Status-Auskunft durch den AN.
- Die Ansprechpartner der jeweiligen Eskalationsstufen und deren Kontaktdaten werden in der Transition festgelegt und von beiden Seiten fortlaufend aktualisiert.

Die Eskalationsstufen sind mit Vertretern aus der Organisation des AN so zu besetzen, dass die Kompetenzen und Befugnisse der Eskalation angemessen sind und mit der jeweiligen Managementebene der AG korrespondieren. Die Vertreter der Eskalationsebenen sind anhand der Beispiele der nachfolgenden Tabelle zu besetzen:

|                    | AG                                                      | AN                                                           |
|--------------------|---------------------------------------------------------|--------------------------------------------------------------|
| Eskalationsstufe 1 | Manager on Duty des 1 <sup>st</sup> -Level Service Desk | z. B. Manager on Duty des 2 <sup>nd</sup> Level Service Desk |
| Eskalationsstufe 2 | IT-Verantwortlicher                                     | z.B. Betriebsleiter                                          |
| Eskalationsstufe 3 | Vorstand                                                | z.B. Geschäftsführer                                         |

**Tabelle 2: Rollen in den Eskalationsstufen**

Alle Eskalationen müssen mindestens umfassen:

- Eine klare Beschreibung des Problems
- Maßnahmen vor der Eskalation
- Folgen und Risiken bei Nichtauflösung
- Entscheidung erforderlich und
- Zeitskalen, in denen die Auflösung benötigt wird

Es liegt in der Verantwortung der eskalierenden Partei, geeignete Eskalationsunterlagen zu erstellen.

### 2.3.5 Crisis Management / Major Incident Prozess

Der Crisis Management Prozess der AG kommt als Eskalationsmethode innerhalb des Incident Management Prozesses zur Anwendung, wenn Business Critical Services oder Applikationen ausgefallen oder beschädigt sind und entspricht somit dem Major Incident Prozess gemäß ITIL. Ziel des Crisis Management ist die Sicherstellung der Wiederherstellung geschäftskritischer Dienste innerhalb der vereinbarten Service Level und die Minimierung der negativen Auswirkungen auf die betroffenen Geschäftsprozesse. Der Major Incident Prozess kommt außerdem bei KTITIS relevanten Sicherheitsvorfällen zur Anwendung, die der gesetzlichen Meldepflicht unterliegen.

Der Crisis Management Prozess umfasst:

- Implementierung von Maßnahmen zur kurzfristigen/schnellen Umsetzung
- Schnellstmögliche Wiederherstellung des Regelbetriebs
- Zeitnaher Informationsaustausch und Einhaltung der vereinbarten Vorgaben zur Versorgung der AG mit Informationen beim Auftreten einer Krise und während deren Bearbeitung
- Sicherstellung, dass alle betroffenen Linieneinheiten innerhalb der vereinbarten Zeitfenster informiert werden
- Einrichtung von organisationsübergreifenden Informationsabläufen im Krisenfall
- Spezifizierung der Prozesse, Aufgaben, Kommunikationswege, Schnittstellen und Verantwortungsbereiche im Eskalationsfall
- Flächendeckende Transparenz relevanter Ansprechpartner und Kontakte
- Sicherstellung der Erreichbarkeit der Ansprechpartner
- Unterstützung bei der Erfüllung gesetzlicher Meldepflichten für KRITIS relevante Vorfälle durch Bereitstellung relevanter Informationen für Meldungen an das BSI innerhalb der gesetzlichen Fristen.

Zur Bearbeitung und Lösung entstandener „Krisen“ im Incident Management Prozess ist es notwendig, dass den Mitarbeitern und Managern seitens der AG und des AN schnellstmöglich alle benötigten Informationen zur Verfügung gestellt werden. Dazu müssen Ansprechpartner, Aufgaben und Verantwortungen im Falle einer Eskalation klar definiert sein.

**Definition „Krise“:** Voraussetzung für eine Krise ist ein Incident, der direkt oder indirekt eine geschäftskritische Komponente oder Dienst beeinträchtigt und die Störung die Kriterien für Ausfallzeitraum und Dauer erfüllt. Ein solcher Incident wird als Major Incident mit Prioritätsklasse 1 eingestuft und von dem Manager on Duty des AN oder IT-Verantwortlichen der AG deklariert.

Sobald erkannt wird, dass die Kriterien für eine Krise erfüllt sind, muss der jeweilige MoD die Krise deklarieren und den Krisenprozess einleiten. Die Krise wird durch den Lead Crisis Manager der AG organisiert.

#### **Rollen und Aufgaben im Crisis Management:**

Im Crisis Management sind folgende Rollen relevant:

- IT-Verantwortlicher der AG
- Manager on Duty (MoD) des 2<sup>nd</sup> Level Service Desk / NOC des AN und
- Lead Crisis Manager der AG (wird im jeweiligen Krisenfall vom IT-Verantwortlichen oder IT-Gesamtverantwortlichen benannt)

mit folgenden Aufgaben:

#### **IT-Verantwortlicher (AG)**

- Ansprech- und Kommunikationspartner für alle Krisen, Expertenteams und MoD der AG im Krisenfall
- Einleiten notwendiger Schritte zur Sicherstellung der zeitnahen Krisenbearbeitung
- beantragen und genehmigen von Personaleinsatz
- treffen von ad hoc Entscheidungen über Zuhilfenahme von Dritten falls notwendig
- Einleitung gegebenenfalls notwendiger Maßnahmen
- Beteiligung am ständigen Austausch von Informationen
- Eskalationsstufe für Crisis Management und MoD in Fällen bei den Einheiten der AG eingebunden werden
- direkter Ansprechpartner für den AN
- liefert dem AN Informationen bezüglich der Krise
- stellt den Support in den Krisen- und Expertenteams sicher
- triggern von Aktivitäten innerhalb einer Krise und Reporting an das Management und
- sofortige Reaktion bei Kontaktierung (Erreichbarkeit 7x24). Der MoD muss, falls der IT-Verantwortliche nicht sofort erreicht werden kann, diesen weiterhin versuchen zu erreichen und per E-Mail und SMS informieren.

#### **MoD (AN)**

- Eskalationsstufe für Krisen- und Expertenteams bei Problemen in Zusammenhang mit der Auslieferung
- beantragen und genehmigen von Personaleinsatz auf Seite des AN
- treffen von ad hoc Entscheidungen über Zuhilfenahme von Dritten falls notwendig auf der Seite des AN
- Einleitung gegebenenfalls notwendiger Maßnahmen
- Beteiligt sich am ständigen Austausch von Informationen zwischen Crisis Management oder IT-Verantwortlichen
- Freigabe des Status- und Abschlussberichts
- steuert die jeweiligen Expertenteams im Krisenfall
- triggern von Aktivitäten innerhalb einer Krise und Reporting an die AG und
- sofortige Reaktion bei Kontaktierung

#### **Lead Crisis Manager (AG)**

- Übernimmt die Steuerung aller Krisen
- Steuerung aller beteiligten Spezialisten und Experten
- stellt die Bereitschaft des Krisen-Managements sicher

- stellt die Qualität während einer Krise sicher
- reportet Krisen an das Management und überprüft Bearbeitungszeiten
- kommuniziert mit
  - dem MoD, wenn eine Eskalation wegen der Lieferzeiten notwendig wird (in Krisen)
  - den IT-Verantwortlichen und
  - den Expertenteams,
- ist berechtigt, Telefon- und Webkonferenzen einzuleiten

**Im Crisis Management übernimmt der AN folgende Aufgaben:**

- Bereitstellung der Rolle „MoD“ 7x24 bei Eintritt und für die Dauer einer Krisensituation (zumindest als Rufbereitschaft außerhalb der Standard Supportzeit)
- Einbeziehen und Steuerung eines technischen Teams mit einem erweiterten Erfahrungsschatz zur Lösung der Krise
- Informieren oder Einbeziehen höherer Management-Ebenen zur Unterstützung bei der Kriseneskalation
- Zuhilfenahme von Dritten falls notwendig auf Seiten des AN
- kontinuierlicher Austausch von Informationen zu Status und getroffenen Maßnahmen zur Beseitigung der Störung
- Erstellung eines Abschlussberichts über das Krisenmanagement an die Leitung der AG
- Meldung einer potenziellen Krise an den IT-Verantwortlichen, wenn der Provider selbst im Rahmen seiner betrieblichen Tätigkeit feststellt, dass die Kriterien für eine Krise erfüllt sind oder zu erwarten sind

**2.4 Event Management / Monitoring**

Ziel des Event Managements ist die Überwachung bzw. das Monitoring aller vorkommenden Events in den beteiligten Systemen, um normale Abläufe zu sichern und um außergewöhnliche Vorkommnisse zu entdecken und entsprechend zu reagieren. Das Event Management beinhaltet ebenfalls die Automatisierung von Prozessen, um nicht vorhersehbare Umstände von Events zu verfolgen und zu eskalieren.

Alle Systeme der AG (sowohl Produktivsysteme als auch Test- oder Stage-Systeme) in der Virtual Private Cloud des AN sowie die gehosteten Appliances und Managed Fachanwendungen der AG sind durch den AN in ein aktives Monitoringsystem zur proaktiven Überwachung einzubinden. Sobald über das Monitoringsystem ein Event erkannt wird, der eine Störung darstellt, ist für dieses Ereignis der Incident Management Prozess zu initiieren. Des Weiteren liefert das Monitoringsystem Kennzahlen für das Capacity Management.

Das Monitoringsystem soll über eine Alarmierungsfunktion verfügen, mit der per E-Mail kritische Alarmer automatisiert an die IT-Verantwortlichen der AG gemeldet werden.

Das Monitoringsystem soll über die Möglichkeit verfügen, die Alarmer für definierte Komponenten über einen definierten Zeitraum zu deaktivieren, um Fehlalarme bei Wartungsarbeiten zu vermeiden. Der AN ist dafür verantwortlich, für die Dauer geplanter Wartungsarbeiten die Alarmierung bei den betroffenen Komponenten zu deaktivieren und danach wieder zu aktivieren. Das schließt auch Wartungsarbeiten in der Infrastruktur der AG oder dessen Partner ein, die Auswirkungen auf die vom AN überwachten Komponenten haben und von der AG an den AN gemeldet werden.

Des Weiteren sollte das Monitoringsystem über ein „Dashboard“ verfügen, auf das Mitarbeiter des 1<sup>st</sup> Level Service Desk und der IT-Verantwortliche der AG Zugriff haben und das den aktuellen Zustand der Systeme in Echtzeit sowie historische Verläufe von Messwerten in verschiedenen Zeitskalen dargestellt. Für das Dashboard sollen verschiedene, individuelle Ansichten eingerichtet werden können, so dass die Mitarbeiter des 1<sup>st</sup> Level Service Desk und IT-Verantwortlichen die für sie relevanten Systeme angezeigt bekommen.

Für die gehosteten Appliances und Managed Fachanwendungen der AG werden die Monitoringpunkte (Messstellen für das Monitoringsystem, die i.d.R. per SNMP, Traps oder Polling eines Ports erfasst werden) von der AG vorgegeben und in der Transformationsphase mit dem AN abgestimmt und dokumentiert. Für jeden Monitoringpunkt wird festgelegt, wie und in welchen Intervallen die Werte ausgelesen werden und welche Schwellwerte für Warnung, Alarm und Fehlerzustand definiert werden und welche Aktion bei Erreichen eines Schwellwertes bzw. Entstöungsmaßnahme bei einem Fehlerzustand durch den AN ausgeführt werden muss.

Das können beispielsweise sein:

- Benachrichtigung der AG bei Erreichen eines Schwellwertes für Warnung, oder
- Restart einer Instanz als Entstöungsmaßnahme bei einem Fehlerzustand.

Für das Event Management übernimmt der AN folgende Aufgaben:

- Kontinuierliche aktive Überwachung der IT-Systeme, mit denen die Services für die AG erbracht werden, mit dem Monitoringsystem und weiteren anlagenspezifischen Managementsystemen gegen Nachweis
- Kontinuierliche aktive Überwachung der gehosteten Appliances und Managed Fachanwendungen der AG mit den definierten Monitoringpunkten
- Ausführen der für den Fehlerzustand einer gehosteten Appliances oder Managed Fachanwendungen vereinbarten Aktion
- Identifikation von Incidents, die sich aus dem Status der Anlagen oder Fehlermeldungen erkennen lassen
- Initiierung des Incident Management Prozesses bei erkannten Störungen. Eröffnen eines Tickets im Ticketsystem innerhalb der definierten Reaktionszeit
- Bereitstellung von Kennzahlen für das Capacity Management
- Kontinuierliche Anpassung der Monitoringpunkte z. B. nach Änderungen und Feinjustierung der Schwellwerte und Korrelationen zwischen verschiedenen Monitoringpunkten zur Optimierung der Aussagekraft von Events
- Bereitstellung von Zugriffen für die IT-Verantwortlichen auf das Dashboard mit Ansichten und Alarmierungsfunktion

**Wichtig:** Der Bieter hat im Rahmen seines Angebotes sein angebotenes **Monitoring-Konzept** darzustellen.

## 2.5 Request Fulfillment (IMACD)

Die Service-Requests sind vordefinierte, standardisierte und häufig wiederkehrende Änderungen in einem bereitgestellten Service, die nicht über den Change Prozess ausgeführt werden.

Request Fulfillment ist das Bearbeiten von Service-Request zur Bereitstellung und Änderung von Services, die vereinbarungsgemäß nicht über die Self-Service Funktionen durch die AG ausgeführt werden können.

Über ein Self-Service-Portal (siehe 4.1.4 Self-Service-Portal) muss die überwiegende Mehrheit von Standard Service Requests durch die AG selbst ausgeführt werden können, so dass Bereitstellungsleistungen im Request Fulfillment durch die AG nur in Ausnahmefällen in Anspruch genommen werden müssen.

Für das Request Fulfillment im Allgemeinen und für die genannten Ausnahmefälle werden zwei Typen von Service Requests definiert:

- **Standard Service Request:** Prozess mit
  - definierten Verfahren oder Templates
  - geringem Risiko
  - vorhersehbarem Aufwand und
  - Wiederholbarkeit
- **Komplexer Service Request:** Prozess mit
  - Eingriffen in die Architektur
  - hohen Sicherheits- und Compliance-Auswirkungen
  - Migrations- oder Plattformwechseln
  - Individueller Analyse oder Planung

Für Standard Service Requests und Komplexe Service Requests werden monatliche Kontingente vereinbart, die über die entsprechenden Preispositionen gemäß Preisblatt vergütet werden. Sollten die Kontingente über mehrere Monate hinweg über- oder unterschritten werden, werden entsprechende Anpassungen der Kontingente vereinbart.

Zur Einordnung von Service Requests in Standard und Komplex und zur Abgrenzung gegenüber Professional Services gelten für zeitlichen Aufwand zur Durchführung der Service Requests folgende Richtwerte:

- Standard Service Request: maximal 1 Stunde
- Komplexe Service Request: maximal 4 Stunden

Der Aufwand bemisst sich in einem eingeschwungenen Prozess, wenn der jeweilige Service Request bekannt, erprobt und definiert ist. Der durchschnittliche Aufwand sollte dabei deutlich unter den Maximalwerten liegen. Ausgehend davon sind die Service-Pauschalen zu kalkulieren.

Ausgenommen von der Vergütungspflicht sind Service Requests, die vereinbarungsgemäß über das Self-Service-Portal ausführbar sein müssten, aber tatsächlich nicht ausgeführt werden können, z. B. weil dies aus technischen Gründen nicht möglich ist oder der Provisionierungsprozess nicht oder nicht ordnungsgemäß konfiguriert ist. Im letzten Fall hat der AN zusätzlich dafür zu sorgen, dass diese Funktion im Self-Service-Portal ergänzt oder entsprechend konfiguriert wird, es sei denn es handelt sich um einen sehr seltenen Request. In diesem Fall kann der AN sich entscheiden, solche Request dauerhaft und kostenfrei per Service Request auszuführen.

Die nachfolgenden Beispiele stellen exemplarisch und nicht abschließend die verschiedenen Arten von Services Requests (IMACD) dar, unterteilt in Standard SE und Komplex SR:

**INSTALL:** Installation und Inbetriebnahme neuer Komponenten

**MOVE:** Umzug bestehender Komponenten

**ADD:** Aktivierung zusätzlicher Dienste, Funktionen oder Leistungsmerkmalen

**CHANGE:** Änderungen von Diensten, Funktionen oder Leistungsmerkmalen

**De-INSTALL:** Dekommissionierung von Diensten und Systemen

Die Aufträge zur Durchführung von Service Requests werden via Ticket an den AN erteilt. Die Service Request Tickets im Ticketsystem des AN ermöglichen die Eingabe Request-spezifischer Provisionierungsparameter über integrierte Formulare mit entsprechenden Pflichtfeldern, alternativ muss der AN Formularvorlagen in einem gängigen Dokumentformat (z.B. Excel) bereitstellen, die per Attachments an das Ticket dem AN übermittelt werden.

Der AN entwickelt im Rahmen der Transition einen Katalog an Service Requests, klassifiziert in „Standard Service Request“ und „Komplexer Service Request“ und entwickelt diesen kontinuierlich weiter. Sollte ein neuer Request auftreten, der noch nicht klassifiziert ist, ist er anhand der Systematik dem entsprechenden Request Typ zuzuordnen und der Katalog entsprechend zu erweitern.

## 2.6 Access Management

Der AN stellt sicher, dass die Systeme und Services so eingerichtet werden, dass alle Zugriffe entsprechend einem abgestimmten Berechtigungskonzept authentifiziert und autorisiert werden.

Als führendes System zur Authentisierung und Autorisierung gilt für alle IaaS- und SaaS-Dienste sowie alle Managementsysteme das Active Directory / Entra ID der AG (siehe Punkt 4.1.2 Active Directory).

Sollte der AN ein eigenes Identity- und Access Management System (IAM) zwischengeschaltet haben, über das die Zugriffsteuerung auf die Dienste oder Managementsysteme erfolgt, muss es die Zugriffsteuerung über eine Schnittstelle zum Active Directory / Entra ID der AG die Zugriffsrechte steuern. In diesem Fall muss der AN in der Lage sein, auf Verlangen durch die AG jederzeit einen Bericht über alle aktuell registrierten Identitäten und deren Berechtigungen zu erstellen oder für eine einzelne Identität alle Benutzerkonten und deren Berechtigungen nachzuweisen.

## 2.7 Problem Management

Ziel des Problem Managements ist die Durchführung von Prozessen zur Ermittlung der Ursachen von schweren, wiederholt auftretenden oder potenziellen Störungen sowie die Erarbeitung von Lösungen zur endgültigen Beseitigung der Ursachen. Der AN verpflichtet sich zur Durchführung von Aktivitäten, um Störungen proaktiv zu vermeiden.

Wenn nicht klar ist, in wessen Verantwortungsbereich ein Problem liegt, werden die Beteiligten unter Führung des AN kooperativ zusammenarbeiten, insbesondere alle benötigten Informationen/

Zuliefertätigkeiten zeitnah zur Verfügung stellen und gegenseitig über den Status der Problembehebung informieren. Workarounds, Maßnahmen und Problembearbeitungen haben in enger Abstimmung mit der AG zu erfolgen. Die AG muss jederzeit Einblick in die Problem-Datenbank des AN (z.B. Problem Tickets im Ticket System) gewährt werden.

Störungen der Priorität 1 mit unbekannter Störungsursache sowie auf Anforderung der AG auch andere Störungen, werden innerhalb der Problem-Recording Zeit (gem. *Anlage Service Level Agreements*) zur Analyse an das Problem Management übergeben. Die Analyse bis zur Identifikation der Störungsursache im Rahmen des Problem Management Prozesses darf im Durchschnitt nicht länger als die Problem-Analysis Zeit (gem. *Anlage Service Level Agreements*) dauern. Workarounds, Maßnahmen und Problembearbeitungen haben in enger Abstimmung mit der AG zu erfolgen.

Der AN führt im Rahmen des Problem Managements folgende Leistungen durch:

- Reaktives Problem Management durch Identifizierung und Registrierung von Problemen durch Analyse der Tickets
- Bearbeitung von Problem Tickets, die aus Störungen mit unbekannter Störungsursache generiert wurden
- Klassifizierung und Priorisierung der erkannten Probleme
- Ermittlung von Ursachen der Störung(en) / Analyse der Probleme. Das Ergebnis ist dann ein Known Error und bei übergreifenden Problemen ist die AG darüber zu informieren
- Problembeschreibung und Ermittlung von Workarounds
- Ermittlung von Lösungen zur endgültigen Beseitigung der Störung
- Probleme abschließen und dokumentieren
- Trends zu Problemen identifizieren
- Proaktives Problem Management mit Durchführung von vorbeugenden Aktivitäten, um Störungen zu vermeiden. Hierzu zählen insbesondere Trendanalysen und die gezielte Beobachtung anfälliger oder stark beanspruchter Komponenten. Der AN überwacht ständig die Systeme und initiiert selbständig einen Change Request, wenn sich Kapazitätsengpässe oder andere Situationen anbahnen, die zu Störungen führen können
- Regelmäßige Überprüfung der Knowledge-Base der Hersteller auf relevante Known-Errors als zusätzliche vorbeugende Maßnahme
- Bereitstellen eines monatlichen Berichts mit der Anzahl der offenen Problem Tickets und der im Berichtsmonat abgeschlossenen Root Cause Analysen inklusive deren Bearbeitungsdauer

## 2.8 IT Operations Control

Für IT Operations Control ist der AN verantwortlich. IT Operations Control beinhaltet laufende Routine- und Vorsorgetätigkeiten, die für den ordnungsgemäßen Betrieb und Erhaltung der Funktionsfähigkeit der Systeme erforderlich sind. Das umfasst alle vom Hersteller empfohlenen regelmäßigen Wartungs- und Administrationsarbeiten, wie Kontrolle wesentlicher Systemparameter, Bereinigung von Datenbeständen und Logfiles sowie Einrichtung, Aktivierung und Kontrolle von Backupaktivitäten.

Im IT Operations Control übernimmt der AN folgende Aufgaben:

- Durchführung regelmäßiger vom Hersteller empfohlenen Wartungs- und Administrationsarbeiten an den Systemen

- regelmäßige Kontrolle wesentlicher Systemparameter
- regelmäßige Bereinigung von Datenbeständen und
- Einrichtung, Aktivierung und Kontrolle von Backupaktivitäten zur Sicherung und Wiederherstellung der Systemkonfiguration und Datenbestände

## 2.9 Change Management

Change Management ist ein Prozess zur Verwaltung aller Änderungen an Konfigurationselementen (CIs) zusammen mit jeder anderen Umgebung, die ein Unternehmen unter Change Management haben möchte - in der Regel alle Umgebungen und Schnittstellen, die unter der Kontrolle von "IT Operations" stehen. Ziel des Change Managements ist, sicherzustellen, dass mit standardisierten Methoden und Verfahren die Ausführung von Änderungen kontrolliert umgesetzt werden und die Risiken minimiert werden.

Generell kann man von folgenden drei Kategorien von Changes ausgehen:

- **Standard Change** stellen nur Konfigurationsänderungen dar und bergen kein Risiko der Verschlechterung oder Unterbrechung von Diensten. Sie sind daher von der AG vorab autorisiert. Änderungen mit nachweislich geringen Risiken, die vom AN bereits mehrfach erfolgreich umgesetzt wurden, können auch als Standard Changes definiert werden. Eine solche Definition wird als Change behandelt und wird über das Change Advisory Board mit dem AG abgestimmt.
- **Minor Change** mit geringer Auswirkung und geringem Risiko.
- **Major Change** mit hoher Auswirkung oder hohem Risiko.
- **Emergency Change** wenn zur Wiederherstellung des Servicebetriebs nach größeren Ereignissen, Sicherheitsvorfällen oder anderen schwerwiegenden Auswirkungen schnellstmöglich Änderungen in der Systemumgebung vorgenommen werden müssen.

### 2.9.1 Rollen im Change Management

Die nachfolgend aufgeführten Rollen sind obligatorisch, definieren aber nicht die komplette Account-Organisation des AN.

#### 2.9.1.1 Change Manager

Der AN benennt einen Change Manager als Ansprechpartner für die AG. Der Change Manager steuert den Lebenszyklus aller Changes. Die AG stellt gleichfalls einen Ansprechpartner zur Verfügung, der als Ansprechpartner für den Change Manager des AN fungiert.

Die Erreichbarkeit dieser Rolle wird in der Transition Phase zwischen der AG und dem AN festgelegt. Außerhalb dieser Zeiten stellt der AN einen Eskalationsweg für die Behandlung von kurzfristigen Änderungen zur Verfügung, die für die Kontinuität und Wiederherstellung von Services in oder außerhalb der vereinbarten Service Levels erforderlich sind (Emergency Changes). Der Change Manager ist unter anderem für die Aufnahme und Dokumentation aller RfCs im Zuständigkeitsbereich des AN, Erstellung von Reports über durchgeführte und geplante Changes verantwortlich. Emergency Changes muss der Change Manager spätestens nach der Dokumentationszeit für Emergency Changes (gem. *Anlage Service Level Agreements*) nach erfolgter Realisierung komplett dokumentieren und nachreichen.

### **2.9.1.2 Change Advisory Board (CAB)**

Ein Change Advisory Board gemäß ITIL soll alle Änderungen zur Prüfung und Genehmigung vorlegen. Die konkreten Kriterien und Verantwortlichkeiten werden in der Transition Phase zwischen AG und AN vereinbart.

### **2.9.2 Verantwortlichkeiten im Change Management**

#### **Planung eines Changes**

Changes sind während der vereinbarten Wartungsfenster zu realisieren und die zugehörigen Change Requests (RfCs) sind der AG im Voraus mitzuteilen. Die Umsetzung von Changes außerhalb der vereinbarten Wartungsfenster kann nur ausnahmsweise und mit Zustimmung der AG durchgeführt werden.

Der AN hat die Anzahl der Betriebsunterbrechungen so gering wie möglich zu halten. Risiken von Changes werden durch vorherige Kontrollen und Tests reduziert. Bestehen weiterhin Risikofaktoren für den Change, kann die AG die geplante Betriebsunterbrechung verschieben.

Der AN wird die AG informieren, wenn sich ein Ausfall oder eine Unterbrechung des Dienstes während einer Change-Implementierung nicht vermeiden lässt. Der AN unterscheidet in diesen Informationen einen Totalverlust der Servicequalität und eine Verschlechterung der Servicequalität und definiert den Zeitraum für Serviceunterbrechungen oder Serviceeinschränkungen.

Die Verwaltung, Dokumentation und Berichterstattung aller Changes erfolgt über ein vom AN zu lieferndes Serviceportal.

#### **Durchführung von Changes**

Ein Standard Change wird innerhalb der Ausführungszeit (gemäß *Anlage Service Level Agreements*) oder zu einem späteren Wunschtermin implementiert, wenn dies im Change Request definiert ist. Emergency Changes sollen so schnell wie möglich durchgeführt werden - zum Beispiel, um einen größeren Vorfall zu beheben oder einen Sicherheitspatch zu implementieren. Solche Änderungen werden durch den Emergency Change Kontakt der AG genehmigt.

Für jeden Change muss der AN einen Fallbackplan erstellen, der bei einem nicht erfolgreich durchgeführten Change ausgeführt wird, um den Ursprungszustand wieder herzustellen.

#### **Abnahme**

Changes, die ein erhebliches Risiko für die Services darstellen, die Initiierung eines neuen Service und die Änderung eines bestehenden Service stehen unter dem Vorbehalt der Abnahme durch die AG. Beide Parteien müssen vor Inbetriebnahme einen detaillierten Akzeptanztest und Abnahmekriterien mit einem Abnahmeprotokoll vereinbaren, die alle Aspekte möglicher Akzeptanz- und Testszenarien abdecken. Für alle anderen Änderungen und Standard Changes wird ein einheitlicher Change Acceptance Prozess zwischen der AG und dem AN durchgeführt. Die konkreten Kriterien und Verantwortlichkeiten werden zwischen dem AN und der AG vereinbart.

Die Abnahmefrist beginnt mit dem ersten Abnahmetest nach der "Bereit-zur-Abnahme"-Bestätigung des AN. Die Abnahme wird mit einem Abnahmeprüfprotokoll dokumentiert.

### **2.9.3 Emergency-Change**

Bei Bedarf wird die AG dem AN die Durchführung eines Emergency-Changes ermöglichen, um den Servicebetrieb nach größeren Ereignissen, Sicherheitsvorfällen oder anderen schwerwiegenden Auswirkungen wiederherzustellen.

Für die Freigabe zur Durchführung eines Emergency Changes hat der AN folgende Angaben zu machen:

- Risiken
- Betroffene Systeme / Services
- mögliche Auswirkungen bei Durchführung des Emergency Changes
- mögliche Auswirkungen bei Nichtdurchführung des Emergency Changes und
- Ausfalldauer

Die AG muss einen Emergency Change genehmigen, wobei alle SLAs auch dann bestehen bleiben, wenn eine Genehmigung erteilt wurde.

### **2.9.4 Wartungsfenster**

Planmäßige Wartungsarbeiten dürfen nur nach vorheriger Information der AG durch den AN mit einer vereinbarten Vorlaufzeit für geplante Wartungsarbeiten im geplanten Wartungsfenster durchgeführt werden. Zwischen der AG und dem AN wird im Rahmen der Transition ein Kalender mit Standardwartungsfenstern vereinbart. Änderungen, die über diese Fenster hinausgehen, bedürfen der ausdrücklichen Zustimmung der AG.

Die Inanspruchnahme von Wartungsfenstern werden im Change Advisory Board besprochen und vereinbart auf Basis folgender Angaben:

- Umfang und Auswirkung der geplanten Änderungen und Wartungsarbeiten
- das Risiko einer Serviceunterbrechung
- Fallbackplan mit Zeitpunkt und Dauer der Wiederherstellung des Ursprunzustands
- der Leistungsumfang (unternehmensspezifisch / standortspezifisch) und
- das gewünschte Zeitfenster

### **2.9.5 Aufgaben des AN im Change Management**

Für das Change Management übernimmt der AN folgende Aufgaben:

- Bereitstellung der Rolle „Change Manager“, der die Change Requests den jeweiligen Teams (auch weiteren Dritten) zuweist, die RfC-Planung unterstützt, die Durchführung von Changes koordiniert und für Dokumentation und Reporting verantwortlich ist
- Entgegennahme von Change Requests durch die AG, insbesondere bezüglich:
  - Anforderungen zu technischen oder wirtschaftlichen Beratungsleistungen

- Kapazitätsanforderungen (Capacity Management)
  - Verfügbarkeits- und Service Continuity Anforderungen und
  - Qualitätsanforderungen und Service Level Anforderungen
- Einbringen von Change Requests aus den Anforderungen des operativen Betriebs des AN (Incident-, Problem, Capacity, Release-Management) in den Change Prozess der AG
- Aufnahme und Dokumentation aller RfCs im Zuständigkeitsbereich des AN
- Bewertung, Risikoanalyse, Klassifizierung und Planung von Change Requests in Abstimmung mit den beteiligten Organisationseinheiten der AG
- Einhaltung der definierten Vorlaufzeiten in Abhängigkeit des Change Typs zur Klärung, Abstimmung und Freigabe
- Ausarbeitung von Fallback-Szenarien in Abstimmung mit den zu beteiligten Organisationseinheiten der AG
- Erstellung von Abnahmekriterien und -protokollen in Abstimmung mit der AG
- Durchführung von Abnahmetests und Dokumentation im Abnahmeprotokoll
- Terminierung, Umsetzung und Test der von der AG freigegebenen RfCs
- Durchführung von Emergency Changes nach Freigabe durch die AG und Nachreichung der kompletten Change Dokumentation nach erfolgter Realisierung
- Erstellung von Reports über durchgeführte Changes

#### **2.9.6 Beistellungen und Mitwirkungspflichten der AG**

Zu Beistellungen und Mitwirkungspflichten gelten für den Change Management Prozess die in „Anlage Mitwirkungspflichten“ im Rahmen der Angebotslegung vom AN aufzuführenden Beistellungen und Mitwirkungspflichten.

#### **2.10 Release- und Deployment Management**

Das Release Management für alle Systemkomponenten, die Bestandteil des Managed Service sind, liegt in der Verantwortung des AN. Der AN hat dafür zu sorgen, dass die Softwarestände auf einem aktuellen Stand und alle Komponenten untereinander kompatibel sind. Das schließt alle Softwarekomponenten für Systemkomponenten, deren Plattformen (Betriebssystem, Virtualisierung), System-Anwendungen, und Appliances ein.

Die AG unterhält einen Rahmenvertrag mit Microsoft, über den Lizenzen direkt beschafft werden können. Der AN muss die Möglichkeit vorsehen, dass diese Lizenzen im Rahmen von Bring-your-own-License (BYOL) eingebracht werden, ebenso wie die Lizenzen für Appliances und Applikationen, die die AG auf den Plattformen betreibt. Für den Fall, dass für Lizenzen, die von der AG eingebracht wurden, eine lizenzrechtliche Verletzung erfolgt oder Funktionen im Herstellersupport eingeschränkt werden, ist der AN von jeglicher Haftung oder den daraus resultierenden Folgen aus den Betriebsprozessen entbunden (z. B. dem Patch-Management und den daraus resultierenden Verfügbarkeits- oder Sicherheits-SLAs).

Die Implementierung von Releases wird über den Change Prozess freigegeben und gesteuert. Insbesondere hat der AN dafür zu sorgen, dass alle Release-Stände auf einem Versionsstand sind, der durch den jeweiligen Herstellersupport abgebildet wird.

Sobald ein Release als End-of-Support angekündigt wird, muss der AN entweder entsprechende Maßnahmen zur Risikominimierung über einen Change Request einleiten oder der AG Risiken aufzeigen und dafür Sorge tragen, dass die Interoperabilität gewährleistet ist.

Unter den verschiedenen Releases werden folgende Typen unterschieden:

- **Patches:** zur Beseitigung von Softwarefehlern innerhalb einer Version
- **Security Patches:** zur Beseitigung von Sicherheitslücken
- **Updates:** neue Versionen mit Funktionsänderungen/-erweiterungen innerhalb einer Hauptversion
- **(Major-)Upgrades:** Sprung auf eine neue Version mit umfangreichen Änderungen oder komplett neuen Funktionen

Besonderes Augenmerk sollte sich dabei auf sicherheitsrelevante Security Patches richten, die möglichst frühzeitig nach Veröffentlichung durch den jeweiligen Hersteller implementiert werden sollten, wenn eine relevante Sicherheitslücke dadurch geschlossen wird und eine entsprechende Empfehlung des Herstellers oder einer CERT Institution ausgesprochen wird.

**Für das Release Management übernimmt der AN folgende Aufgaben:**

- Regelmäßige Überprüfung der Release Notes und Security Alerts zu der eingesetzten Software (Systemsoftware, Firmware) bei den Herstellern und Überprüfung auf Relevanz
- Abgleich der eingesetzten Softwareversionen mit der Release-Roadmap der Hersteller, insbesondere um sicherzustellen, dass keine produktiven Versionen in den End-of-Support oder End-of-Service laufen
- Implementierung von relevanten Patches via Change Request
- Abgabe einer Empfehlung zu relevanten Updates und im Rahmen der Service Review Meetings.
- Hinweis auf und Bewertung zu (Major-)Upgrades im Rahmen der Service Review Meetings.
- Unterstützung bei der Release-Planung zum Rollout von Updates/Upgrades
- Security-Patches werden innerhalb der Implementierungszeit für sicherheitsrelevante Security Patches (gem. *Anlage Service Level Agreements*) nach Ankündigung durch den Hersteller via Change Prozess implementiert, vorbehaltlich der Freigabe durch die AG
- Implementierung von Updates und Patches entsprechend der Release-Planung via Change Prozess
- Implementierung von (Major-)Upgrades auf Anforderung durch die AG, oder wenn der Lifecycle des Herstellers das erfordert. Übersteigt die Implementierung eines (Major-)Upgrades deutlich den Aufwand eines Updates, dann wird die Implementierung im Rahmen eines Projektes durchgeführt und über Professional Services abgerechnet und ist nicht im pauschalen Betriebspreis des AN inkludiert.

## **2.11 Asset- und Configuration Management**

Das Asset- und Configuration Management dient der Erhaltung und Pflege der Informationen über Configuration Items (CIs), die für die Leistungserbringung der Services und seinen Korrelationen

erforderlich sind, sowie die für den Betrieb erforderliche Systemdokumentation und das Betriebshandbuch. Das Management dieser Informationen erfolgt durchgehend über den Lebenszyklus der CIs.

Der AN ist für die Qualität und die laufende Pflege und Erweiterung der Dokumentation der hier betrachteten Systeme verantwortlich. Bestandteil der Dokumentation ist auch die korrekte Benennung und Beschriftung von Komponenten und die Verwaltung der Assets im Asset Management.

Für das Configuration Management übernimmt der AN folgende Aufgaben:

- Erstellung und fortlaufende Pflege eines Verzeichnisses aller von ihm betreuten Systeme und IT-Komponenten (CIs) in einem einheitlichen Dokumentationssystem (CMDB) mit technischen und relevanten kaufmännischen Informationen sowie der eingesetzten Software (Basis- und Fachsoftware) und Lizenzen
- Anpassung der CI Daten nach Änderung
- Anpassung der Systemdokumentation und des Betriebshandbuchs in einem einheitlichen Dokumentationssystem nach Änderung die durch Changes vorgenommen wurden

#### **2.11.1 Lizenz Management**

Der AN stellt sicher, dass alle von ihm bereitgestellten Systeme und Anwendungen lizenzrechtlich vollständig, korrekt und revisionssicher abgebildet sind und der Lizenznachweis fortlaufend und lückenlos gepflegt wird.

Für das Lizenz Management übernimmt der AN folgende Aufgaben:

- Beratung zur Optimierung der Lizenzierung
- Softwarenachweis: Revisionssichere Dokumentation der installierten Software
- Aufbewahrung und Verwaltung der Originaldatenträger
- Aufbewahrung und Verwaltung von Lizenznachweisen (Zertifikaten, Verträgen, etc.)
- Überwachung von Lizenz-Über- und -Unterdeckung
- Abgleich von Soll-Ist Beständen: Regelmäßiger Abgleich der dokumentierten Daten mit dem tatsächlichen Installationsstand und
- quartalsweise ein Bericht zum aktuellen Stand

Für durch die AG bereitgestellte Softwareprodukte und im Rahmen von BYOL eingebrachte Lizenzen trägt der AN keine Verantwortung hinsichtlich Lizenzierung oder Auditfähigkeit, außer wenn dies in Abhängigkeit der Lizenzbedingungen erforderlich ist.

#### **2.11.2 Systemdokumentation**

Der AN erstellt in der Transitionsphase, spätestens bis zur Inbetriebnahme, eine Systemdokumentation über die gesamte Infrastruktur, die im Rahmen des Managed Services in der Verantwortung des AN liegt und passt diese fortlaufend an, wenn sich relevante Änderungen an den Systemen ergeben haben. Die Systemdokumentation beinhaltet mindestens:

- Netzstrukturgrafik mit Darstellung des gesamten physikalischen und logischen IP- Netzwerkes mit allen Komponenten der zentralen Plattform und der Standortnetze (Netzwerksegmente, VLANs, IP-Adressen, DNS-Namen, Server, vServer, Gateways, Switches, WAN-Anbindung, etc.)

- schematische Darstellung der physikalischen und logischen Verschaltung der installierten Systeme und Applikationen mit Kurzbeschreibung
- Beschreibung der Schnittstellen, Verkehrsbeziehungen und Übertragungsprotokolle
- tabellarische Aufstellung der installierten Hardwarekomponenten inkl. Typ, Seriennummern, Hostname, IP-Adressenkonfiguration, Installationsort usw. (Basis für das Asset Management und CMDB) und
- tabellarische Aufstellung der auf den Servern installierten Betriebssysteme und Anwendungen mit Angabe der Release-Nummer

Die Systemdokumentation ist in elektronischer Form in einem für die jeweilige Aufgabe am besten geeigneten Standardformat (z.B. MS-Office, Visio, o.a. – die genauen Formate sind mit der AG in der Transition abzustimmen) zu erstellen und der AG zu übergeben.

### **2.11.3 Betriebshandbuch**

Der AN erstellt ein Betriebshandbuch in dem alle betrieblichen Abläufe, die Gegenstand dieser Managed Services sind, dokumentiert werden und passt dieses fortlaufend an, wenn sich relevante Änderungen an den Systemen oder Prozessen ergeben haben.

Struktur und Inhalte des Betriebshandbuchs sind auf Grundlage der nachfolgend aufgeführten inhaltlichen Anforderungen in der Transition mit der AG abzustimmen.

Der Inhalt des Betriebshandbuchs hat mindestens folgende Informationen zu umfassen:

- Richtlinien für die Betriebsdokumentation
- Übersicht und Kurzbeschreibung der Systemumgebung mit Verweis auf die entsprechenden Dokumente der Systemdokumentation
- Verfahren und Richtlinien zur Inbetriebnahme und zum Betrieb der Ports / Infrastrukturen
- Verfahren zur Entstörung
- Verfahren zum Wiederanlaufverfahren
- Verfahren und Richtlinien zur System-Administration
- Verfahren und Richtlinien für die Durchführung von Änderungen
- Verfahren, Richtlinien und Tools für die Systemüberwachung
- Verfahren, Richtlinien und Tools für die Sicherheitsanforderungen
- Ansprechpartner, Organisationsstruktur, Verantwortlichkeiten in den Serviceprozessen
- Alarmierungs- und Eskalationspläne und
- Betriebszeiten und Service Levels

Die im Betriebshandbuch beschriebenen Verfahrensweisen sind vom AN im Rahmen der Leistungserbringung zwingend einzuhalten.

### **2.12 Knowledge Management**

Das Knowledge Management ist für das systematische Erfassen, Analysieren, Speichern und Bereitstellen von Wissen und Informationen innerhalb der Service Organisation zuständig. Knowledge Management

hat das primäre Ziel, Wissen effizient verfügbar zu machen, so dass einmal erworbenes Wissen einfach abrufbar ist und nicht aufwändig wiedererlangt werden muss. Der Knowledge Management Prozess führt die benötigten Wissens-Beiträge aus anderen Prozessen zusammen und stellt sie gezielt den Prozessen zu, die diese benötigen.

Insbesondere soll das Knowledge Management sicherstellen, dass alle relevanten Akteure der BIG in der Lage sind, die bereitgestellten Dienste effizient zu nutzen. Dafür sollen Schulungsangebote etabliert werden, die von grundlegenden Bedienungsanleitungen bis hin zu fortgeschrittenen Optimierungsstrategien reichen.

Für die hier beschriebenen Aufgaben stellt der AN insbesondere die Wissensbeiträge zur Unterstützung des 1st Level Service Desk der AG und den Supporteinheiten an der Schnittstelle zu den Anwendern im Incident- und Service Request Prozess zur Verfügung. Ziel ist es, diese Supporteinheiten zu befähigen, den Anwendern in typischen Fehlersituationen, bei Bedienungsfragen in der Nutzung der Systeme und Anwendung sowie bei Verfahrensfragen (...wie und wo kann ich was bestellen? ...wer ist zuständig für?) eine Lösung oder Hilfestellung zu geben, damit Störungen erst gar nicht auftreten oder im 1st-Level-Support schnell gelöst werden können.

Dazu werden folgende Arten von Wissensbeiträgen unterschieden, für die der AN Inhalte beisteuert:

**Anwenderbezogene Wissensbeiträge:**

- Bedienungsanleitungen für Endgeräte und Dienste und
- FAQs (User Level)

**Wissensbeiträge für den 1st-Level-Support:**

- FAQs (Support Level)
- Frage-/Analysebaum zur Incident Vorqualifizierung
- Known-Error Einträge in einer Knowledge-Base des AN und
- Verfahrensanweisungen und Zuständigkeiten bei der AG

Für das Knowledge Management übernimmt der AN folgende Aufgaben:

- Erstellung und Bereitstellung von Bedienungsanleitungen für Anwender oder Anpassung dieser nach Änderungen (z. B. durch neue Releases, geänderter Funktionsumfang)
- Erstellung und Bereitstellung von FAQs für Anwender oder Anpassung dieser nach Änderungen (z. B. durch neue Releases, neue Endgeräte, geänderter Funktionsumfang). Diese FAQs decken typische Anwenderprobleme im Bereich der Bedienung von Endgeräten und Services ab inkl. Lösungsbeschreibung.
- Erstellung von FAQs für den 1st Level Service Desk und den 1st-Level-Onsite-Support oder Anpassung dieser nach Änderungen (z. B. durch neue Releases, geänderter Funktionsumfang). Diese FAQs decken gegenüber den Anwender-FAQs den gleichen Funktionsumfang ab, haben aber mehr fachlichen Tiefgang für technisch versierteres Supportpersonal ergänzt um Verfahrensbeschreibungen.
- Erstellung eines Analyse-/Fragebaums zur Erfassung des Fehlerbildes, der Störungsursache und der Auswirkung von Störungen zur Kategorisierung und Priorisierung für den 1st-Level-Support auf Basis typischer Störungssituationen und Erfahrungswerte

- Kontinuierliche Anpassung und Erweiterung des Analyse-/Fragebaums auf Basis tatsächlich eingetretener Störungen und nach Systemänderungen
- Einweisung des 1st Level Service Desk der AG in die Handhabung des Analyse-/Fragebaums

### 2.13 Service Level Management

Als zentraler Ansprechpartner für die Leistungserbringung und das Service Level Management stellt der AN einen qualifizierten, dedizierten Servicemanager. Dieser übernimmt die Koordination, die Weiterleitung, das Reporting sowie notwendige Eskalationen sämtlicher Service-, Betriebs- und Vertriebsthemen.

Der Servicemanager stellt eine Übersicht der einzelnen Schlüsselfunktionen (wie Key-Account-Manager, Manager on Duty, Eskalationsmanager) und deren verantwortlichen Personen, inkl. Vertreterregelungen, zur Verfügung.

Veränderungen werden der AG angekündigt. Die Veränderung der Zuständigkeit des Servicemanagers sowie des Eskalationsmanagers bedürfen, außer in begründeten Härtefällen, der Zustimmung der AG.

#### 2.13.1 Beschwerdemanagement

Der AN stellt der AG ein zentrales Beschwerdemanagementtool zur Verfügung. Hierin meldet die AG sämtliche Beschwerden und Auffälligkeiten, die im Rahmen der Erbringung der geschuldeten Leistung entstehen. Der Service Manager ist verantwortlich, die Beschwerden regelmäßig zu erfassen und Maßnahmen zur Abhilfe einzuleiten. Die Maßnahmen werden im Service Review Meeting dargestellt und besprochen.

#### 2.13.2 Reporting

Der AN, verantwortet durch den Service Manager, stellt der AG die nachfolgend genannten Reports über die Systeme und Services der Virtual Private Cloud, die Gegenstand des Managed Service sind, in den angegebenen Intervallen, in elektronischer Weise und in zwei Arten zur Verfügung. Gesamtdarstellungen werden revisionssicher als PDF-Dokumente bereitgestellt, die darin enthaltenen Werte werden zusätzlich in einem bearbeitbaren Excel-Format mitgeliefert.

| Report          | Inhalt                                                                                                                                                               | Frequenz* |
|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Security-Report | Übersicht aktueller sicherheitsrelevanter Incidents.<br><br>Liste aller aktuellen User.<br><br>Liste aller User mit privilegierten Berechtigungen (Administratoren). | Monatlich |

|                         |                                                                                                                                                                                                                                         |                                     |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|
|                         | Liste aktueller Rechtezuordnungen auf Freigabe- und Laufwerksebene für alle User.                                                                                                                                                       |                                     |
| SLA- und Service-Report | Übersicht über den Erfüllungsgrad aller vereinbarten Service Levels und KPIs.<br><br>Übersicht der Top-20 aller aufgenommenen Tickets nach Kategorien.<br><br>Übersicht aller Störungsursachen nach Prioritäten.                        | Monatlich                           |
| Asset-Report            | Aufstellung aller Assets mit Hardware-Merkmalen, Seriennummern, MAC-Adressen, IP-Adressen, OS, Standort, Bestelldatum und Laufzeiten.                                                                                                   | Monatlich                           |
| Change-Report           | Aufstellung aller eingereichter Service Requests (IMACD) und Change Requests (RFC) mit Benennung des Inhaltes und der Bereitstellungszeiten                                                                                             | Monatlich                           |
| Lizenz-Report           | Übersicht über den aktuellen IST-Stand der Lizenzierung und Abgleich mit Über- und Unterdeckung                                                                                                                                         | Monatlich                           |
| Plattform-Report        | Übersicht über alle aktiven Systeme mit Ausstattungsangabe, Nachweis aller Update- und Wartungsarbeiten, Nachweis aller Upgrade- und Downgrade-Maßnahmen, Übersicht der Kapazitätskennzahlen und Schwellwerterreichung mit Trendanalyse | Monatlich                           |
| Betriebs-Report         | Übersicht aller laufenden Betriebsthemen, die sich in Klärung befinden. Übersicht aus Beschwerdemanagement                                                                                                                              | Monatlich                           |
| Projekt-Report          | Übersicht aktueller Projektaktivitäten und Einhaltung der Zeitplanung, Erreichung Meilensteine, Erfüllungsgrad von Aufgaben                                                                                                             | wöchentlich bei laufenden Projekten |
| Stresstest-Report       | Auswertung einer unabhängigen Sicherheitsprüfung der Plattform                                                                                                                                                                          | Jährlich zum Termin                 |

\* Bereitstellung jeweils spätestens bis zum 10. des Folgemonats

Die wesentlichen Punkte dieser Reports werden im Service Review Meeting vorgestellt und besprochen.

### 2.13.3 Service Review Meeting

Der AN führt, in der Zuständigkeit des Service Managers, regelmäßige Service Review Meetings durch. Beispiele von Themen und Inhalten der Service Review Meetings sind:

- Darstellung von wesentlichen Veränderungen im Berichtszeitraum (Bestand, technologisch, personell)
- Empfehlung über anstehende Releases (Updates)
- Besprechung der von der AG geforderten Reports
- Verstöße gegen SLAs, Grund des Verstoßes und Auswirkungen auf die AG
- Festlegung von Vertragsstrafen für SLA-Verstöße
- Abfrage der Kundenzufriedenheit unter Einbeziehung des Beschwerdemanagements und erzielte Servicequalität und
- Besprechung von Optimierungs- und Verbesserungsmaßnahmen

In der Regel werden die Service Review Meetings einmal im Monat im Rahmen einer Webkonferenz mit Audio-, Video- und Dokumentensharing-Funktion durchgeführt. Verantwortlich für die Durchführung, Moderation und Bereitstellung von Unterlagen ist der Service Manager. Das Web-Konferenzsystem wird durch den AN bereitgestellt. Für die Teilnahme an den Service Review Meetings dürfen der AG keine zusätzlichen Kosten entstehen. Auf Verlangen der AG wird das Service Review Meeting an einem der Hauptstandorte der AG durchgeführt.

Ein erweitertes Service Review Meeting sollte mindestens zweimal jährlich sowie zusätzlich bei besonderem Bedarf angeboten werden, in dem über die monatlichen Themen hinaus Innovationsthemen dargestellt und besprochen werden. Zielsetzung ist die Weiterentwicklung der Services und die Digitalisierung des Kerngeschäftes der AG auf Basis von künftigen Entwicklungen der Technologien, des Serviceportfolios des AN, der Roadmaps der Hersteller und der Anforderungen der AG zu besprechen.

### 2.14 Capacity Management

Das Capacity Management stellt sicher, dass die Kapazität der Dienste und Infrastrukturen ausreicht, um die vereinbarten Kapazitäts- und Performance-Ziele wirtschaftlich zu erbringen. Das Capacity Management berücksichtigt alle Ressourcen, die erforderlich sind, um den Service zu erbringen und plant dabei die kurz-, mittel- und langfristigen Anforderungen ein. Der Teil-Prozess „Component Capacity Management“ überwacht die Performance, Nutzung und Kapazität der IT-Ressourcen und individueller IT-Komponenten, gibt Prognosen ab und passt die Kapazitäten ggf. an.

Das (Component) Capacity Management des AN muss sicherstellen, dass für die Erbringung der Services die erforderlichen Kapazitäten in den hier betrachteten Systemen vorgehalten werden und ausreichend Restkapazitäten für Erweiterungen zur Verfügung stehen. Der AN muss regelmäßig die Kapazitäten und Auslastung der Komponenten erfassen, mit dem Bedarf abgleichen und bei Erreichen kritischer Schwellwerte entsprechende Erweiterungsmaßnahmen initiieren. Die erfassten Kapazitätswerte werden dem Reporting zur Verfügung gestellt.

Für das Component Capacity Management übernimmt der AN folgende Aufgaben:

- Kontinuierliche Erfassung der Nutzung und Auslastung aller relevanten Komponenten
- Definition von Schwellwerten für die Kapazitäten und Abgleich mit den aktuellen Auslastungswerten
- Vorhalten von ausreichenden Restkapazitäten
- einleiten von Maßnahmen bei Erreichen oder Überschreiten von Schwellwerten über einen Change Request an das Change Management und
- bereitstellen der Auslastungswerte der aktuellen Nutzung und Trendanalyse für das Reporting

### **2.15 Availability Management**

Über den technischen und logischen Aufbau der Plattform und deren Systeme erstellt der AN eine technische Systemdokumentation (in der Transition-Phase) und passt diese fortlaufend an.

Ein Datensicherungskonzept wird in Abstimmung mit der AG erstellt und im Rahmen der Systemdokumentation und des Betriebshandbuchs dokumentiert und fortlaufend angepasst. Das Datensicherungskonzept umfasst für alle Systeme / Anwendungen folgende Informationen:

- Quelle der zu sichernden Daten
- Zielort der Datensicherung (geographisch, Zielsystem, Ordner/Container, Nomenklatur des Datensicherungssatzes)
- Art der Datensicherung (Full-, Incremental) und Zyklus
- Zeiten und Frequenz der Sicherungsläufe, Größe und geschätzte Dauer und
- Übertragungsprotokolle (verschlüsselt)

Zum Hochfahren von Systemen nach einem umfangreichen Ausfall, zur Wiederherstellung von defekten Systemen aus dem Backup oder zur Wiederherstellung von Daten aus der Datensicherung erstellt der AN einen Recovery-Plan (in der Transition-Phase) und passt diesen fortlaufend an.

Für sämtliche Serviceprozesse, insbesondere den Aufgaben, Zuständigkeiten, Verantwortlichkeiten und Verfahren an der Schnittstelle zwischen der AG und beteiligten Dritten und dem AN, erstellt der AN ein Betriebshandbuch (in der Transition-Phase) und passt dieses fortlaufend an.

### **2.16 IT Service Continuity Management**

Das IT Service Continuity Management (ITSCM) managt Risiken, die gravierende Auswirkungen auf die IT-Services haben können. IT Service Continuity Management stellt sicher, dass der AN für geschäftskritische Dienste auch im Falle außergewöhnlicher Ereignisse (Katastrophen) die Minimalanforderungen bereitstellen kann. Dies geschieht durch risikomindernde Maßnahmen und durch eine gezielte Wiederherstellungsplanung für die IT-Services. Für den AN bestehen auf Anforderung durch die AG generelle Mitwirkungspflichten für die Notfall-/Katastrophenplanung sowie bei der Durchführung von Notfallübungen oder Wiederherstellungsmaßnahmen bei eingetretenem Katastrophenfall entsprechend der in den Notfallplänen festgeschriebenen Verfahren.

In gegenseitiger Abstimmung zwischen der AG und dem AN ist mit Verweis auf relevante Anforderungen ein Konzept zu erstellen, welches das Notfallmanagement mit Schwerpunkt IT Service Continuity Management beschreibt, insbesondere:

- die Regelung und Vorsorge eines K-Falles
- wer den K-Fall ausrufen darf
- welche Maßnahmen im K-Fall durchgeführt werden und
- welche Präventivmaßnahmen zur Anwendung kommen

| Übersicht der Angaben für K-Fall-Konzept und IT Service Continuity-Plan |                                                                                                                                                                                                    |
|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Sicherungsplan nach einzelnen Systemen und Anwendungen                  | Übersicht aller gesicherten Systeme, deren Sicherungsart und -häufigkeit; Angaben zur Aufbewahrung der Sicherungsmedien; Größe der Sicherungsdaten; Angaben zur erwartenden Wiederherstellungszeit |
| Redundanzplan                                                           | Übersicht aller Systeme mit Redundanzverfügbarkeit; Beschreibung der eintretenden Einschränkungen bei Ausfall der Primärsysteme                                                                    |
| Wiederanlaufplan                                                        | Übersicht der Schritte und des zeitlichen Verlaufs bei System- und Plattformausfall                                                                                                                |

## 2.17 Information Security Management

Der AN ist verpflichtet, alle geltenden Sicherheitsanforderungen und die Richtlinien der AG sowie der gesetzlichen und regulatorischen Anforderungen, insbesondere aus DSGVO, §§ 67 ff SGB X sowie BSIG/NIS2, einzuhalten.

Der AN muss hierzu ein wirksames Informationssicherheitsmanagementsystem (ISMS) betreiben, in der Regel nach ISO/IEC 27001 oder einem gleichwertigen Standard. Entsprechende Nachweise sowie aktuelle Prüfberichte sind auf Verlangen vorzulegen.

Des Weiteren hat der AN die Einhaltung anerkannter Sicherheitsstandards für Cloud-Dienstleistungen nachzuweisen, insbesondere durch einen aktuellen Prüfbericht nach dem BSI C5-Kriterienkatalog (Typ 2) oder einen vergleichbaren Nachweis.

Insbesondere muss der AN beim Design und der Implementierung der Systeme darauf achten, dass Daten nur mit gesicherten, verschlüsselten Protokollen nach dem Stand der Technik übertragen und gespeichert werden.

### 2.17.1 Datenschutz

Der AN wird sämtliche Daten unter Beachtung der jeweils geltenden gesetzlichen Datenschutzbestimmungen, insbesondere die EU-DSGVO, BDSG sowie SGB V und SGB X in der jeweils

aktuell gültigen Fassung ausschließlich nach den Anweisungen und für Zwecke der AG verarbeiten, nutzen oder weitergeben bzw. übermitteln. Der Dienstleister wird die personenbezogenen Daten vor Missbrauch und Verlust schützen und sämtliche dazu erforderlichen technischen und organisatorischen Maßnahmen ergreifen. Die AG bleibt in jedem Fall Alleinberechtigte an den Daten. Der AG steht gegenüber dem AN ein uneingeschränktes Weisungsrecht hinsichtlich der Datenverarbeitung zu. Dies trifft auch in dem Fall zu, dass der Dienstleister aufgrund einer Insolvenz oder aufgrund einer Veräußerung die Fortsetzung des Vertrages an einen Dritten übertragen möchte bzw. muss.

Der AN wird die AG unverzüglich informieren, wenn Anweisungen der AG den gesetzlichen Datenschutzbestimmungen zuwiderlaufen. Im Rahmen der Datenverarbeitung durch den AN werden die Vertragsparteien in einer entsprechenden gesonderten Vereinbarung, die im Zusammenhang mit der jeweiligen Auftragsdatenverarbeitung entstehenden gegenseitigen Rechte und Pflichten regeln.

Die Vertragsparteien verpflichten sich gegenseitig, alle Informationen in Bezug auf die jeweils andere Vertragspartei oder auf Dritte, die sie im Zusammenhang mit den vertragsgegenständlichen Leistungen erlangen, unter Beachtung der jeweils gültigen Sicherheitsbestimmungen sowie der einschlägigen datenschutzrechtlichen Bestimmungen, geheim zu halten.

Der AN wird die AG auf Anforderung über den Ort und Inhalte der Datenspeicherung informieren und dieser eine kontrollierte Löschung bei Bedarf nachweisen.

#### **2.17.2 Sicherheitsüberprüfung und Stresstest der Plattform**

Der AN lässt in Absprache mit der AG mindestens jährlich, eine Überprüfung der gesamten Plattform sowie der eingesetzten Infrastruktur in den Standorten im Sinne einer Sicherheitsprüfung nach möglichen Sicherheitslücken und potenziellen Angriffszielen durchführen. Weiterhin ist die Plattform (zentrale Komponenten und Dienste sowie wichtige Standortkomponenten) mindestens jährlich einem Stresstest zu unterziehen. Hierbei soll die Stabilität der vorgenannten Komponenten, z. B. beim Ausfall von redundanten Komponenten, inkl. des Monitorings und dessen Reaktionsverläufen, überprüft werden. Die Auswahl des Auditors obliegt der AG in Abstimmung mit dem AN.

Sämtliche Überprüfungen werden in einer standardisierten Berichtsform dokumentiert, zwischen der AG und dem Servicemanagement des AN besprochen und entsprechende Maßnahmen daraus formuliert.

Für die Begleitung und Unterstützung bei der Durchführung der Prüfungen, die Bereitstellung relevanter technischer Informationen, die Abstimmung mit dem von der AG benannten Auditor sowie die gemeinsame Auswertung der Ergebnisse für den Stresstest Report (siehe 2.13.2) ist für den AN ein Aufwand von 5 Personentagen geplant, der im pauschalen Betriebspreis des AN inkludiert ist. Aufwände, die über das geplante Kontingent hinausgehen, können nach Aufwand gemäß den im Preisblatt definierten Stundensätzen für "Professional Service" abgerechnet werden. Die Abrechnung erfolgt dabei abhängig vom eingesetzten Skillprofil.

## 2.18 Financial Management

Die Rechnungslegung für fortlaufende Serviceleistungen durch den AN erfolgt monatlich.

Zur Rechnungsprüfung und -freigabe müssen die Rechnungen parallel dazu dem jeweiligen IT-Verantwortlichen in einem unveränderlichen elektronischen Format zugestellt werden (z. B. als PDF-Dokument per E-Mail an ein definiertes Funktionspostfach der AG). Rechnungsbegleitende Unterlagen, wie z. B. die Erhebung der Abrechnungsmengen sollten in einem elektronisch bearbeitbaren Format bereitgestellt werden (z. B. Excel oder CSV).

Grundlage für die Abrechnung von definierten, wiederkehrenden Leistungen ist das Preisblatt in der jeweils aktuell gültigen Version. Jede Rechnungsposition muss einen Bezug zum Preisblatt aufweisen. Alle anderen abrechenbaren Leistungen müssen einen Bezug zu dem jeweiligen Auftrag/beauftragten Angebot des AN aufweisen.

Die in Rechnung gestellten Verbrauchsmengen (z. B. Storagevolumen, etc.) müssen für die AG nachvollziehbar und überprüfbar sein. Die Rohdaten zur Erfassung der Mengen müssen nach einem abgestimmten Verfahren direkt aus den Systemen der AG heraus generiert werden können. Diese Rohdaten sind in unveränderter Form als rechnungsbegleitende Unterlagen der elektronischen Rechnung an den IT-Verantwortlichen zur Prüfung beizufügen. Verbrauchsmengen werden monatlich zu einem vereinbarten Stichtag ermittelt.

Weitere kaufmännische und vertragliche Bedingungen zur Rechnungsstellung wie Form und Inhalt, Zustellungsweg, Wertstellung, Zahlungsziel, Zahlungsverzug sowie Verrechnung von Gutschriften, Nachzahlungen, Vertragsstrafen, etc. werden in den Vertragswerken festgelegt.

## 2.19 Mitwirkungspflichten

Für alle Leistungen des AN gelten die in der „Anlage Mitwirkungspflichten“ im Rahmen der Angebotslegung vom AN aufgeführten Beistellungen und Mitwirkungspflichten.

### 3 Allgemeine System- und Leistungsanforderungen

#### 3.1 Allgemeine Vorbemerkungen

Im Rahmen des Managed Service werden Plattformen und begleitende Systeme in definierten Leistungsklassen durch den AN bereitgestellt und betrieben. Dabei erfolgt die Betriebsverantwortung generell bis Oberkante Betriebssystem.

Ausgenommen davon sind Systeme mit Lizenzen, die durch die AG im Rahmen von Bring-Your-Own-License (BYOL) gestellt werden, bei denen die Betriebsverantwortung bis zur darunterliegenden Computing-Infrastruktur liegt.

Die Möglichkeit zur Nutzung eigener Lizenzen im Rahmen von BYOL soll von der AG durch geeignete Maßnahmen in der Virtual Private Cloud Plattform sichergestellt werden.

Unter Plattformen verstehen sich in diesem Zusammenhang physikalische oder virtuelle Serversysteme, bestehend aus:

- Hardware (physikalisch oder virtuell)
- Betriebssystem
- Middleware (Web-Application-Server, Datenbanken)
- systemnahe Software, wie z. B. Agenten für die Datensicherung und Überwachung
- Speichersysteme gem. Anforderung
- Datensicherungssysteme und
- RZ-Umgebung (Rack, Strom, Klima, Netzwerkinfrastruktur)

Im Rahmen der Vertragslaufzeit muss es generell möglich sein, die aus dem Rechenzentrum des AN bezogen Services zu reduzieren, abzukündigen und/oder in eine neue Architektur zu integrieren. Der AN muss diesen Innovationsprozess aktiv unterstützen.

#### 3.2 Vorbemerkung zu Virtual Private Cloud / Sovereign Cloud / Public Cloud

Die AG befindet sich aktuell in einem Innovationsprozess, der ihre Systeme und Anwendungen von einer lokalen bzw. Private Cloud RZ-Infrastruktur zunehmend in eine Cloud-Infrastruktur in unterschiedlichen Ausprägungen verlagern möchte.

In Abhängigkeit von den Sicherheits- und Datenschutzanforderungen sowie der technischen Anforderungen der jeweiligen Systeme und Anwendungen, als auch der zu erwartenden Kosten, kommen die Virtual Private Cloud (VPC), gehostete Appliances innerhalb der VPC, Sovereign Cloud und Public Cloud in Betracht.

**Virtual Private Cloud (VPC):** Das Rechenzentrum für BIG soll in einer Virtual Private Cloud (VPC) bereitgestellt werden, die über entsprechende Kontroll- und Sicherheitsmechanismen ein virtuelles, für BIG abgeschottetes Netzwerk innerhalb einer Shared Cloud Infrastruktur bereitstellt, die wie ein Private Cloud Rechenzentrum genutzt werden kann.

**Gehostete Systeme in der VPC:** Spezielle Systeme, Appliances und Anwendungen, die in der Betriebsverantwortung der AG oder deren Partner liegen, sollen im Rahmen eines Hostings in einer dedizierten, geschützten Zone innerhalb der Infrastruktur der VPC betrieben werden.

**Public Cloud:** Neben dem Einsatz einer Virtual Private Cloud als Rechenzentrum für die BIG sollen unkritische IaaS- und SaaS-Services, die in der Virtual Private Cloud technisch oder wirtschaftlich nicht sinnvoll abgebildet werden können, aus der Public Cloud abgerufen werden können (siehe Punkt 5).

**Sovereign Cloud:** Als besondere Form der Public Cloud mit den üblichen Hyperscalern spielt auch die Sovereign Cloud eine wichtige Rolle, in der höhere Datenschutz- und Sicherheitsanforderungen der BIG erfüllt werden. Mögliche Public Cloud und Sovereign Cloud Anbieter sind unter Punkt 5 aufgeführt.

Im Rahmen der Vertragslaufzeit muss es generell möglich sein, die aus dem Virtual Private Cloud Rechenzentrum des AN bezogenen Services zu reduzieren, abzukündigen und/oder in Public Cloud oder Sovereign Cloud zu verlagern.

### 3.3 KRITIS Anforderungen

Die AG ist als KRITIS-relevant eingestuft. Aus diesem Grund muss der AN die daraus resultierenden Anforderungen an IT-Dienstleister nach BSIG/NIS2 sowie die hohen Datenschutzerfordernungen für Sozialdaten nach DSGVO und SGB X sicherstellen und die AG bei der Einhaltung ihrer KRITIS-Nachweispflichten vollumfassend unterstützen.

Auf Basis der KRITIS-Anforderungen gilt für die AG ein Richtlinienkatalog, der durch den AN erfüllt werden muss. Die Richtlinien sind nachfolgender Tabelle aufgeführt.

| Nr. | Name der Richtlinie                       | Kurzbeschreibung                                     | Kurzbegründung                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-----|-------------------------------------------|------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1   | 0.1 Richtlinie Informationssicherheit     | Strategische Leitplanken für Informationssicherheit. | nicht relevant für den Auftragnehmer                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 2   | 0.2 Geltungsbereich                       | Räumlicher und sachlicher ISMS-Anwendungsbereich.    | nicht relevant für den Auftragnehmer                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 3   | 0.3 Übergreifendes Konzept des ISMS       | Grundlegende Struktur und ISMS-Architektur.          | nicht relevant für den Auftragnehmer                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 4   | Richtlinie zur angemessenen Nutzung (AUP) | Zulässige Nutzung betrieblicher IT-Werte.            | Die Richtlinie richtet sich in erster Linie an Endnutzer, enthält jedoch essenzielle Vorgaben für den Umgang mit Identitäten, Endgeräten, Daten und Sicherheitsvorfällen. Diese Verhaltens- und Zugriffsregeln müssen für das künftige Betriebspersonal des Rechenzentrumsdienstleisters zwingend vertraglich, organisatorisch und technisch im Rahmen der Ausschreibung verankert werden, da dieses Personal Zugang zu kritischen Infrastrukturen und Systemen erhält. |

|   |                                                   |                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---|---------------------------------------------------|--------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5 | Richtlinie Protokollierung und Überwachung        | Überwachung sicherheitsrelevanter IT-Systemereignisse. | Die Protokollierung und Überwachung von System- und Netzwerkeignissen ist essenziell für den sicheren RZ-Betrieb, die Erkennung von Sicherheitsvorfällen und die Einhaltung regulatorischer Anforderungen (KRITIS, ISO 27001, B3S GKV/PV). Ein RZ-Dienstleister muss zwingend nachweisbare, revisionssichere und hochverfügbare Protokollierungsinfrastrukturen aufbauen und betreiben.                                                  |
| 6 | Richtlinie Schwachstellenmanagement und Pentests  | Systematische Behebung technischer Schwachstellen.     | Ein systematisches Schwachstellen- und Patchmanagement ist eine elementare Voraussetzung für den sicheren RZ-Betrieb (gemäß ISO 27001, B3S GKV/PV und KRITIS-Vorgaben). Der Betreiber muss nachweisen können, dass er Schwachstellen auf Infrastruktur-, System- und Netzwerkebene kontinuierlich identifiziert, bewertet, priorisiert und fristgerecht behebt.                                                                          |
| 7 | Richtlinie Infrastruktur- und Endgerätesicherheit | Schutz von IT-Infrastruktur und Geräten.               | Diese Richtlinie definiert essenzielle technische und bauliche Vorgaben zum Schutz der IT-Infrastruktur. Für ein Rechenzentrum sind insbesondere die Anforderungen an Systemhärtung, Ausfallsicherheit (Redundanz), Netzwerk- bzw. Umgebungstrennung, Malware-Schutz sowie physische Absicherung und Notstromversorgung zwingend für den sicheren und nachweisbaren Betrieb (KRITIS, ISO 27001, B3S GKV/PV) erforderlich.                |
| 8 | Richtlinie SSDLC                                  | Sicherheit im gesamten Software-Lebenszyklus.          | Ein RZ-Betreiber entwickelt in der Regel keine Kern-Fachanwendungen für den Auftraggeber, stellt jedoch häufig Management-Software, Kundenportale, Automatisierungsskripte oder APIs bereit. Für diese Schnittstellen sowie für die Beschaffung und Integration von Drittanbieter-Software müssen verbindliche Vorgaben zur sicheren Entwicklung, zum Schutz von Testdaten und zur Supply-Chain-Sicherheit vertraglich verankert werden. |

|    |                                                        |                                                            |                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|----|--------------------------------------------------------|------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 9  | Richtlinie Informationssicherheit im Projektmanagement | Sicherheitsintegration in alle Infrastrukturprojekte.      | Der Aufbau, die Migration sowie wesentliche Erweiterungen oder Anpassungen von Rechenzentrumsdienstleistungen sind komplexe Projekte. Der RZ-Betreiber muss nachweisen, dass er ein methodisches Projektmanagement anwendet, welches IT-Sicherheitsanforderungen, Risikobewertungen und strenge Zugriffskontrollen auf Projektinformationen von der initialen Planung bis zum Projektabschluss zwingend integriert.                   |
| 10 | Richtlinie Schutz von Aufzeichnungen                   | Schutz und Verfügbarkeit von Aufzeichnungen.               | Der Rechenzentrumsbetreiber erzeugt und verwaltet zwingend betriebs- und sicherheitsrelevante Aufzeichnungen (z. B. Wartungsprotokolle, Zutrittslogs, Audit-Nachweise, Konfigurationshistorien). Deren Integrität, Verfügbarkeit, Schutz vor Manipulation und langfristige Lesbarkeit müssen technisch und organisatorisch sichergestellt werden, um B3S-Vorgaben und Revisionsanforderungen zu erfüllen.                             |
| 11 | Richtlinie Sicherheit bei kritischen Vertragspartnern  | Informationssicherheit in externen Lieferantenbeziehungen. | Ein Rechenzentrumsdienstleister fungiert als essenzieller, kritischer Vertragspartner für den IT-Betrieb. Die Richtlinie definiert zwingende vertragliche und organisatorische Rahmenbedingungen (wie weitreichende Auditrechte, strenge Subunternehmersteuerung, Cloud-Zertifizierungen und klare Exit-Strategien), die direkt als KO-Kriterien und vertragliche Pflichten in die Ausschreibungsunterlagen integriert werden müssen. |
| 12 | Richtlinie Identitäts- und Zugriffsverwaltung (IAM)    | Verwaltung von Identitäten und Zugriffsrechten.            | Das Identitäts- und Zugriffsmanagement ist eine fundamentale Säule der Rechenzentrumssicherheit. Der RZ-Betreiber muss lückenlos nachweisen können, wie Zugriffe auf Systeme, Netzwerke und Daten (insbesondere administrative Zugriffe) kontrolliert, nach dem Minimalprinzip vergeben, funktionell getrennt und regelmäßig                                                                                                          |

|    |                                                 |                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|----|-------------------------------------------------|----------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                 |                                                                | überprüft werden, um unbefugten Zugriff zu verhindern.                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| 13 | Richtlinie Datensicherung und Wiederherstellung | Backups und zeitnahe Wiederherstellung.                        | Backup- und Restore-Fähigkeiten gehören zu den kritischen Kernleistungen eines jeden Rechenzentrums. Die Richtlinie definiert zwingende Vorgaben an Sicherungsstrategien, die Einhaltung von Wiederherstellungszeiten (RTO/RPO), Verschlüsselung, Georedundanz (Offsite-Speicherung) sowie an regelmäßige und nachweisbare Wiederherstellungstests, die ein Dienstleister zwingend erfüllen muss.                                                                                                 |
| 14 | Richtlinie zur sicheren Systemarchitektur       | Sicherheitsanforderungen bei Einführung neuer Systeme.         | Das Design und der Aufbau der Rechenzentrumsinfrastruktur erfordern ein fundamentales Sicherheitskonzept. Der RZ-Betreiber muss zwingend nachweisen, dass seine Systemarchitektur über alle Schichten hinweg nach anerkannten Prinzipien (wie Defence in Depth, Security by Design) konzipiert ist und technologische Risiken vor der Einführung systematisch bewertet werden.                                                                                                                    |
| 15 | Richtlinie Abweichungen von Richtlinien         | Prozess für Ausnahmen von Sicherheitsvorgaben.                 | Im RZ-Betrieb wird es unweigerlich zu Situationen kommen, in denen spezifische Sicherheitsvorgaben aus technischen, architektonischen oder prozessualen Gründen nicht vollständig umsetzbar sind. Ein RZ-Dienstleister muss für diese Fälle zwingend einen revisionssicheren Ausnahmeprozess (Exception Management) nachweisen, um Abweichungen kontrolliert zu steuern, kompensierende Maßnahmen zu etablieren und regulatorische Compliance (KRITIS, ISO 27001, B3S GKV/PV) aufrechtzuerhalten. |
| 16 | Richtlinie Asset Management                     | Effiziente Verwaltung und Klassifizierung von Vermögenswerten. | Das Asset Management ist das Fundament für einen sicheren und geordneten IT-Betrieb. Der RZ-Betreiber muss lückenlos nachweisen, dass er sämtliche physischen, logischen und informationstechnischen Assets                                                                                                                                                                                                                                                                                       |

|    |                                                 |                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|----|-------------------------------------------------|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                 |                                                  | strukturiert erfasst, risikobasiert klassifiziert, Lizenzen steuert und den gesamten Lebenszyklus – von der Beschaffung bis zur sicheren und nachweisbaren Löschung bzw. physischen Vernichtung – sicher verwaltet.                                                                                                                                                                                                                                           |
| 17 | Richtlinie Aufgeräumte Arbeitsumgebung          | Ordnung am Arbeitsplatz und Bildschirmsperren.   | Auch wenn in einem Rechenzentrum vorwiegend digitale Daten verarbeitet werden, verlangt der sichere Betrieb in administrativen Büros, Leitständen (NOC/SOC) und Technikräumen den strengen physischen Schutz von Ausdrucken (z. B. Netzpläne, Notfallhandbücher) und Bildschirmanzeigen. Die Verhaltensregeln für das Betreiberpersonal müssen daher vertraglich und organisatorisch verankert werden.                                                        |
| 18 | Richtlinie Business Continuity Management (BCM) | Betriebskontinuität bei Störungen und Krisen.    | Die Gewährleistung der Betriebskontinuität ist eine der wichtigsten Kernanforderungen an ein Rechenzentrum im KRITIS-Umfeld. Der RZ-Betreiber muss zwingend nachweisen, dass er über ein wirksames Business Continuity Management System (BCMS) verfügt, Notfallpläne etabliert hat, Redundanzen bietet und vertraglich definierte Wiederanlaufzeiten (RTO) sowie maximal zulässige Datenverluste (RPO) garantiert einhält.                                   |
| 19 | Richtlinie Change Management                    | Strukturierte Steuerung von IT-Systemänderungen. | Ein unkontrolliertes Ändern von IT-Systemen oder Infrastrukturkomponenten stellt ein erhebliches Risiko für die Betriebsstabilität und Sicherheit eines Rechenzentrums dar. Der RZ-Betreiber muss im Rahmen der Ausschreibung zwingend nachweisen, dass er über einen formellen, dokumentierten und risikobasierten Change-Management-Prozess verfügt, der strikte Funktionstrennungen, Genehmigungsworkflows und verbindliche Rollback-Szenarien beinhaltet. |

|    |                                 |                                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----|---------------------------------|-----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 20 | Richtlinie Funktionstrennung    | Trennung kritischer Aufgaben zur Missbrauchsverhinderung.       | Die strikte Funktionstrennung (Separation of Duties - SoD) ist eine elementare Anforderung im KRITIS- und ISO 27001-Umfeld, um Missbrauch, interne Manipulationen und unbeabsichtigte Fehler durch Einzelpersonen zu verhindern. Ein RZ-Betreiber muss nachweisen können, dass operative, administrative und kontrollierende Aufgaben personell und technisch voneinander getrennt sind.                                                                 |
| 21 | Richtlinie Incident Management  | Frühzeitige Erkennung und Bearbeitung von Sicherheitsvorfällen. | Die schnelle Erkennung und strukturierte Behandlung von Sicherheitsvorfällen ist für den ausfallsicheren und KRITIS-konformen Rechenzentrumsbetrieb essenziell. Der RZ-Betreiber muss zwingend nachweisen, dass er über geeignete Systeme zur Angriffserkennung (SzA/SIEM), ein handlungsfähiges Reaktionsteam (SOC/SIRT), definierte Eskalationsprozesse sowie Mechanismen zur fristgerechten Erfüllung von Behördenmeldepflichten (§ 8b BSIG) verfügt. |
| 22 | Richtlinie Kapazitätsmanagement | Planung und effiziente Nutzung von Ressourcen.                  | Die kontinuierliche und planbare Verfügbarkeit von physischen, informationstechnischen und personellen Ressourcen ist das Fundament eines sicheren Rechenzentrumsbetriebs. Ein RZ-Betreiber muss im Rahmen der Ausschreibung zwingend nachweisen, dass er Kapazitäten systematisch überwacht, Prognosen erstellt, Skalierungsmechanismen vorhält und Notfallpläne für Ressourcenengpässe implementiert hat.                                              |
| 23 | Richtlinie Kryptografie         | Sicherer Einsatz kryptografischer Verschlüsselungsverfahren.    | Der sichere Einsatz kryptografischer Verfahren ist essenziell für den Schutz von sensiblen und kritischen Daten (z. B. Sozial- und Gesundheitsdaten) in einem Rechenzentrum. Ein RZ-Betreiber muss zwingend nachweisen, dass er aktuelle,                                                                                                                                                                                                                |

|    |                                                        |                                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----|--------------------------------------------------------|-----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                        |                                                           | vom BSI oder NIST anerkannte Verschlüsselungsstandards für Daten in Ruhe und bei der Übertragung verwendet, veraltete Protokolle deaktiviert und ein hochsicheres, physisch geschütztes Schlüsselmanagement (KMS/HSM) betreibt.                                                                                                                                                                                                                                                         |
| 24 | Richtlinie Meldestelle, externe Informationsversorgung | Kommunikation mit Behörden und Stakeholdern.              | Für einen KRITIS-konformen Rechenzentrumsbetrieb ist eine strukturierte, abgesicherte und nachvollziehbare Kommunikation bei IT-Sicherheitsvorfällen oder Bedrohungslagen zwingend erforderlich. Der RZ-Betreiber muss technische und organisatorische Mechanismen nachweisen, um Informationen aus Frühwarnsystemen zu verarbeiten, eine zentrale Meldestelle für Vorfälle zu betreiben und sensible Informationen geschützt an den Auftraggeber oder befugte Behörden zu übermitteln. |
| 25 | Richtlinie Netzwerksicherheit                          | Umfassender Schutz der gesamten Netzwerkumgebung.         | Die Netzwerksicherheit bildet das technische Fundament eines jeden Rechenzentrums. Die Richtlinie formuliert zwingende Vorgaben an die Perimeter-Sicherheit (Firewall, WAF, DDoS-Schutz), Netzwerksegmentierung (Zonenkonzepte, DMZ), strikte Zugangskontrollen (NAC, VPN), Netzwerkhärtung sowie die regelmäßige Überprüfung von Regeln und Systemen, welche für den RZ-Betreiber als verbindliche technische Kriterien in die Ausschreibung einfließen müssen.                        |
| 26 | Richtlinie Risikomanagement (RM)                       | Systematische Identifizierung und Behandlung von Risiken. | Das Risikomanagement ist ein zentrales Steuerungselement im KRITIS-Umfeld. Da der Auftraggeber auch bei einer Auslagerung von Dienstleistungen (Outsourcing) die volle Verantwortung für das Risikomanagement behält, muss der RZ-Betreiber zwingend nachweisen, dass er ein kompatibles, strukturiertes Risikomanagement betreibt, Risiken systematisch mindert (ohne unzulässige                                                                                                      |

|    |                                                             |                                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|----|-------------------------------------------------------------|--------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                             |                                                              | Risikoakzeptanz) und den Auftraggeber über einen Risikobehandlungsplan kontinuierlich in sein Reporting einbindet.                                                                                                                                                                                                                                                                                                                    |
| 27 | Richtlinie Schulungen und Awareness                         | Sensibilisierung der Mitarbeiter für Informationssicherheit. | Die Sicherheit eines Rechenzentrums hängt maßgeblich vom Sicherheitsbewusstsein und der Fachkompetenz des eingesetzten Personals ab. Da der RZ-Betreiber als externer Dienstleister agiert, muss er vertraglich zwingend verpflichtet werden, sein eigenes Personal sowie Subunternehmer regelmäßig zu schulen, zielgruppenspezifische IT-Security-Kompetenzen für Administratoren aufzubauen und dies dem Auftraggeber nachzuweisen. |
| 28 | Richtlinie baul. physische Sicherheit                       | Physischer Schutz von Gebäuden und Technik.                  | Die bauliche und physische Sicherheit bildet die elementare Grundlage eines jeden Rechenzentrums. Die Richtlinie formuliert zwingende bautechnische Vorgaben (wie Brandschutz nach DIN 4102-1/EN 13501), strikte Perimeter- und Zutrittskontrollen, lückenlose Überwachung sowie Anforderungen an redundante Versorgungsstrukturen (Strom, Klima), die als harte K.O.-Kriterien in der RZ-Ausschreibung verankert werden müssen.      |
| 29 | Richtlinie für personelle/ablauforganisatorische Sicherheit | Sicherheit in HR-Prozessen und Abläufen.                     | Der sichere Betrieb eines Rechenzentrums ist in hohem Maße von der Zuverlässigkeit und Integrität des eingesetzten Personals abhängig. Der RZ-Betreiber muss zwingend nachweisen, dass er strenge personelle Sicherheitsmaßnahmen (z. B. Hintergrundüberprüfungen, Vertraulichkeitsvereinbarungen) anwendet und gleichzeitig sämtliche kritischen IT-Betriebsabläufe lückenlos und standardisiert dokumentiert hat.                   |

|    |                                                     |                                                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----|-----------------------------------------------------|------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 30 | Richtlinie zum Einsatz von KI                       | Sicherer und rechtskonformer Einsatz von KI.               | Setzt der Rechenzentrumsbetreiber zur Erbringung seiner Dienstleistungen (z. B. für automatisiertes Netzwerk-Monitoring, prädiktive Kapazitätssteuerung, intelligente Klimatisierung oder Cyber-Abwehr) Systeme der Künstlichen Intelligenz (KI) ein, müssen diese zwingend nach den Vorgaben der EU-KI-Verordnung und des B3S klassifiziert, überwacht und transparent gemacht werden. Der Schutz von Sozialdaten (Kein KI-Training mit Echt-Daten) hat hierbei höchste Priorität. |
| 31 | Richtlinie zum Erstellen/Managen von Dokumenten     | Lebenszyklus-Steuerung aller dokumentierten Informationen. | Ein Rechenzentrumsbetrieb erfordert eine lückenlose, revisionssichere Dokumentation sämtlicher IT-Prozesse, Sicherheitskonzepte und Architekturen. Der RZ-Betreiber muss zwingend nachweisen, dass er ein formalisiertes Dokumentenmanagementsystem (Lifecycle, Versionierung, Zugriffsschutz) betreibt und dem Auftraggeber jederzeit aktuelle Nachweise und Konzepte bereitstellen kann.                                                                                          |
| 32 | Richtlinie Überprüfung des ISMS                     | Interne Auditierung und Wirksamkeitsprüfung des ISMS.      | Ein RZ-Betreiber muss für kritische Infrastrukturen zwingend nachweisen, dass seine etablierten Sicherheitsmaßnahmen im laufenden Betrieb nicht nur existieren, sondern kontinuierlich auf Wirksamkeit und Konformität geprüft werden. Die Richtlinie definiert verbindliche Fristen für Audits, das Patch-Management (60 Tage) sowie den Umgang mit Nichtkonformitäten, welche in Service-Level-Agreements (SLAs) der Ausschreibung verankert werden müssen.                       |
| 33 | Richtlinie Überprüfung und Freigabe von Richtlinien | Regelmäßiger Prozess zur Richtlinien-Aktualisierung.       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

Tabelle 3 - KRITIS Richtlinien

Aus diesen Richtlinien abgeleitet gelten die in „**Anhang 3a KRITIS-Anforderungen**“ aufgeführten Anforderungen im Detail.

### **3.4 Anforderungen an das Rechenzentrum (Virtual Private Cloud)**

An das Rechenzentrum werden in Bezug auf die Architektur, Betrieb, Ausfallsicherheit, Fehlertoleranz, Datenschutz und IT-Sicherheit die Anforderungen nach allgemein anerkannten Standards und Best Practices zum Stand der Technik gestellt.

#### **3.4.1 Qualitätsanforderungen an das RZ**

##### **3.4.1.1 A-Kriterien Qualitätsanforderungen an das RZ**

Folgende Anforderungen an das Rechenzentrum müssen für die RZ-Komponenten und die Managed Services im Rahmen der hier geforderten Leistungen erfüllt werden:

- Erfüllung der KRITIS Anforderungen an RZ gemäß BSI
- ISO 27001 zertifiziert
- BSI C5 Typ 2 Testat
- Erfüllung der Anforderungen aus SGB V und SGB X, insbesondere
  - § 217f Abs. 4b SGB V
  - §284 SGB V
- Betrieb nach DSGVO und BDSG
- Datenhaltung innerhalb EU
- HV/Georedundant
- EN 50600 Verfügbarkeitsklasse mindestens VK3 (oder vergleichbar)

##### **3.4.1.2 B-Kriterien Qualitätsanforderungen an das RZ**

Darüber hinaus wird erwartet, dass der AN folgende Anforderungen der AG an das RZ erfüllen kann, die als Bewertungskriterien herangezogen werden:

- EN 50600 Verfügbarkeitsklasse AK4
- Datenhaltung innerhalb Deutschland
- ISO/IEC 27017 (Cloud Security)
- ISO/IEC 27018 (Datenschutz in Cloud)
- ISO 9001:2015 zertifizierte Betriebsprozesse
- ISO 22301 (Business Continuity Management)
- PCI DSS (oder vergleichbar)
- Listung bei Trusted Cloud e.V. (oder vergleichbar)

Die Nachhaltigkeit hat für BIG einen hohen Stellenwert und der AN muss der AG auf Anforderung alle relevanten Umwelt-, Energie- und Nachhaltigkeitskennzahlen bereitstellen, die zur Erfüllung regulatorischer, aufsichtsrechtlicher oder berichtsbezogener Anforderungen der AG erforderlich sind.

Nachfolgend eine Aufstellung an Nachweisen zur Nachhaltigkeit, die vom AN erwartet werden und als Bewertungskriterien herangezogen werden:

- ISO 14001 Umweltmanagement (oder vergleichbar)
- Zertifizierung Blauer Engel für Rechenzentrum (DE-UZ 228) oder vergleichbar
- LEED-Zertifizierung (Leadership in Energy and Environmental Design)
- 100% Ökostrom
- ISO 50001
- Power Usage Effectiveness (PUE)
- Water Usage Effectiveness (WUE)
- Energieeffizienzrichtlinie der EU (EED)
- Einhaltung des DNSH-Prinzips „Do No Significant Harm“
- Climate Neutral Data Centre Pact
- Corporate Sustainability Reporting Directive (CSRD)

### 3.4.2 Performance-Anforderungen

Die Performance des Systems und der Netzwerkinfrastruktur muss so ausgelegt sein, dass akzeptable Antwortzeiten für den Anwender bei interaktiven Anwendungen, sowie bei transaktionsbasierten Systemen erzielt werden, die eine flüssige Benutzererfahrung ohne wahrnehmbare Verzögerungen erlauben.

Als akzeptable Grenzwerte im Sinne von Service Level Objective (SLO) können beispielhaft angesehen werden:

- Interaktive Anwendung:
  - Klick / Menü öffnen: < 100 – 500 ms
  - Dateneingabe / Bestätigung: <1 Sekunde
  - Seitenwechsel / Navigation: < 2 Sekunden
- Transaktionsbasierte Systeme
  - Datenbankabfrage: <1 Sekunde
- Rechenintensive Cloud-Anwendungen
  - API-Response für Standardanfragen: <1 Sekunde
  - Komplexe Datenbankabfragen: < 5 – 10 Sekunden
- Echtzeitanwendungen
  - VoIP Sprachübertragung: <150 ms

Werden diese Performance-Werte überschritten, so ist der Auftragnehmer dazu verpflichtet, im Rahmen der angebotenen Leistung proaktiv Best-Practice-Lösungen vorzuschlagen und deren Umsetzung bei der AG zu unterstützen.

Darüber hinaus sind für die Clients der VDI-Infrastruktur folgende weitere Performance-Parameter abzubilden und die möglichen SLOs zu benennen:

#### Metriken zur Benutzerfreundlichkeit

- Anmeldezeiten: Die Zeit, die die Benutzer benötigen, um sich bei ihren virtuellen Desktops anzumelden. Durchschnittliche Anmeldezeit: <30s
- Antwortzeiten der Anwendungen: Die Geschwindigkeit, mit der Anwendungen auf Benutzerbefehle reagieren.

- Sitzungsstabilität: Die Konsistenz und Stabilität von Benutzersitzungen während VDI-Interaktionen.

#### Metriken zur Ressourcenauslastung

- CPU-Auslastung: Der Prozentsatz der CPU-Kapazität, der von VDI-Sitzungen genutzt wird.  
Pro Worker Last im:  
1-min Durchschnitt < 80%  
5 min Durchschnitt < 75%  
60 min Durchschnitt < 70%
- Speicherauslastung: RAM-Auslastung pro Hypervisor-Host, der von virtuellen Desktops und Anwendungen verbraucht wird < 80% pro Worker
- Speicher-E/A-Raten: Die Rate der Dateneingabe/-ausgabe von Speichergeräten

#### Netzwerk-Leistungsmetriken

- Netzwerk-Latenzzeit: Die Zeit, die Datenpakete für die Übertragung zwischen den Endpunkten benötigen <=6ms (innerhalb Komponente AN)
- Bandbreitennutzung: Das Ausmaß, in dem die Netzwerkbandbreite während des VDI-Betriebs genutzt wird.
- Packet Loss: Die Rate der Datenpaketverluste während der Übertragung <0,1%

#### Metriken zur Anwendungsleistung:

- Anwendungsstartzeiten: Die Dauer für den Start von Anwendungen auf virtuellen Desktops.
- Antwortzeiten der Anwendungen: Die Geschwindigkeit, mit der Anwendungen auf Benutzerinteraktionen reagieren.

### 3.4.3 Anforderungen an die Server-Infrastruktur

Eingesetzte Hardware entspricht aktuellen Industriestandards und ist marktgängig. Eingesetzte Virtualisierungssoftware entspricht aktuellen Industriestandards und ist marktgängig. Für Serverinstanzen, die für 3rd-Party-Anwendungen bereitgestellt werden, werden vorgenannte Wartungs- und Serviceumfänge im gleichen Umfang durchgeführt. Eventuell erforderliche zusätzliche Betriebsaufgaben werden für jedes System nach Vorgaben des 3rd-Party-Anbieters vereinbart.

### 3.4.4 Verfügbarkeiten

Für die Managed Services und die damit verbundenen Systeme werden folgende Verfügbarkeitsklassen gefordert:

| Verfügbarkeitsklasse | Verfügbarkeit pro Monat |
|----------------------|-------------------------|
| 1                    | 99,95%                  |
| 2                    | 99,90%                  |
| 3                    | 99,50%                  |

**Tabelle 4: Verfügbarkeitsklassen**

Die Zuordnung der Verfügbarkeitsklassen zu den Serviceklassen erfolgt in der „Anlage Service Level Agreements“ und im Preisblatt wird die Serviceklasse den jeweiligen Diensten zugeordnet.

**3.4.5 Sicherheitsanforderungen an das RZ**

Alle Systeme sollten über eine sichere Grundkonfiguration gem. BSI-Grundschutzhandbuch verfügen. Ziele einer sicheren Grundkonfiguration müssen sein, dass:

- das System gehärtet ist und alle unnötigen Dienste und Ports deaktiviert sind
- das System gegen Angriffe über das Netz abgesichert ist
- ein nicht berechtigter Benutzer keinen Zugriff auf sensitive Daten erlangen kann, die nicht für ihn bestimmt sind
- kein normaler Benutzer beim normalen Arbeiten mit dem System durch reine Bedienungsfehler oder Leichtsinn schwerwiegenden Schaden am System oder an Daten anderer Benutzer verursachen kann, und dass
- auch für die Arbeiten des Systemadministrators die Auswirkungen kleinerer Fehler so weit wie möglich begrenzt sind.

Die Einstellungen, die im Rahmen der Grundkonfiguration überprüft und angepasst werden sollten, betreffen insbesondere die folgenden Bereiche:

- Einstellungen für den Systemadministrator
- Einstellungen für die Systemverzeichnisse und –dateien
- Einstellungen für Benutzerkonten
- Bereinigung der Benutzerdatenbank
- Überprüfung der Netzdienste
- Einstellungen für den Zugriff auf das Netz und
- Anlegen einer Integritätsdatenbank

Alle Systeme müssen standardmäßig mit Sicherheitsvorrichtungen zum Schutz vor Malware, Hackern und verborgenen Eindringlingen ausgestattet werden.

Zudem sind folgende Aspekte aufgrund der KRITIS-Anforderungen im Betrieb des RZ und der Dienstleistung nachzuweisen:

- Informationssicherheitsprozesse/ISMS
- Zugriffsschutz und Berechtigungsvergabe
- Asset-Management
- Personalsicherheit (HR-Security)
- Physische Sicherheit und Zutrittsschutz
- Operationelle IS-Anforderungen (Netzwerksicherheit, Virenschutz, Logging & Monitoring, Backup & Restore, etc.)
- Sicherheit in der Softwareentwicklung und Change-Prozesse
- Security-Incident-Management / Incident Handling

- Sicherheit in ausgelagerten Prozessen

### **3.4.6 Notfallvorsorge**

Um Systeme im Notfall schnell wiederherzustellen, müssen diese (virtuelle Maschinen, physikalische Systeme und ggfs. LUN) regelmäßig gesichert werden und ein Notfallplan zur Wiederherstellung in Abstimmung mit der AG erstellt werden. Diese muss technische und organisatorische Maßnahmen enthalten zur:

- Backup- und Disaster Recovery Strategie
- Notfall- und Wiederherstellungspläne
  - Notfallpläne für verschiedene Szenarien
  - Eskalationswege und Verantwortlichkeiten inkl. Kontaktlisten
  - Jährliche Notfallübungen / Wiederanlauftests
- Compliance Anforderungen

### **3.4.7 Anforderungen Virenschutz**

Im Rahmen des Virenschutzes sind seitens des AN folgende Anforderungen als optionale Leistungen abzubilden.

**Hinweis:** Der AG wird zu Vertragsbeginn notwendige Applikationen und Systeme hierzu beistellen und ggf. während der Vertragslaufzeit die Leistungen über der AN beziehen:

Virenschutz für Endpunkte:

- Intelligente Scans - durch die zentralen Scans werden Sicherheitsaufgaben auf virtuelle Sicherheits-Appliances ausgelagert
- Sicherheits-Agent mit Umgebungserkennung
- Ressourcenoptimierung für physische Maschinen
- mehrstufige Sicherheit für Endpunkte: Viren- und Malware-Schutz mit verhaltensbasierter Überwachung, Schutz vor Zero-Day-Bedrohungen, Anwendungssteuerung und Sandboxing, Firewall, Geräte- und Inhaltssteuerung
- Schutz vor Viren, Malware, Spyware, Phishing, Trojanern und Rootkit-Erkennung und
- verhaltensbasierte Überwachung und Anwendungssteuerung

Virenschutz für die Plattform:

- Bietet umgehend Schutz vor permanenten Malware-Angriffen einschließlich Sandbox-Analysen, die mithilfe von Malware-Schutz und Web-Reputation die Erkennung komplexer Bedrohungen und die Beseitigung verdächtiger Objekte ermöglichen
- wehrt Angriffe auf ungepatchte Schwachstellen mittels Intrusion Prevention (IDS/IPS) ab. Sicherheitsrichtlinien werden automatisch aktualisiert und sorgen dafür, dass der richtige Schutz rechtzeitig auf die richtigen Server angewandt wird
- erkennt und sperrt automatisch unzulässige Software dank Applikationskontrolle auf Serverebene

- unterstützt die Compliance und erfüllt Ihre Datei und Systemüberwachungsanforderungen mit Hilfe der Integritätsüberwachung
- erkennt wichtige Sicherheitsereignisse, die sich in mehreren Log-Einträgen verbergen, mit Hilfe der Log-Überwachung und
- schützt Docker Container auf dem Host in all ihren Umgebungen

### 3.5 Innovationsklausel

Der AN verpflichtet sich, die bereitgestellten IaaS-Dienste im Rahmen des Managed Service während der gesamten Vertragslaufzeit kontinuierlich weiterzuentwickeln und an den aktuellen Stand der Technik sowie an bewährte Verfahren im Bereich Cloud-Infrastrukturen anzupassen.

Im Sinne der kontinuierlichen Dienstverbesserung sind insbesondere folgende Aspekte regelmäßig zu prüfen und bei positiver Bewertung schrittweise umzusetzen:

- Einführung neuer Technologien zur Automatisierung, Orchestrierung und Skalierung
- Anpassung an neue regulatorische und technische Standards
- Sicherheitsinnovationen zur Erhöhung des Schutzes von Daten und Systemen
- Erweiterung von Self-Service-Funktionalitäten
- Integration von AI/ML-gestützten Optimierungs- oder Monitoring-Tools
- Verbesserung der Nachhaltigkeit und Ressourceneffizienz

Der AN stellt sicher, dass mindestens einmal jährlich ein Innovationsworkshop mit der AG stattfindet, in dem aktuelle technologische Trends und mögliche Verbesserungen für die IaaS-Dienste vorgestellt und gemeinsam bewertet werden.

Die AG kann auf dieser Basis angemessene und wirtschaftlich zumutbare Weiterentwicklungen beauftragen. Die Umsetzung dieser Maßnahmen erfolgt im Rahmen der bestehenden Vertragsbeziehungen oder – bei wesentlichen Änderungen – nach gesonderter Vereinbarung.

#### **4 Leistungsbeschreibung Managed Services**

Nachfolgend sind die seitens des AN abzubildenden Managed Services beschrieben. Zusätzlich zu den Managed Services stellt der AN über ein Rechenzentrum eine Plattform bereit, mit der die Managed Services bereitgestellt, betrieben und administriert werden. Die Plattform obliegt dem AN und wird nicht gesondert beauftragt und abgerechnet. Dabei erfolgt die Betriebsverantwortung generell bis Oberkannte Betriebssystem. Die Anforderungen an diese Plattform sind in Abschnitt 4.1.4 näher erläutert.

Ungeachtet der hier erfolgten Detailierung sind die in Abschnitt 2 formulierten generellen Leistungen zu den Serviceprozessen, die zum Management, Betrieb und Support der Managed Services erforderlich sind vom AN zu erbringen.

Das Verrechnungsmodell und die Preisbildung für die Managed Services ist in der „Anlage Preisblatt“ beschrieben. Anforderungen an die Servicequalität sind in der „Anlage Service Level Agreements“ beschrieben. Darüber hinaus erbringt der AN Leistungen zur Service Transition und Transformation zur Inbetriebnahme der Managed Services wie in der „Anlage Transition“ beschrieben.

##### **4.1 Basis Infrastrukturdienste**

Die Basis Infrastrukturdienste umfassen die grundsätzlichen Dienste, die erforderlich sind, um die Plattform zu betreiben und nutzen zu können und sind integraler Bestandteil der abrufbaren IaaS- und SaaS-Dienste.

###### **4.1.1 Konnektivität**

Derzeit verfügt die AG über ein SD-WAN-Netzwerk, welches alle Standorte der AG miteinander verbindet. Im Zuge der Bereitstellung aus dem Rechenzentrum des AN fordert die AG die Anbindung des Rechenzentrums an dieses Netzwerk sowie eine Zusammenarbeit mit dem Betreiber des Netzwerks.

Die nachfolgende Abbildung stellt die Zielarchitektur für die Konnektivität dar:

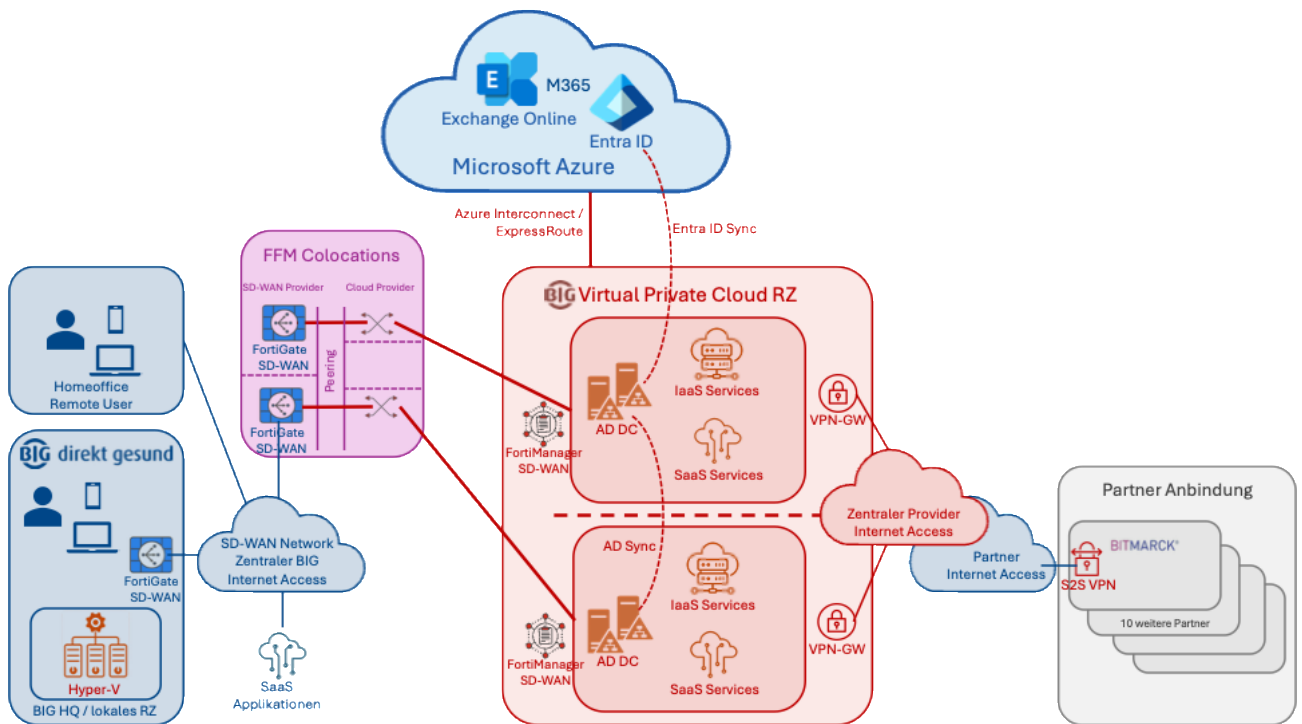


Abbildung 1 - Architektur der Konnektivität

Von der AG betriebene Infrastruktur:

- Die Standorte der BIG sind primär über SD WAN auf Basis von Fortinet Gateways (FortiGate) angebunden und terminieren am RZ Standort des SD-WAN Providers in einem Carrier-neutralen Rechenzentrum in der Metropolregion Frankfurt am Main.
- Der Zugriff aus dem Home Office erfolgt per VPN Verbindung. Die VPN Verbindung terminiert ebenfalls am RZ Standort des SD-WAN-Providers.
- Der zentrale BIG Internet Access wird ebenfalls über den SD-WAN Provider realisiert.

Allgemeine Anforderung an die Konnektivität:

- Für den Zugriff der Mitarbeiter aus den Standorten der BIG und aus den Home Office auf die Managed IT-Services des AN über das SD-WAN Netz müssen die RZ-Standorte des AN an den Terminierungspunkt der zentralen FortiGate des SD-WAN Providers angebunden werden. Dazu muss der AN ein Peering über ein oder zwei der nachfolgende aufgeführten Carrier-neutralen Rechenzentrum in der Metropolregion Frankfurt am Main zur Infrastruktur des SD-WAN Providers herstellen:
  - Equinix FR2, Kruppstraße 121-127, 60388 Frankfurt am Main  
<https://www.equinix.com/de/de/data-centers/europe-colocation/germany-colocation/frankfurt-data-centers/fr2>

- Equinix FR5, Kleyerstrasse 88-90, 60326 Frankfurt am Main  
<https://www.equinix.com/de/de/data-centers/europe-colocation/germany-colocation/frankfurt-data-centers/fr5>
- Equinix FR4, FR6  
<https://www.equinix.com/de/de/data-centers/europe-colocation/germany-colocation/frankfurt-data-centers/fr4>  
<https://www.equinix.com/de/de/data-centers/europe-colocation/germany-colocation/frankfurt-data-centers/fr6>
- Equinix FR7 Gutleutstraße 310, 60327 Frankfurt am Main  
<https://www.equinix.com/de/de/data-centers/europe-colocation/germany-colocation/frankfurt-data-centers/fr7>
- Gutleutstraße 310, 60327 Frankfurt am Main
- Telehouse Deutschland GmbH. Kleyerstraße 75-87, 60326 Frankfurt am Main  
<https://www.telehouse-rechenzentrum.de/>
- NTT FRA1 Eschborner Landstraße 100, 60489 Frankfurt-Mitte-West  
<https://services.global.ntt/de-de/services-und-produkte/global-data-centers/globale-standorte/emea/frankfurt-1-data-center>
- Digital Realty Campus Ostend FRA1-FRA16, FRA18  
<https://www.digitalrealty.com/de/data-centers/emea/frankfurt>
- Es werden keine variablen Kosten nach Übertragungsvolumen akzeptiert. Die Verrechnung der Konnektivität erfolgt nach Bandbreite der Konnektivität und Ausbaustufe der Systeme.

Folgende Leistungen zur Herstellung der Konnektivität sind durch den AN zu erbringen:

- Bereitstellung der Netzwerkverbindung zum Peering mit dem SD-WAN Provider mit folgenden Spezifikation:
  - Redundant active/active
  - Port-Speed 2x 100 Gbit/s
  - Committed Access Rate 2x 10 Gbit/s, skalierbar bis zur Port Speed
  - Latenz maximal 3ms RTD zwischen FortiGate des SD-WAN Providers und den FortiManager, die im RZ des AN gehosteten werden
- Zentraler Internetzugang (siehe 4.2.6 Internet Anbindung)
  - Für die Site-to-Site VPN-Anbindung der Partner der AG
  - für den Zugriff aus dem Internet auf die im RZ bereitgestellten IaaS- und SaaS-Services
- Azure Interconnect / Express Route zu Microsoft Azure
- die Skalierung auf die von der AG benötigten Kapazitäten und Performance
- Sicherstellung der Verfügbarkeit und Performance über die vereinbarte Vertragslaufzeit

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Gesamt Betriebsverantwortung für die Konnektivität
- Koordinationsaufgaben bei Partnern der AG

- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb der Netzwerk-Infrastruktur
- Betriebsdokumentation im Betriebshandbuch

#### Configuration Management

- Einrichtung der Netzwerkverbindungen
- Einrichtung CoS / QoS auf der Netzwerkverbindung
- Konfiguration der IP-Adressstruktur
- Konfiguration Routing/Switching
- Einrichtung Monitoring

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Überwachung der Verfügbarkeit und Performance
- Analyse von Performance Problemen
- Interdisziplinäre Störungsbeseitigung mit dem SD-WAN Partner des AG und den Netzbetreibern

#### 4.1.2 Active Directory

Der AN stellt einen Verzeichnisdienst auf der Basis von Microsoft Active Directory, inkl. aller erforderlichen Netzwerkdienste, wie DNS und WINS, bereit und betreibt diesen.

Der Dienst Active Directory Services hat eine Abhängigkeit zu den Diensten DHCP, DNS und WINS. Diese Dienste sind ebenfalls im Rahmen von Active Directory Services durch den AN bereitzustellen und zu betreiben.

Das bestehende Active Directory der AG muss in seiner gesamten Struktur vom AN übernommen und auf die neue Plattform migriert werden.

Active Directory (AD) ist ein Verzeichnisdienst von Microsoft, der als Grundlage für verschiedene weitere Microsoft Services wie Exchange oder SQL dient. Mithilfe von Active Directory werden Benutzer und deren Attribute wie Telefonnummern, Passwörter und Email-Adressen, aber auch Objekte wie Drucker, Server, Scanner etc. angelegt und verwaltet. In dem Verzeichnis sind die Nutzer und ihre jeweiligen Gruppenzugehörigkeiten hinterlegt. Darüber hinaus ermöglicht AD den Zugriff auf Objekte wie Druckerressourcen, Computerkonten, Benutzerkonten und unterschiedliche Organisationseinheiten. Die Verwaltung und Ablage der Objekte erfolgt in Containern, sog. Organisationseinheiten, die wiederum anhand der Organisationsstruktur aufgebaut werden können.

Die Hauptkomponenten des Active Directory sind:

- Lightweight Directory Access Protocol (LDAP), ein offenes Protokoll, mit dem der Zugriff auf das Active Directory erfolgt
- Kerberos-Protokoll, ein Protokoll mit dem Benutzer für den Zugriff auf bestimmte Dienste innerhalb des Netzwerks authentifiziert werden können
- Domain Name System (DNS), ein Protokoll welches für die Computernamensverwaltung innerhalb des Netzwerkes eingesetzt wird
- WINS, ein Protokoll, welches vergleichbar mit DNS ist und in manchen Anwendungsfällen aus Kompatibilitätsgründen eingesetzt wird
- Dynamic Host Configuration Protocol (DHCP), ein Protokoll, welches den am Computernetzwerk teilnehmenden Clients automatisiert IP-Adressen zuweist

Das Standarddesign für das Active Directory sieht folgenden Aufbau vor und muss mindestens erfüllt werden:

- 4 Domain Controller in 2 Clustern auf zwei georedundante RZ-Standorte (Standort A (primär) / Standort B sekundär)
- Jeder Domain Controller virtualisiert in eigener VM nur mit essenziellen Diensten
- Domain Controller laufen immer auf unterschiedlichen Hypervisor Hosts
- Anti Affinity Regel: Kein DC-Paar auf demselben Host
- Physische Netzsegmentierung
  - Servernetz (VM Traffic)
  - Managementnetz
  - Replikations- /Inter-Site-Traffic
  - Optional: Backup Netz
- Netzperformance:

- Niedrige Latenz zwischen DCs (<10 ms intersite)
  - Stabiler DNS Zugriff
- Keine State Inspection zwischen DCs

Anforderung an das Active Directory:

- Dimensionierung auf die erforderlichen Kapazitäten für Objekte:
  - Benutzerkonten: 2608
  - Computerkonten: 767
  - Gruppen: 3491
  - Gruppenrichtlinienobjekte: 141
  - Druckerobjekte: 28
  - DNS-Objekte: 2
  - Zertifikatsobjekte: 85
  - Anzahl DNS Zonen: 32
  - Reserve für mindestens 1.000 zusätzliche Objekte
- Performance KPIs:
  - DNS-Queries pro Sekunde: 98580 durchschnittlich
  - Dynamische DNS-Updates pro Sekunde: 3231 durchschnittlich
  - LDAP Response Time < 50 ms
  - Kerberos Authentication Latency < 20 ms
  - DNS Response Time < 20 ms
  - Storage Read Latency < 10 ms
  - Storage Write Latency < 15 ms
  - GPO Processing Time < 30 s
  - Replikation Intra-Site: Sekunden
  - (Replikation Inter-Site: < 15 Minuten)
- Verfügbarkeit > 99,99 %

Folgende generelle Leistungen sind durch den AN zu erbringen:

- die initiale Installation des Microsoft Active Directory Services
- Migration der AD-Strukturen und Objekte aus dem vorhandenen AD
- Konnektivität zu Microsoft Entra ID und Synchronisation
- die Skalierung auf die seitens der AG benötigten Kapazitäten und
- Sicherstellung der Serververfügbarkeit über die vereinbarte Vertragslaufzeit

Im Detail sind durch den AN folgende Leistungen zu erbringen:

Betriebsleistungen:

- Gesamte Betriebsverantwortung Active Directory Services
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung der Koordinationsaufgaben der AG
- Betrieb des Betriebssystems
- Betrieb bis Unterseite Betriebssystem (Hypervisor)

- Betrieb DHCP, DNS, WINS
- Anpassung Betriebssystemparameter nach Vorgaben des Verantwortlichen für die Applikation (z. B. AD-Schema)
- Neustart der Serversysteme bei Störungen im Betriebssystem oder auf Anforderungen des Verantwortlichen für die Applikation
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation und
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management:

- Update und Migration von Major Releases
- Einspielen von Betriebssystem Patches und
- Einspielen von Applikations Patches

#### Configuration Management

- Administration sämtlicher Applikationsparameter
- Festlegung und Freigabe der AD-Struktur
- Anlegen und Konfiguration von DNS Zonen/Alias
- Anlegen und Konfiguration von DHCP Scopes/Reservierung und
- Bereitstellung von DNS- Namen und Servernamen

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen. **Ausnahme:** Notwendige Lizenzen des Herstellers Microsoft werden durch die AG gestellt.

#### Administration

- Verwaltung und Pflege Active Directory Database
- Anlegen von Benutzerkonten
- Markieren von Funktionsaccounts
- Administration von Objekten (Benutzer, Gruppen, OUs, Computer, Drucker, Gruppenrichtlinien etc.)
- Überprüfung AD-Diensten (Monitoring) und AD-Replication
- Administration Einträge im DNS Server
- Administration Einträge im WINS Server und
- Restore von erforderlichen Konfigurationsdaten und Active Directory Objekten

#### 4.1.3 Logging und Monitoring

Zur Gewährleistung der Betriebssicherheit, Leistung, Verfügbarkeit und Compliance der Cloud-Services und um Probleme frühzeitig zu erkennen und die Infrastruktur zu optimieren, betreibt der AN ein Logging mit zentraler Erfassung der Log-Daten der Infrastruktur sowie Monitoring und Analyse der Log-Daten.

Grundsätzlich unterliegen die Log-Daten den Datenschutzanforderungen und es muss sichergestellt werden, dass die Datenhoheit bei der AG verbleibt und diese über ein entsprechendes Berechtigungskonzept Zugriff auf die Log-Daten der Systeme in Ihrer Verantwortung bekommen und festlegen können, welche Daten an das SOC zur Analyse freigegeben und übertragen werden.

##### Anforderungen an das Logging

- Erfassung der Ereignisprotokolle (Systemlogs / Anwendungslogs / Netzwerklogs / Sicherheitslogs, Firewalllogs)
- Audit-Logs zur Dokumentation von Benutzeraktivitäten, compliant zu ISMS nach ISO 27001
- Error Logs
- Aggregation der Log-Daten in einem zentralen System zur Analyse mit Analysetools wie Logstash, Elasticsearch, Kibana, oder Splunk
- Möglichkeit zum Export von Logdaten an das zentrale SIEM

##### Anforderungen an das Monitoring

- Betrieb eines Monitoringsystems zur permanenten Überwachung der Systeme (Infrastruktur, Anwendungen, IDS/IPS; Netzwerk, Benutzeraktivitäten)
- Generierung von Warnungen und Alarmen zur Analyse und Bearbeitung im Event- Management des AN
- Dashboard zur Echtzeit-Visualisierung für die AG mit Web-basiertem Zugriff
- Durchführung von Leistungen zur Korrelationsanalyse, Fehler- und Anomalieerkennung, Compliance Überwachung und Performance-Analyse durch den AN
- Monitoring der Managed Fachanwendungen nach Vorgaben der Monitoringpunkte durch die AG

Im Detail sind durch den AN folgende Leistungen zu erbringen:

##### Betriebsverantwortung

- Gesamte Betriebsverantwortung für das Logging und Monitoring
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb des Monitoring-Systems
- Betriebsdokumentation im Betriebshandbuch

##### Patch Management

- Update und Migration von Major Releases

#### Configuration Management

- Einrichtung Zugriffskontrolle und Authentifizierung
- Einrichtung der Logserver und Targets für Log
- Einrichtung der Monitoringpunkte und Korrelation
- Einrichtung Events und Alarme
- Einrichtung Rollenbasierter Dashboards

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Anpassung der Monitoringpunkte
- Anpassung der Dashboards
- Bearbeitung von Events und Alarmen im Event-Management
- Backup der Konfigurationsdateien und
- Restore von erforderlichen Konfigurationsdateien

#### 4.1.4 Self-Service-Portal

Die Administration der Cloud-Infrastruktur erfolgt über ein zentrales Management-System (Self-Service-Portal) selbstständig im Sinne eines Self-Service durch die AG. Diese soll die ihnen zugeteilten Ressourcen selbst administrieren und effizient verwalten können, sowie Personen aus ihrer Organisation berechtigen können. Die wichtigsten Funktionen des Management-Systems sind das Ressourcenmanagement und die Kostenkontrolle.

Anforderung an das Self-Service-Portal:

- Das Self-Service Portal ist hochverfügbar
- Cloud-Anwendungen müssen auch bei Ausfall des Portals verfügbar bleiben
- Das Portal muss über ausreichend Performance verfügen, so dass zeitgleiche Anfragen parallel verarbeitet werden
- Das Portal kann über ein Web-basiertes Interface mit einem benutzerfreundlichen UI bedient werden
  - Die Bedienung ist intuitiv und selbsterklärend
  - Kontextsensitive Hilfefunktion
  - Konsistentes UI in allen Ebenen
  - Steuerung und Verwaltung aller angeschlossener Clouds über ein einheitliches UI
  - Barrierefrei nach EN 301 549, BITV 2.0 oder WCAG
  - Möglichkeit zum Customizing des Layouts gem. Corporate Design
  - Unterstützung dark mode
- Provisionierung von IaaS- und SaaS-Diensten über definierte und mit der AG abgestimmte Templates
- Compliance Richtlinien für Provisionierung können eingestellt werden
  - Umgebungsbezogene Richtlinien
  - Benutzerbezogene Richtlinien
  - Applikationsbezogene Richtlinien
  - Richtlinien in Abhängigkeit der Datenklasse
- Anpassung der Ressourcen bestehender/provisionierter Dienste (vCPU / Memory / Storage / Backup)
- Administration von Ressourcen
  - Überwachung des Ressourcenverbrauch
  - Start / Stop / Restart von Diensten
- Benutzerverwaltung:
  - Berechtigungen auf Gruppenbasis
  - Authentifizierung und Autorisierung über Entra ID
  - Unterstützung von Single Sign On und 2-Faktor Authentifizierung
  - Ein Anwender kann mehreren Gruppen angehören
- Abrechnung und Kostenmanagement (FinOps):
  - Kostenübersicht auf Kostenstelle bis auf alle Ebenen der Benutzerverwaltung
  - Alle Ressourcen müssen bei der Provisionierung eindeutig einer Kostenstelle zugeordnet werden
  - Zuweisung und Überwachung von Budgets
  - Automatische Alarmierung bei Erreichen von Schwellwerten in zugewiesenen Budgets

## 4.2 Netzwerkdienste

Die Netzwerkdienste umfassen die grundsätzlichen Dienste, die erforderlich sind, um die IP-Verbindungen zwischen den Systemen und zu den Anwendern herstellen zu können. Diese sind integraler Bestandteil der abrufbaren IaaS- und SaaS-Dienste.

### 4.2.1 Basis-Netzwerkdienste

Als erforderliche Netzwerk-Basisdienste müssen zur Funktionsweise der Server folgende Dienste bereitgestellt werden, soweit sie nicht durch die Active Directory Dienste (siehe Punkt 4.1.2) abgedeckt sind oder ergänzend dazu:

- DNS
- DHCP
- NTP

Die Netzwerk-Basisdienste müssen mit der lokalen Netzwerk-Infrastruktur an den Standorten der AG interagieren können.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Die Bereitstellung der Basis-Netzwerkdienste
- die initiale Installation der Server für Netzwerkdienste im Rechenzentrum des AN
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Betrieb

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Gesamte Betriebsverantwortung der Basis-Netzwerkdienste
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases

#### Configuration Management

- Einrichtung Netzwerkkonfiguration
- Einrichtung Logging und Monitoring

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Überwachung der Fehlerlogs

- Anpassung an Netzwerkänderungen
- Backup der Konfigurationsdateien und
- Restore von erforderlichen Konfigurationsdateien

#### **4.2.2 Netzwerk-Segmentierung**

Um eine sichere Verbindung zu den Ressourcen in der Virtual Cloud und um eine private Kommunikationsumgebung zu schaffen, muss das Netzwerk in logische Netzwerksegmente unterteilt werden können (vNet).

Anforderungen an die Netzwerk-Segmentierung:

- Unterteilung in VLANs
- Unterteilung in Subnets
- Verwendung privater IP-Adressen und eigener öffentlicher IP-Adressen  
BYOIP Subnetze nicht kleiner als /24 (255.255.255.0)
- vNet Peering
- Hybrid Cloud-Verbindungen zur sicheren und isolierten Verbindung zwischen Virtual Private Cloud-Ressourcen und lokalen Ressourcen

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### **Betriebsverantwortung**

- Gesamte Betriebsverantwortung für die Switching/Routing Netzwerkinfrastruktur
- Betriebsdokumentation im Betriebshandbuch

#### **Patch Management**

- Update und Migration von Major Releases

#### **Configuration Management**

- Einrichtung Netzwerkkonfiguration
- Einrichtung Logging und Monitoring

#### **Lizenzierung**

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### **Administration**

- Überwachung der Fehlerlogs
- Anpassung an Netzwerkänderungen
- Backup der Konfigurationsdateien und
- Restore von erforderlichen Konfigurationsdateien

#### 4.2.3 Cloud Firewall Services

Der AN stellt Cloud Firewall Services bereit, als Grundvoraussetzung für die Bereitstellung aller cloudbasierten Services des AN. Die AG unterstützt bei der Definition grundlegender Firewall-Policies.

Anforderungen an die Cloud Firewall Services:

- Die Firewall verbindet die verschiedenen Netzsegmente sowie das WAN und die DMZ miteinander und regelt die Verkehrsbeziehungen der Ressourcen und Services untereinander. Dazu bietet sie verschiedene Leistungspakete, die nach Bedarf dazugebucht werden können:
  - Essential Security: Stateful Firewall; NAT; Zugriffsteuerung; Basis DDoS-Schutz
  - Advanced Security: Application Layer Security; IDS/IPS, SSL Inspection; Zero Trust-Zugangskontrolle; erweiterter DDoS-Schutz gegen volumetrische Angriffe
- Die AG erhält einen eigenständigen Firewall Mandanten welcher das Netzwerk getrennt von anderen Mandanten verarbeitet.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Die Bereitstellung eines Cloud Firewall Services als eigenständigen Mandanten
- die initiale Installation der Firewall Services
- die Skalierung auf die von der AG benötigten Kapazitäten
- die Bereitstellung von Templates und Standardkonfiguration
- Administration der Regelwerke nach Vorgaben der AG und
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Betrieb

Im Detail sind durch den AN folgende Leistungen zu erbringen:

##### Betriebsverantwortung

- Gesamte Betriebsverantwortung Firewall Cloud Services
- Koordinationsaufgaben bei Partnern (Dienstleister zur Unterstützung des Betriebes und Service Provider) der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb der Firewall
- Betrieb Unterkannte Firewall (Netzwerkstecker)
- Neustart der Firewall bei Störungen und
- Betriebsdokumentation im Betriebshandbuch

##### Patch Management

- Update und Migration von Major Releases
- Einspielen von Firmware Patches

##### Configuration Management

- Einrichtung VPN Verbindung

- Einrichtung Firewall Mandant
- Einrichtung von Firewallregeln
- Einrichtung von virtuellen IPs und
- Konfiguration von Routingeinträgen

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Pflegen von Firewallregeln
- Analyse der Logdateien
- Backup der Konfigurationsdateien und
- Restore von erforderlichen Konfigurationsdateien

#### 4.2.4 Load-Balancer

Zur effizienten Verteilung des Datenverkehrs auf mehrere Systeme sind Load Balancer erforderlich.

Als erweiterte Funktionen der Load Balancer bzw. Application Delivery Controller (ADC) werden außerdem Web-Application Proxy und WAF-Protection angesehen, diese könnten aber auch dediziert und separiert vom Loadbalancer angeboten werden.

Anforderungen an den Loadbalancer:

- Lastverteilung nach verschiedenen Algorithmen und geographisch
- Verfügbarkeit mit Health Check und Failover
- dynamisches Hinzufügen oder entfernen von Servern für einen Dienst
- L4 Loadbalancing
- L7 Loadbalancing (mit SSL/TLS-Entschlüsselung)
- Sitzungsmanagement (Sticky Sessions)
- UDP Loadbalancing optional

Folgende generelle Leistungen sind durch den AN für Loadbalancer zu erbringen:

- Bereitstellung der Load Balancer
- die initiale Installation der Load Balancer im Rechenzentrum des AN,
- die Skalierung auf die vom AG benötigten Kapazitäten und
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Betrieb.

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Gesamte Betriebsverantwortung Loadbalancer Services (inkl. WAP und WAF)
- Koordinationsaufgaben bei Partnern der AG

- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb des Loadbalancers
- Betrieb Unterkante Loadbalancer (Netzwerkstecker)
- Neustart des Loadbalancers oder der WAP/WAF Services bei Störungen und
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases
- Einspielen von Firmware Patches

#### Configuration Management

- Einrichtung Netzwerkkonfiguration
- Health Checks einrichten
- Load-Balancing Algorithmen einrichten
- Server-Pools konfigurieren
- SSL/TLS-Konfiguration einrichten
- Sitzungsmanagement & Sticky Sessions einrichten
- Einrichtung Logging und Monitoring

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Traffic-Statistiken auswerten
- Health Checks überwachen
- Load-Balancing-Strategien optimieren
- Backup der Konfigurationsdateien und
- Restore von erforderlichen Konfigurationsdateien

#### **Web Application Proxy (WAP):**

Der Web Application Proxy Service (WAP) ermöglicht es der AG, ihre internen Services im World Wide Web zu veröffentlichen. Somit können Endanwender mit den dafür vorgesehenen Geräten auch von außerhalb des BIG Netzwerks auf die veröffentlichten Dienste zugreifen.

Dies wird technisch über einen Web Application Proxy abgebildet.

Um den Zugriff auf diese veröffentlichten Dienste sicher zu gestalten, bietet der Web Application Proxy die Möglichkeit einer Authentifizierung der Endanwender/Endgeräte im Vorhinein. Der Web Application Proxy kann zudem als zentraler SSL-Endpunkt für veröffentlichte Dienste verwendet werden. Der Datenverkehr (in der Regel aus dem Internet) wird in diesem Fall über das HTTPS-Protokoll bis zum WAP mittels SSL verschlüsselt übertragen.

Folgende generelle Leistungen sind durch den AN zusätzlich für den WAP-Service zu erbringen:

- die Bereitstellung der WAP Services
- die Veröffentlichung kompatibler Services über den WAP
- die Vorab-Authentifizierung über den WAP
- die Terminierung von HTTPS-Datenströmen (SSL-Offloading)
- die Skalierung auf die vom Kunden benötigten Kapazitäten
- die Sicherstellung der Serververfügbarkeit über die vereinbarte Vertragslaufzeit

#### **Web Application Firewall (WAF Protection)**

In Verbindung mit dem Load-Balancer ist eine Web Application Firewall gefordert, zum Schutz von Webanwendungen vor Angriffen.

- Echtzeit-Überwachung und Filterung von ein- und ausgehendem Datenverkehr
- Schutz vor Zero-Day-Angriffen
- Erkennung von Anomalien

Folgende generelle Leistungen sind durch den AN zusätzlich für den WAF-Service zu erbringen:

- die Bereitstellung der WAF Services
- Netzwerk- und Integrationskonfiguration
- Sicherheitsrichtlinien konfigurieren
- White-/Blacklists konfigurieren
- Logging- und Monitoring einrichten

#### **4.2.5 Site-to-Site VPN-Services**

Der Site-to-Site VPN Service ist ein durch den AN bereitgestellter Managed Service, mit dem ein Virtuelles Privates Netzwerk (VPN) über eine verschlüsselte TLS (Transport Layer Security) Verbindung realisiert wird.

Inkludiert im VPN Service ist der Betrieb eines VPN-Servers (Router, Gateway, Firewall, Server) zur Realisierung des Dienstes.

Durch die VPN Services können dauerhafte, sichere Verbindungen z.B. zwischen örtlich getrennten Netzen an Standorten der AG und dessen Partnern und dem Virtual Cloud Rechenzentrum über das Internet hergestellt werden.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Die Bereitstellung eines VPN Servers
- die initiale Installation des VPN Servers im Rechenzentrum des AN
- die Skalierung auf die von der AG benötigten Kapazitäten
- die Einrichtung der von der AG benötigten VPN Tunnel und
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Betrieb

Im Detail sind durch den AN folgende Leistungen zu erbringen:

##### **Betriebsverantwortung**

- Gesamt Betriebsverantwortung VPN Services
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Neustart der VPN Services bei Störungen und
- Betriebsdokumentation im Betriebshandbuch

##### **Patch Management**

- Update und Migration von Major Releases und
- Einspielen von Firmware Patches

##### **Configuration Management**

- Einrichtung VPN-Verbindung
- Einrichtung von Firewall regeln
- Einrichtung von virtuellen IPs und
- Konfiguration von Routingeinträgen

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Überwachung VPN-Tunnel
- Analyse von Verbindungsproblemen
- Überprüfung HA-Status
- Backup der Konfigurationsdateien und
- Restore von erforderlichen Konfigurationsdateien

#### 4.2.6 Internet Anbindung

Der Internetzugang für die Systeme und Anwendungen im Virtual Private Cloud Rechenzentrum erfolgt über einen gesicherten, zentralen Internetanschluss im RZ des AN. Dazu muss das RZ über eine ausreichend performante und verfügbare Internetanbindung und Schutzvorrichtungen (Firewall, IDS, IPS, Abwehr von DDoS Attacken, etc.) verfügen, welche den in diesem Dokument aufgeführten Anforderungen Rechnung tragen.

Der Internetzugang an den Standorten der AG und deren Partner erfolgt über eigene, von der AG und den Partnern betriebene Anschlüsse.

#### 4.3 IaaS-Dienste in der Virtual Private Cloud

Der AN bietet der AG IaaS (Infrastructure as a Service) Services als Cloud-Dienst in der Virtual Private Cloud an, der es ermöglicht, skalierbar und bedarfsgerecht Rechnerinfrastruktur zu nutzen, ohne dass die AG diese selbst, z.B. im eigenen Rechenzentrum, vorhalten muss. IaaS Services kann sowohl im Computing- als auch im Storage Bereich zur Verfügung gestellt werden.

Die virtualisierten Server beinhalten Hard- und Softwarekomponenten, die Voraussetzung für den Betrieb der Fachanwendungen sind. Die Installation, Administration und der Support für die jeweilige Fachanwendung ist dabei nicht Bestandteil des Service und wird durch BIG durchgeführt (ausgenommen Managed Fachanwendungen).

Die Server für die Fachanwendungen der AG werden als virtualisierte Server (vServer) durch den AN zur Verfügung gestellt. Es ist eine in sich geschlossene Serverfarm aufzubauen, die alle benötigten Services und Dienste skalierbar und in geeigneter Form zur Verfügung stellt. Die Verantwortung des AN endet bei diesen Systemen bei der Oberkannte Betriebssystem bzw. bei Bedarf bei Middleware-Komponenten wie Web-Services, Datenbanken und Netzwerkaspekten.

Die Installation und Konfiguration von Fachanwendungen erfolgen durch die AG oder durch von der AG beauftragte Dritte. Hierfür erforderliche Remotezugänge sind bereitzustellen.

Der Dienst IaaS umfasst grundsätzlich:

- Die Bereitstellung von Computing und/oder Storage in den Rechenzentren der AG

- die Skalierung auf die von der AG benötigten Kapazitäten
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Betrieb der Infrastruktur und
- Support der AG gemäß der vereinbarten Service Level

Die benötigten Kapazitäten für das Computing werden redundant in den Rechenzentren vorgehalten. Der Ausfall der Computing -Infrastruktur in einem RZ-Standort löst ein automatisches Failover auf den zweiten RZ-Standort aus. Beim Ausfall im Bereich Computing werden die virtuellen Maschinen am zweiten Standort neu gestartet. Für nicht gespiegelte Services können bei dieser Failover-Methode die realisierbaren RTO-/RPO-Zeiten in der Größenordnung Minuten liegen.

Die AG kann pro System entscheiden, ob das Management des Systems durch den AN übernommen werden soll. Dadurch lassen sich Systeme im virtuellen Housing abbilden. Bei diesen übernimmt die AG ab der Hülle der virtuellen Maschine selbst das Management.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Die initiale Bereitstellung einer IaaS Plattform in Form einer Virtual Private Cloud
- die Skalierung auf die von der AG benötigten Kapazitäten,
- die Bereitstellung von virtuellen Maschinen und
- Sicherstellung der Serververfügbarkeit über die vereinbarte Vertragslaufzeit

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Gesamte Betriebsverantwortung IaaS Services
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb des Betriebssystems
- Betrieb Unterkante Betriebssystem (Hypervisor)
- Anpassung Betriebssystemparameter nach Vorgaben des Verantwortlichen für die Applikation,
- Neustart der Serversysteme bei Störungen im Betriebssystem oder auf Anforderungen des Verantwortlichen für die Applikation
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation und
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases
- Einspielen von Betriebssystem Patches und
- Einspielen von Applikations-Patches

#### Configuration Management

- Administration sämtlicher Applikationsparameter
- Bereitstellung von DNS-Namen und Servernamen
- Bereitstellen von virtuellen Servern
- Erweitern von virtuellen Ressourcen und
- Erzeugen und Verwalten von Snapshots

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen. **Ausnahme:** Lizenzen, die im Rahmen von BYOL durch die AG gestellt werden.

#### Administration

- Kontrolle der Virens Scanner Pattern
- Anlegen und Verwaltung von virtuellen Ressourcen
- Sicherstellen von Datenkonsistenz
- Reporting über den verwendeten Ressourcenpool und
- Restore von erforderlichen VM Disks und Dateien.

#### 4.3.1 Hypervisor / VM-Services

Die Hypervisor / VM-Services beinhalten die Bereitstellung eines Hypervisor-Systems zur Virtualisierung von Servern und Diensten in unterschiedlichen Ausbaustufen in einer geschlossenen Serverfarm.

##### Anforderungen an den Hypervisor:

- Sicherstellung der Skalierbarkeit
  - Für Prüfungen müssen aus einer einzigen Vorlage oder zuvor erstelltem Image kurzzeitig hunderte von VMs) bereitgestellt werden können
- Sicherstellung der Hochverfügbarkeit (HA)
- Unterstützung von Windows- und Linux-Gastsystemen
- Integriertes Ressourcenmanagement und Lastverteilung
- Möglichkeit zur Sicherung und Wiederherstellung von VMs
- Unterstützung für virtuelle Netzwerke (vLAN, vNET)
- Nested Virtualisation, Möglichkeit eine VM innerhalb einer anderen VM zu betreiben
- Web-basierte Administrationsoberfläche mit graphischem UI zur Verwaltung der VMs
- Integration der Basis Infrastrukturdienste
- Integration der Netzwerkdienste
- Integration der IaaS Dienste
- Zugriffsrechte über definierte Benutzerrollen im IDM-Service
- Bereitstellung von vorkonfigurierten virtuellen Maschinen im Self-Service.
- Möglichkeit einer automatischen Zeitbegrenzung und Löschung von VMs nach Ablauf der Nutzungsdauer
- Bereitstellung und Export von Reports zur Nutzung und Ressourcenauslastung

Über den Hypervisor werden VMs für unterschiedliche Anwendungsfälle in verschiedenen Leistungsstufen bereitgestellt. An die VMs werden folgende Anforderungen gestellt:

- Windows Gastsysteme
  - Windows Server ab 2019
- Linux Gastsysteme
  - Ubuntu
  - SUSE (SLES / OpenSUSE)
  - Debian
  - Red Hat
- VMs inkl. Betriebssystem, oder lizenzfrei für BYOL (Bring-your-own-License)
- Individuelle, für die Anwendung angepasste Leistungsstufen
  - mit spezifizierten vCPU / Taktfrequenz / CPU-Auslastung / CPU-Overcommitment / RAM / Storage / vNICs
  - Redundanz und Failover
  - Geeignet für Videokonferenzserver (RTP-Verkehr)
  - Geeignet für Medienstreaming
- Möglichkeit zur Archivierung inkl. aller Daten und Konfigurationen zur späteren Reaktivierung/ Wiederherstellung (Snapshot)
- Deaktivierung / Reaktivierung von VMs / Snapshots
- Optional VMs mit besonderen Anforderungen
  - Optional Bereitstellung von GPUs für Entwicklung und Simulationen im Bereich Modellierung von KI-Modellen

Distributionen in Gastsystemen, für die im Lifecycle kein Herstellersupport oder Sicherheits-Patches mehr bereitgestellt werden, können durch binärkompatible und supportete Alternativen ersetzt werden.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Die Bereitstellung von Hypervisor und VM-Service Dienstleistung
- die Skalierung auf die von der AG benötigten Kapazitäten und
- Sicherstellung der Verfügbarkeit über die vereinbarte Vertragslaufzeit

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Gesamt Betriebsverantwortung für die Hypervisor Plattform
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb der Hypervisor Plattform (Physik)
- Betrieb bis Unterkante VMs (Netzwerk, Kabel) und
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases und
- Einspielen von Firmware Patches

#### Configuration Management

- Konfiguration von Interfaces
- Konfiguration von VMFS Partitionen
- Konfiguration von Cluster und HA Eigenschaften und
- Anbindung und Konfiguration Storage

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Überwachung der Erreichbarkeit / Verfügbarkeit
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation
- Fehleranalyse von Hardwareproblemen
- Analyse von Performance Problemen
- Vor Ort Analyse z.B. Hardware Diagnose und
- Case Management mit dem Hersteller

#### **4.3.2 Hypervisor am Standort der AG**

Aus Performancegründen, insbesondere Latenzzeiten für die Scanstrecke, ist es erforderlich eine Hypervisor Plattform on Premise im HQ der BIG zu betreiben.

Dazu besteht bereits eine Hypervisor Plattform auf Basis von Dell Servern mit direkt angeschlossenem Storage und Hyper V im Eigentum der AG. Diese Plattform muss als Managed Services im Rahmen der VM-Services durch den AN betrieben werden, wobei die bestehende Plattform als Beistellung in die Betriebsverantwortung des AN übergeben wird.

Idealerweise wird die On-Premise Hypervisor Plattform in das zentrale Managementsystem des AN für die Hypervisor-Umgebung integriert. Falls Hyper V aus technischen oder organisatorischen Gründen oder aus Gründen der Interoperabilität nicht integriert werden können, steht es dem AN frei seinen eigenen Hypervisor Stack zu installieren.

Der Leistungsumfang des AN unterscheidet sich nicht von den VM-Services innerhalb der Virtual Private Cloud. Insbesondere sind auch folgende betriebliche Leistungen enthalten:

- Release-/Patch-Management für die Server Firmware
- Monitoring der Hardware
- Backup täglich außerhalb der Standard Arbeitszeit 6 – 22 Uhr
- Capacity Management, wobei erforderliche Kapazitätserweiterungen an die AG gemeldet werden. Die Bereitstellung der Kapazitätserweiterung liegt dann in der Verantwortung der AG.

Die AG gewährt dem AN Remotezugang auf die Serverplattform (iDRAC via Web-Frontend auf die Dell Server). Alle operativen vor-Ort-Maßnahmen werden vom AN die AG delegiert, wobei die SLAs für die Dauer der vor-Ort-Maßnahmen ausgesetzt werden können.

Für die Dell Server besteht ein Wartungsvertrag. Wartungsfälle, die vom AN identifiziert werden, werden an die AG delegiert. Die Verantwortung für den Hardware Lifecycle liegt bei der AG.

#### Spezifikation der ON-Premise Hypervisor Plattform

- 2x Dell PowerEdge R 660 Server (in getrennten Brandabschnitten im RZ des Hauptstandorts)
  - CPU: 2x Intel Xeon Silver 4509Y 16 Kerne
  - RAM: 256 GB
  - Storage: 9,6 TB NVMe
  - 1x Trusted Platform Module 2.0 V6
- Hypervisor
  - Hyper V
- Workload
  - 2 Windows VMs für Scanstrecke
  - 2 Linux VMs als lokaler Proxy
  - 2 Linux Server für Pentests

#### 4.3.3 Storage-Services

Zur performanten Speicherung von Daten für die verschiedenen Systeme und Anwendungen werden folgende Typen von Storage Systeme benötigt:

- Block-Storage
  - mit iSCSI Schnittstelle
- File-Storage
- Object-Storage (S3-kompatibel)
- Immutable Storage

An die Storage Systeme werden folgende Anforderungen gestellt:

- Transport und die Speicherung der Daten müssen verschlüsselt erfolgen
- Speichervolumen müssen bis mindestens 500 TB in einem Volume skaliert werden können (zur Ablage von Sensordaten)

Um eine maximale Flexibilität zu ermöglichen, stellt der AN drei verschiedene Storage-Klassen zur Verfügung. Dabei sollen sich die verschiedenen Klassen durch die Anzahl möglicher Operationen pro Sekunde unterscheiden. Das Antwortzeit-Verhalten soll sich ebenfalls je nach Storage-Klasse unterscheiden. Grundsätzlich existiert eine Bindung zwischen dem Volumen und der daraus resultierenden maximalen Performance. Desweiteren muss jede Storage-Klasse sowohl ungespiegelt, als auch synchron gespiegelt angeboten werden. Für Object Storage wird Erasure Coding (EC) als gleichwertige Alternative zu Spiegelung angesehen.

Darstellung der Performance-Anforderungen an Storageklassen:

|                       | Storageklasse A | Storageklasse B | Storageklasse C |
|-----------------------|-----------------|-----------------|-----------------|
| <b>IOPS pro TByte</b> | 32              | 1024            | 4096            |
| <b>SLO (max.)</b>     | 128             | 2048            | 8192            |
| <b>Latenz (ms)</b>    | 64              | 8               | 4               |

**Tabelle 5: Performance Anforderungen an Storage Klassen**

Anzubietende Varianten:

|                        | Block Storage | File Storage | Object Storage |
|------------------------|---------------|--------------|----------------|
| <b>Storageklasse A</b> | ja            | ja           | ja             |
| <b>Storageklasse B</b> | ja            | ja           | optional       |
| <b>Storageklasse C</b> | ja            | ja           | nein           |
| <b>ungespiegelt</b>    | ja            | ja           | ja             |
| <b>gespiegelt</b>      | ja            | ja           | EC             |

**Tabelle 6: Varianten Storage Services**

### Storage Klasse A

Der Einsatz der Storage-Klasse „Capacity“ ist für Anwendungen gedacht, die über sehr große Datenmengen verfügen. Typische Einsatzfelder sind beispielsweise Ablage von Sensordaten, Archivsysteme mit wenigen Zugriffen oder Ablage von alten Datenstrukturen.

### Storage Klasse B

Die Storage-Klasse „Performance“ ist die am häufigsten verwendete Storage-Klasse. Häufigster Einsatzzweck sind Betriebssystemfestplatten und Netzlaufwerke.

### Storage Klasse C

Anwendungen die eine sehr hohe I/O Last erzeugen, können mit der Storage-Klasse „Extreme“ betrieben werden. Klassische Anwendungsfelder sind Datenbanken, ausgenommen Object Storage.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Die Bereitstellung der Storage-Services Dienstleistung
- Übernahme der bisherigen Daten auf das neue System
- die Skalierung auf die von der AG benötigten Kapazitäten und
- Sicherstellung der Verfügbarkeit über die vereinbarte Vertragslaufzeit

### **Immutable Storage**

Zur Archivierung von Daten und als Schutz von Ransomware muss das Storage System Immutable Storage bzw. eine WORM-Funktion ermöglichen.

Immutable Storage ist zwingend erforderlich für das Versichertenarchiv der Applikation d.3 von d.velop, die folgende Storage-Systeme / Schnittstellen unterstützt.

- S3 = Allgemeiner S3-Speicher
- AZURE = Azure Blob Storage
- NETAPP = Network Appliance NetApp (mit SnapLock)
- CELERRA = EMC<sup>2</sup> VNX-Systeme mit FLR-Option
- CENTERA = EMC<sup>2</sup> Centera und EMC<sup>2</sup> Atmos-Systeme
- CLOUDSTORAGE = d.velop cloud storage
- DATADOMAIN = EMC<sup>2</sup> Data Domain
- FILELOCK = Grau Data FileLock
- GOVERNIKUSLZA = Governikus DATA Aeonia-Signatursystem
- HCP = Hitachi Content Platform
- ICAS = iTernity iCAS
- ISILON = Dell EMC Isilon
- PRONEXT = Procilon proNEXT-Signatursystem
- SILENTCUBES = Fast LTA Silent Cubes
- SYSTEMCONNECT = System Connect für 3rd Party Konnektoren (Read Only)
- TSM = Tivoli Storage Manager (mit Data Retention)

Für das Versichertenarchiv zwingend erforderlich ist zumindest S3-kompatible Storage als Immutable Object Store mit Object Lock/WORM Funktion.

Die Unterstützung weiterer Schnittstellen hat der Bieter in seinem Angebot darzustellen.

Im Detail sind durch den AN folgende Leistungen zu erbringen:

### **Betriebsverantwortung**

- Gesamte Betriebsverantwortung Storage Services
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases und
- Einspielen von Firmware Patches

#### Configuration Management

- Konfiguration von Aggregaten
- Konfiguration von Volumes
- Konfiguration von Interfaces
- Anlegen von iGroup, LUN, NFS, Cifs und
- Konfiguration Storage Efficiency

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen.

#### Administration

- Überwachung der Erreichbarkeit / Verfügbarkeit
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation
- Kernel Panic Analyse
- Fehleranalyse von Hardwareproblemen
- Analyse von Performance Problemen
- Vor Ort Analyse z.B. Hardware Diagnose und
- Case Management mit dem Hersteller

#### **4.3.4 Terminal Services - VDA Infrastruktur**

Der Einsatz von Thin Clients wird bei der AG sukzessive heruntergefahren, so dass VDI-Infrastruktur dafür nicht mehr relevant werden. Dennoch sind Anwendungsfälle denkbar, z. B. für Wartungszugänge oder Partner-Anbindung in denen Terminal Services auf Basis von VDA (Virtual Delivery Agent) interessant sein können, so dass diese optional angeboten werden sollen.

Die anzubietenden Terminal-Services bestehen aus einer skalierbaren Terminalserver-Infrastruktur und einem VDA-Worker, einem Softwareclient, der auf dem Benutzergerät installiert wird und über den Virtual Delivery Agent (VDA) eine Session auf einem VDA-Server bereitstellt, über die Benutzer auf Ressourcen (Anwendungen), die von mehreren Benutzern geteilt werden, zugreifen können.

#### **4.3.5 Fileservices**

Der AN stellt einen Fileserver Dienst bereit, der als Share oder Unternehmens-, Gruppen- oder Benutzerlaufwerk in die Clients (virtuelle Desktops und physische Desktops in den Standorten der BIG oder Homeoffice via VPN) integriert werden kann, um Dateien und Dokumente darauf zu speichern. Die Zugriffsrechte auf die Freigaben müssen über das IDM rollenspezifisch und individuell einstellbar sein. Die Zugriffsrechte werden typischerweise bis zur dritten Verzeichnistiefe einer Freigabe unterschiedlich vergeben.

Mithilfe eines Fileservers und angeschlossenen Block-Storage oder direkt über den File-Storage Dienst des Storage Systems ist es möglich, dass mehrere Nutzer Zugriff auf dieselben Dateien erhalten. Diese werden in unterschiedlichen Netzlaufwerken organisiert und abgebildet. Die AG kann dabei frei definieren, welche Laufwerke als Unternehmens-, Gruppen- oder Benutzerlaufwerke verwendet werden sollen und welche Nutzer auf welche Daten Zugriff erhalten. Über das IDM werden die Berechtigungen umgesetzt. Die Dateisysteme müssen SMB 3.1.1 und NFS v4 unterstützen. Bei entsprechenden Dateisystemen können während des laufenden Betriebs Snapshots zur Datensicherung gemacht werden.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- die Bereitstellung eines virtuellen Servers
- die initiale Installation des File Servers im Rechenzentrum der AG
- die Skalierung auf die von der AG benötigten Kapazitäten
- Backup/Restore mit einer Vorhaltezeit von 45 Tagen
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Serverbetrieb

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### **Betriebsverantwortung**

- Gesamte Betriebsverantwortung File Service,
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG

- Betrieb des Betriebssystems
- Betrieb Unterkante Betriebssystem (Hypervisor)
- Anpassung Betriebssystemparameter nach Vorgaben des Verantwortlichen für die Applikation
- Neustart der Serversysteme bei Störungen im Betriebssystem oder auf Anforderungen des Verantwortlichen für die Applikation
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation und
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases
- Einspielen von Betriebssystem Patches und
- Einspielen von Applikations Patches

#### Configuration Management

- Festlegung und Freigabe der File-Struktur
- Anlegen und Konfiguration von File-Strukturen bis zur dritten Ebene
- Konfiguration von Volumeschattenkopien
- Anlegen und Konfiguration von Freigaben
- Konfiguration von DFS-Diensten und
- Konfiguration von Datendeduplizierung

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen. **Ausnahme:** Lizenzen, die im Rahmen von BYOL durch die AG gestellt werden.

#### Administration

- Administration von Ordnern (Benutzer, Gruppen, OUs, Berechtigungen - lesen - schreiben etc.)
- Überprüfung File-Dienste (Monitoring) und DFS- Replication
- Verwaltung und Pflege File-Strukturen
- Überwachung der Speicherbereiche und Speichererweiterung nach Anforderung und
- Restore von erforderlichen Dateien und Ordnern

#### 4.3.6 Backup-Services

Die von den Anwendungen der AG auf den bereitgestellten Systemen erzeugten Daten sollen in einem Backup- und Wiederherstellungskonzept, das sowohl auf der Ebene der Applikation, des Storage Systems, der Fileserver als auch auf der Ebene des Hypervisors greift, in ein Backup-System des AN gesichert werden. Eine Wiederherstellung von Daten ist daher, abhängig von der gewählten Sicherungsstrategie und Anwendung, im Umfang des Service vorzusehen.

Generell gilt:

- Backups müssen mehrfach verschlüsselt gespeichert werden können
- Es müssen regelmäßige Wiederherstellungstests durchgeführt und dokumentiert werden
- Write-Only
- Validierung von Backups ohne Einschränkung der Produktivumgebung müssen ermöglicht werden
- Backups und Restore müssen von den Nutzern über ein einfach zu bedienendes Web-Interface geplant und verwaltet werden können
- Die Backup-Infrastruktur muss logisch und räumlich getrennt sein

Folgende Backup-Varianten sind seitens des AN anzubieten:

#### **Backup-1**

In dieser Variante werden die Daten des gebuchten Service per Default 1x täglich gesichert. Die Aufbewahrungszeit für diese Standardsicherung beträgt jeweils 30 Tage. Ein Backup jeden Monat wird zusätzlich als Monatsbackup für 365 Tage vorgehalten. Standardisiert wird das Backup einfach durchgeführt, d.h. alle Daten werden in einem der Rechenzentren des AN hinterlegt.

#### **Backup-2**

In dieser Variante werden die Daten des gebuchten Service 1x täglich gesichert. Die Aufbewahrungszeit für diese Sicherung beträgt jeweils 30 Tage. Ein Backup pro Woche wird als Wochenbackup gespeichert und 90 Tage vorgehalten. Ein Backup pro Monat wird zusätzlich als Monatsbackup für 365 Tage vorgehalten. In dieser Variante werden die Daten doppelt, also in zwei Rechenzentren des AN vorgehalten.

#### **Backup-3**

In dieser Variante werden die Daten des gebuchten Service 1x täglich gesichert. Bei Bedarf kann die AG diese Frequenz erhöhen. Die höchstmögliche Frequenz beträgt 1x stündlich. Die Aufbewahrungszeit für diese Sicherung beträgt jeweils 30 Tage. Die Aufbewahrungszeit kann bei Bedarf durch die AG individuell angepasst werden. Ein Backup pro Woche wird als Wochenbackup gespeichert und 90 Tage vorgehalten. Ein Backup pro Monat wird zusätzlich als Monatsbackup für 365 Tage vorgehalten. In dieser Variante werden die Daten doppelt, also in zwei Rechenzentren des AN vorgehalten.

Die folgende Tabelle veranschaulicht die anzubietenden Varianten:

|                  | <b>Backup-1</b> | <b>Backup-2</b> | <b>Backup-3</b>                                    |
|------------------|-----------------|-----------------|----------------------------------------------------|
| <b>Sicherung</b> | 1x täglich      | 1x täglich      | 1x täglich /<br>frei wählbar bis max. 1x stündlich |

|                     |                                              |                                                                       |                                                                                    |
|---------------------|----------------------------------------------|-----------------------------------------------------------------------|------------------------------------------------------------------------------------|
| <b>Aufbewahrung</b> | Tagesbackup: 30 Tage<br>Monatsbackup: 1 Jahr | Tagesbackup: 30 Tage<br>Wochenbackup: 90 Tage<br>Monatsbackup: 1 Jahr | Tagesbackup: 30 Tage<br>Wochenbackup: 90 Tage<br>Monatsbackup: 1 Jahr/frei wählbar |
| <b>Datenkopie</b>   | 1 Backup (RZ1)                               | 2 Backups (RZ1 + RZ2)                                                 | 2 Backups (RZ1 + RZ2)                                                              |
| <b>Daten</b>        | Alle (oder ohne benannte Ausnahmen)          | Alle (oder ohne benannte Ausnahmen)                                   | Alle (oder ohne benannte Ausnahmen)                                                |
| <b>Restore</b>      | DB, Single Items                             | DB, Single Items                                                      | DB, Single Items                                                                   |

**Tabelle 7: Backup-Varianten****Langzeitarchivierung**

Zu allen Backup-Varianten kann die AG, sollte sie eine Aufbewahrungszeit von mehr als einem Jahr (365 Tage) benötigen, die Langzeitarchivierung wählen. Dabei soll zusätzlich zu den monatlichen Backups ein Jahresbackup erstellt werden, welches bis zu 30 Jahre in den Rechenzentren des AN aufbewahrt werden kann. Der Aufbewahrungszeitraum der Langzeitarchivierung kann von der AG frei definiert werden.

Mit dieser Backup Lösung ist es möglich, heterogene Infrastrukturen (On-Premise) zu sichern. Ebenfalls möglich ist eine Funktionserweiterung um Archivierungs- und Disaster Recovery Prozesse.

Zur Steuerung der Sicherungsumgebung erhält die AG eine GUI, welche eine Übersicht aller Prozesse der Backup Infrastruktur enthält. Es ist möglich, unterschiedliche Zugriffs- und Berechtigungsstrukturen zu vergeben. Die Funktionen erstrecken sich dabei über die Definition von Read-Only, Backup-, Archivierungs- und Restore Prozessen. Die Berechtigungen werden abhängig vom vereinbarten Managed Service Level definiert, dokumentiert und umgesetzt.

Die Performanz und Qualität der Backup Prozesse kann mittels der integrierten Monitoring- und Alert Funktion ermittelt und überwacht werden.

Mit dieser Lösung kann die AG entscheiden, auf welchen Medien die Backup Daten gespeichert und vorgehalten werden sollen.

Folgende generelle Leistungen sind durch den AN zu erbringen:

- die Bereitstellung des ausgewählten Backup Services
- die initiale Installation des Datensicherungsziels
- die Skalierung auf die von der AG benötigten Kapazitäten und
- Die Vorhaltung der Backup Daten gemäß den von der AG gewählten Speicher- und Aufbewahrungszeiten.

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Gesamte Betriebsverantwortung Backup Services
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb des Betriebssystems
- Anpassung Betriebssystemparameter nach Vorgaben des Verantwortlichen für die Applikation
- Neustart der Serversysteme bei Störungen im Betriebssystem oder auf Anforderungen des Verantwortlichen für die Applikation
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation und
- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases
- Einspielen von Betriebssystem Patches
- Einspielen von Applikations Patches und
- Freigabe von Applikations Patches nach Prüfung der Anforderungen an Fachapplikation

#### Configuration Management

- Konfiguration von neuen Backup Jobs
- Änderung von Backup Jobs und
- Anpassung von Backupzeiten

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen. **Ausnahme:** Lizenzen, die im Rahmen von BYOL durch die AG gestellt werden.

#### Administration

- Monitoring der Leistungsbereitschaft der Dienste
- Monitoring der Leistungsbereitschaft von Tapelibrary, Tapelaufwerke und Diskpools
- Überprüfen des Status der gelaufen Backup Jobs
- Fehlerbehebung und Analyse der fehlgeschlagenen Backup Jobs
- Entfernen und hinzufügen von Tapes in der Library und
- Restore von erforderlichen Dateien und Ordnern

#### 4.3.6.1 Backup-Services für M365 Workloads

Der Backup-Service für M365 Workloads dient der von Microsoft unabhängigen Sicherung der M365-Workloads des AG, wie Sharepoint, MS-Teams, Exchange Online. Die Sicherungsdaten sind ausschließlich

in der Virtual Private Cloud des AN zu speichern. Eine Speicherung der Backup-Daten in Microsoft Azure oder sonstigen Public-Cloud-Speicherdiensten ist unzulässig.

Der Backup-Service für Microsoft-365-Workloads ist ein Bestandteil des unter 4.3.6 beschriebenen Backup-Services und die darin definierten Anforderungen an den Backup-Service gelten, soweit nachfolgend keine spezielleren oder ergänzenden Anforderungen festgelegt werden, gleichermaßen für den Backup-Service der Microsoft-365-Workloads.

#### **Technische Voraussetzungen / Anbindung an M365**

- Der AN muss den Backup-Service über die von Microsoft unterstützten Schnittstellen bereitstellen und darf ausschließlich die von Microsoft offiziell unterstützten und dokumentierten Schnittstellen verwenden.
  - Unterstützung der Microsoft APIs
    - Microsoft Graph API
    - SharePoint API soweit erforderlich
- Registrierung der Backup Applikation im Microsoft Entra ID Tenant der AG
  - Authentifizierung über OAuth 2.0 unter Anwendung des Least-Privilege-Prinzips
  - Einsatz Microsoft zertifizierter Backup-Produkte
- Zusätzlich muss der Backup-Service
  - Conditional Access Policies berücksichtigen
  - ausschließlich verschlüsselte Kommunikationsverbindungen verwenden
  - Änderungen der Microsoft APIs während der Vertragslaufzeit unterstützen

#### **Backup-Systeme in der Virtual Private Cloud**

- Sicherung auf Backup-Repositorys auf dedizierten Storage-Systemen in der Virtual Private Cloud
- Die Backup-Repositorys dürfen ausschließlich innerhalb der Virtual Private Cloud betrieben werden
- Repositorys logisch vom Produktivnetz getrennt und gegen unberechtigte Zugriffe abgesichert
- Unterstützung Immutable Backup unter Verwendung unveränderbarer Backup-Speicher (Object Lock, WORM oder gleichwertig).
- Transportverschlüsselung TLS 1.3
- Backup Verschlüsselung AES-256
- Schlüsselmanagement über PKI-Infrastruktur oder über Customer Managed Keys (CMK) unter Kontrolle des AG.

#### **Sicherung der der M365 Workloads**

Die nachfolgend aufgeführten Microsoft-365-Workloads stellen eine nicht abschließende Auflistung dar. Der Leistungsumfang umfasst darüber hinaus alle weiteren vom AG genutzten Microsoft-365-Workloads, soweit diese durch die eingesetzte Backup-Lösung unterstützt werden. Dies gilt auch für zukünftig von Microsoft bereitgestellte, geänderte oder abgelöste Workloads.

- Exchange Online:
  - Postfächer
  - Archive
  - Kalender
  - Kontakte
  - Aufgaben

- Regeln, Ordnerstruktur, Kategorien sowie Berechtigungen
- SharePoint Online
  - Sites
  - Dokumente
  - Listen
  - Bibliotheken
  - Versionen
  - Metadaten, Berechtigungen und Site-Struktur
- OneDrive for Business
  - Dateien
  - Versionen
  - Berechtigungen
  - Metadaten und Ordnerstruktur
- Microsoft Teams
  - Chats
  - Kanäle
  - Dateien
  - Registerkarten
  - Mitglieder, Berechtigungen sowie Kanalstruktur

#### Wiederherstellung

- Granulare und vollständige Herstellung aller Workloads
  - Einzelne E-Mail
  - Komplettes Postfach
  - Dokument
  - Komplette Site
  - Teams Chat
  - einzelne Dateien, Versionen, Listen, Bibliotheken sowie Berechtigungen
- Disaster Recovery des kompletten Tenants
- Cross-Workload-Restore

#### 4.3.7 Appliances/Housing

Der Auftraggeber betreibt folgende Systeme, die als Appliance im Virtual Private Cloud Rechenzentrum des AN betrieben werden:

- Trendmicro DDI:
  - Die Hardware hat 2 Höheneinheiten, 1 Management-Port (iDrac, Dell Remote Management Port), max. 4x SFP-ports (10gbit) / 5x rj45-ports (1gbit).
  - Der Betrieb erfolgt durch die AG.
- Cisco CUBE / SBC:
  - Die Hardware hat 1 Höheneinheit. Das System ist redundant auf zwei RZ zu verteilen.
  - Der Betrieb erfolgt durch die AG.
- HP-Server / SQL:
  - Die Hardware besteht aus 2 Clustern mit je 2 Servern mit zwei Höheneinheiten:
    - HPE EL 380 Server – Intel 6346 – 2 Socket – 4 TB RAM

- HPE DL 380 Server – Intel 6250 – 1 Socket – 512 GB RAM
- Der Betrieb erfolgt durch den AN.

Dazu muss der AN einen Housing Service zum Betrieb der Appliances im RZ des AN mit Zugriff auf die Virtual Private Cloud Ressourcen anbieten.

#### 4.4 SaaS-Dienste in der Virtual Private Cloud

Die nachfolgend aufgeführten SaaS-Dienste werden als Managed Service vom AN bereitgestellt

##### 4.4.1 Exchange Services

Exchange Server ist eine Groupware- und E-Mail-Transport-Server-Software. Mithilfe des Exchange Servers ist es möglich, E-Mails sowie Termine, Aufgaben und Kontakte zentral abzulegen und zu verwalten, um die Zusammenarbeit innerhalb eines Unternehmens zu ermöglichen und zu erleichtern.

Der Exchange Server wird stets in Verbindung mit einem Microsoft-Windows-Server genutzt. Der Exchange Server ist in der neuesten Version zu installieren. Es ist allerdings möglich, auf die Vorgängerversion downzugraden, sollte dies aus technischen Gründen auf Wunsch der AG notwendig sein.

Microsoft Outlook wird als Front End Anwendung genutzt. Darüber hinaus ist Outlook auch als Web App Applikation verfügbar und kann zusätzlich auf mobile Geräte synchronisiert werden.

Der überwiegende Teil der Exchange Postfächer, idR. die persönlichen User-Postfächer, werden zu Exchange Online migriert. Der Exchange Service deckt die Anforderungen für Funktionspostfächer, auf die mehrere Mitarbeiter Zugriff haben sowie ggf. weitere Postfächer mit besonderen Anforderungen ab.

Der Exchange Server ist so zu dimensionieren, dass er bei Bedarf auf bis zu 50 Postfächer und 500 GB Storage skaliert werden kann.

Die folgenden Endgeräte müssen unterstützt werden:

- Fat-Client
- Notebook, Windows Tablet (Anbindung über VPN-Verbindung)
- Smartphones/Tablets (Anbindung über native Exchange-Schnittstellen und Push Benachrichtigung)

Folgende Schnittstellen / Protokolle werden unterstützt:

- MAPI: Messaging Application Programming Interface: Microsoft Schnittstelle zur Kommunikation mit dem Groupware Server
- LDAP: Lightweight Directory Access Protocol: Zugriff auf Verzeichnisdienste nach dem X.500 Standard

- SMTP: Simple Mail Transfer Protocol: Ein Protokoll zur Übertragung von E-Mails in einem TCP/ IP Netzwerk
- IMAP: Das Internet Message Access Protocol (IMAP), ursprünglich Interactive Mail Access Protocol, ist ein Netzwerkprotokoll, das ein Netzwerkdateisystem für E-Mails bereitstellt.

### **Anwendungsunterstützung**

Der AN unterstützt bei allen Fragen im Zusammenhang mit der Nutzung der Anwendung. Anwender der AG richten ihre Fragen hierbei zunächst an den SERVICE DESK.

### **Archivierung**

Der AN betreibt in Verbindung mit dem MS-Exchange Service ein Archivierungssystem, mit dem die geltenden gesetzlichen Anforderungen (z. B. GDPdU) und die Grundsätze für eine rechtssichere Archivierung erfüllt werden. Die Mindestanforderungen sind gem. VOI (Anmerkung: die Anforderungen an Dokumente gilt sinngemäß auch für die Archivierung von E-Mail):

- Jedes Dokument muss nach Maßgabe der rechtlichen und organisationsinternen Anforderungen ordnungsgemäß aufbewahrt werden.
- Die Archivierung hat vollständig zu erfolgen – kein Dokument darf auf dem Weg ins Archiv oder im Archiv selbst verloren gehen.
- Jedes Dokument ist zum organisatorisch frühestmöglichen Zeitpunkt zu archivieren.
- Jedes Dokument muss mit seinem Original übereinstimmen und unveränderbar archiviert werden.
- Jedes Dokument darf nur von entsprechend berechtigten Benutzern eingesehen werden.
- Jedes Dokument muss in angemessener Zeit wiedergefunden und reproduziert werden können.
- Jedes Dokument darf frühestens nach Ablauf seiner Aufbewahrungsfrist vernichtet, d.h. aus dem Archiv gelöscht werden.
- Jede ändernde Aktion im elektronischen Archivsystem muss für Berechtigte nachvollziehbar protokolliert werden.
- Das gesamte organisatorische und technische Verfahren der Archivierung kann von einem Sachverständigen Dritten jederzeit geprüft werden.
- Bei allen Migrationen und Änderungen am Archivsystem muss die Einhaltung aller zuvor aufgeführten Grundsätze sichergestellt sein.
- Die Archive müssen nahtlos in den Client integriert werden, so dass der Anwender direkt aus der Anwendung transparent darauf zugreifen kann.

Es muss ein Unternehmensarchiv bereitgestellt werden, so dass alle ein- und ausgehenden E-Mails archiviert werden können. Zusätzlich müssen für definierte Benutzer Benutzerarchive bereitgestellt werden können, bei dem u. a. auch eventuelle Größenbeschränkungen für das Postfach aufgehoben werden können.

### **Backup und Recovery**

Der Datenspeicher und das Archiv der Anwendung werden täglich durch den AN gesichert. Auf Wunsch des AG werden einzelne Postfächer wiederhergestellt. Darüber hinaus soll der Anwender einzelne E-Mails aus dem Archiv wiederherstellen können.

**Virus Scanning Mails**

Alle eingehenden und ausgehenden E-Mails müssen mit einem leistungsfähigen System auf Schadsoftware und unerlaubte Anhänge hin untersucht werden. Die erforderlichen Viren Signaturen müssen regelmäßig aktualisiert werden. (Weitere Anforderungen s. Punkt 3.4.7)

**Spam Filter**

Alle eingehenden Mails sollen effektiv von Spam und Phishing-Nachrichten befreit werden. Der Spam-Filter muss Klassifizierungsregeln nach dem Stand der Technik verwenden. Der Anwender muss die Möglichkeit haben, E-Mails entsprechend zu kennzeichnen, um die Filter zu trainieren (nicht gefilterte E-Mails als Spam kennzeichnen oder umgekehrt). Darüber hinaus müssen White- und Blacklists angelegt werden können, die übergeordnet für alle Anwender gelten.

**Verschlüsselung / Signatur von E-Mails**

Eine Verschlüsselung/Signatur von E-Mails mit Hilfe von digitalen Zertifikaten muss generell möglich sein. Die digitalen Zertifikate sollten über das PKI-System des AN ausgestellt und verwaltet werden.

Im Detail sind durch den AN folgende Leistungen zu erbringen:

**Betriebsverantwortung**

- Gesamte Betriebsverantwortung Exchange Services
- Koordinationsaufgaben bei Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb des Betriebssystems
- Betrieb Unterkante Betriebssystem (Hypervisor)
- Betrieb eines SMTP Relays
- Anpassung Betriebssystemparameter nach Vorgaben des Verantwortlichen für die Applikation
- Neustart der Serversysteme bei Störungen im Betriebssystem oder auf Anforderungen des Verantwortlichen für die Applikation
- Erweiterung der Datenpartitionen bzw. Anpassung dieser anhand von Monitoring-Ergebnissen oder auf Aufforderung des Verantwortlichen für die Applikation und
- Betriebsdokumentation im Betriebshandbuch

**Patch Management**

- Update und Migration von Major Releases
- Einspielen von Betriebssystem Patches und
- Einspielen von Applikations Patches

**Configuration Management**

- Administration sämtlicher Applikationsparameter und

- Mail Routing (extern, MX-Record)

#### Lizenzierung

- Der AN hat alle hierzu notwendigen Lizenzen beizustellen. **Ausnahme:** Notwendige Lizenzen des Herstellers Microsoft werden durch die AG gestellt.

#### Administration

- Markieren von Funktionsaccounts
- Pflege vom Mail-Workflow zum Exchange
- Pflege von funktionalen Mail- Accounts zum Exchange
- Pflege von Benutzer-Postfächern
- Content-Pflege (Pflege der Applikationssysteme zur Nutzung des SMTP- Relays)
- Pflege Exchange Datenbanken und
- Restore von erforderlichen Konfigurationsdaten und Postfächern

#### 4.4.2 PKI-Infrastruktur

Der AN betreibt für die AG eine Public-Key-Infrastruktur (PKI) innerhalb der Virtual Private Cloud-Umgebung zur Bereitstellung kryptographischer Dienste zur Authentisierung, Verschlüsselung, Signatur und Zertifikatsverwaltung unter Berücksichtigung der Datenschutz und Security Anforderungen.

Zur Bereitstellung der PKI-Infrastruktur sind durch den AN folgende Leistungen zu erbringen:

- Bereitstellung einer PKI-Plattform inklusive
  - Root-CA
    - Bereitstellung und Betrieb einer besonders geschützten logisch oder physikalischen Sicherheitszone für die Root-CA
  - Issuing-CA
    - Betrieb der operativen Zertifizierungsstellen einschließlich Zertifikatsausstellung, Erneuerung, Sperrung und Widerruf
  - Registration Authority (RA)
    - Technische Unterstützung zur Identitätsprüfung und Freigabeprozesse für Zertifikatsanforderungen
    - Integration in Active Directory, Entra ID und DNS
    - Auto-Enrollment mit Unterstützung von SCEP (Simple Certificate Enrollment Protocol)
  - OCSP- und CRL-Services
    - Bereitstellung und Betrieb hochverfügbarer Validierungsdienste für Zertifikatsstatusabfragen und Sperrlistenbereitstellung
- Plattformbetrieb
  - Bereitstellung und Betrieb der zugrunde liegenden Plattform einschließlich Netzwerk-, Storage-, Compute- und Sicherheitsservices

- Hochverfügbarer georedundanter Aufbau der PKI Komponenten einschließlich Clusterbetrieb mit automatischem Failover und abgesicherten Kommunikationsverbindungen
- Bereitstellung dedizierter Hardware Security Modules (HSM) oder HSM-as-a-Service
- 24x7-Überwachung aller PKI-Komponenten einschließlich Security Monitoring und Angriffserkennung

#### 4.4.3 Kubernetes Plattform

BIG betreibt eine Service Delivery Plattform für die Entwicklung, Bereitstellung und den Betrieb von Anwendungen auf Basis von Kubernetes als Runtime Umgebung für Container Anwendungen. Diese besteht aus drei Kubernetes-Clustern für Produktionssysteme (Prod), Integrationsumgebung (Stage) und Testumgebung (Test).

Jeder dieser Cluster besitzt eine Control Plane zur Verwaltung des Clusters und den Worker Nodes zur Ausführung der Container Workloads.

Die Runtime Infrastruktur enthält verschiedene Komponenten zur Steuerung des Netzwerkverkehrs.

- **Runtime Components:**
  - Cilium als Netzwerk- und Security-Komponente zur
    - Verwaltung des Netzwerkverkehrs zwischen Services
    - Durchsetzung von Netzwerk-Security-Policies
    - Traffic Analyse
  - Traefik als Ingress Controller mit den Funktionen
    - Routing von HTTP/HTTPS Traffic
    - TLS Verschlüsselung
    - Weiterleitung von Requests an interne Services

Neben der Runtime Infrastruktur existieren mehrere Plattform-Services, die Sicherheit, Monitoring und Betrieb gewährleisten.

- **Plattform Services**
  - **Vault** zur Verwaltung von Geheimnissen wie Passwörter, API-Schlüssel und Zertifikate für die Plattform
  - **Kyverno** als Policy Engine zur automatisierten Überprüfung und Durchsetzung von Sicherheitsrichtlinien und Compliance auf Deployments, z. B.
    - Container dürfen nur signierte Images verwenden
    - Container dürfen nicht als Root laufen
    - Ressourcenlimits müssen gesetzt sein
  - **Aqua Security** zur Analyse von Container Images auf Sicherheitslücken mit den Funktionen:
    - Vulnerability Scanning
    - Runtime Security
    - Compliance Reports

Die Kubernetes Plattform basiert auf einer Computing Infrastruktur aktuell in folgender Dimensionierung:

Computing Anforderungen für die Kubernetes Control Plane:

| Environment | Control Nodes | CPU    | Memory | Storage                                              |
|-------------|---------------|--------|--------|------------------------------------------------------|
| Prod        | 3             | 8 vCPU | 16 GB  | 50 GB<br>(Block Storage<br>Klasse B<br>ungespiegelt) |
| Stage       | 3             | 8 vCPU | 16 GB  | 50 GB<br>(Block Storage<br>Klasse B<br>ungespiegelt) |
| Test        | 3             | 8 vCPU | 16 GB  | 50 GB<br>(Block Storage<br>Klasse B<br>ungespiegelt) |

**Tabelle 8: Kubernetes Control Plane**

Computing Anforderungen für die Kubernetes Worker Nodes:

| Environment | Worker Nodes | CPU     | Memory | Disk                                                  |
|-------------|--------------|---------|--------|-------------------------------------------------------|
| Prod        | 5            | 16 vCPU | 32 GB  | 100 GB<br>(Block Storage<br>Klasse B<br>ungespiegelt) |
| Stage       | 6            | 16 vCPU | 32 GB  | 100 GB<br>(Block Storage<br>Klasse A<br>ungespiegelt) |
| Test        | 5            | 16 vCPU | 32 GB  | 100 GB<br>(Block Storage<br>Klasse A<br>ungespiegelt) |

**Tabelle 9: Kubernetes Worker Nodes**

Zur Überwachung der Metriken, Logs und Systemzustände der Kubernetes Infrastruktur werden verschiedene Monitoring-Tools eingesetzt.

- **Monitoring**
  - **Prometheus** sammelt technische Metriken als Grundlage für Monitoring und Alerting, z. B.:

- CPU und Speicherverbrauch
- Netzwerktraffic
- Service Health
- **Thanos** zur Langzeitspeicherung und globalen Aggregation von Prometheus-Metriken  
Es erweitert Prometheus um:
  - Unbegrenzte Speicherdauer – Metriken werden in Object Storage ausgelagert
  - Globale Query-Ansicht – mehrere Prometheus-Instanzen werden zu einer einzigen abfragbaren Ansicht zusammengeführt
  - Hochverfügbarkeit – Deduplizierung von redundanten Prometheus-Replikas
  - Downsampling – ältere Daten werden komprimiert, um Speicher und Abfragezeit zu sparen
- **Grafana** visualisiert Monitoringdaten und stellt sie in Dashboards dar:
  - Systemzustand
  - Performance Probleme
  - Trends und Auslastung
- **Loki** sammelt Logs der Anwendungen und Infrastruktur, die benötigt werden für:
  - Fehlersuche
  - Incident Analyse
  - Debugging
- **Uptime Kuma** überwacht die Verfügbarkeit von Services mit den Funktionen:
  - Service Checks
  - Verfügbarkeitsmessung
  - Alarmierung bei Ausfällen

Folgende generelle Leistungen sind durch den AN zu erbringen:

- Bereitstellung der Computing Infrastruktur bestehend aus VMs Netzwerkinfrastruktur und Storage für die Kubernetes Control Plane und die Kubernetes Worker Nodes
- Installation und Konfiguration des Kubernetes-Orchestrierungssystems sowie die Einrichtung von Load Balancing- und Skalierungsoptionen
- Installation und Konfiguration von Softwarekomponenten und Tools für den Betrieb des Clusters
- die Skalierung der Computing Infrastruktur auf die von den Workloads benötigten Kapazitäten und
- der tägliche, über die vereinbarte Vertragslaufzeit andauernde Betrieb der Computing Infrastruktur

Im Detail sind durch den AN folgende Leistungen zu erbringen:

#### Betriebsverantwortung

- Betrieb der Kubernetes Infrastruktur

- Betriebsdokumentation im Betriebshandbuch

#### Patch Management

- Update und Migration von Major Releases für die Kubernetes Infrastruktur
- Einspielen von Betriebssystem Patches für die Kubernetes Infrastruktur
- Aktualisierung und Patching von Kubernetes-Komponenten und zugehöriger Software

#### Configuration Management

- Netzwerk- und Routing-Konfiguration für die Kubernetes Plattform

#### Administration

- Überwachung der Erreichbarkeit / Verfügbarkeit
- Überwachung der Cluster Performance und Kapazitäten
- Täglicher Backup der Cluster Daten
- Fehleranalyse von Hardwareproblemen
- Analyse von Performance Problemen
- Case Management mit dem Hersteller

#### 4.4.4 Database Services (DBaaS)

Die AG nutzt derzeit ausschließlich Microsoft SQL Server für Datenbanken, unabhängig davon, dass für Fachanwendungen auch andere Datenbanken im Workload der Computing Infrastruktur genutzt werden, die aber nicht Gegenstand der Managed Services sind.

Die Microsoft SQL Server Lizenzen werden von der AG über einen eigenen Rahmenvertrag beschafft und in Form von Bring-Your-Own-License (BYOL) bereitgestellt.

Als DBaaS-Services stellt der AN Microsoft SQL Server je nach Anforderung in verschiedenen Leistungsstufen für Skalierbarkeit, Sicherheit, Verfügbarkeit und Ausfallsicherheit bereit:

- Betrieb auf virtuellen Servern als Standard
- Single Instance DB (für Entwicklung und Testumgebungen)
- Hochverfügbarkeit über Infrastruktur und Virtualisierungsebene
  - Clusterfähige Virtualisierung
  - Storage Spiegelung
- Skalierbarkeit: Bei Bedarf können zusätzliche Knoten zur Erhöhung der Verarbeitungsleistung und zur Lastverteilung hinzugefügt werden
- Daten werden verschlüsselt abgelegt

Zur Verwaltung der Datenbanken durch die AG wird ein Management-Tools für folgende Aufgaben bereitgestellt:

- Wartungs- und Optimierungsaufgaben
- Konfiguration von Sicherheitseinstellungen
- Konfiguration von Zugriffsberechtigungen

- Einsicht in die Protokollierung (Leistungsüberwachung, Aktivitäten, Fehleranalyse)

Folgende generelle Leistungen werden vom AN erbracht:

- Bereitstellung virtueller Datenbankserver/Instanzen mit angebundenem Storage und Backup,
- Initiale Installation der Datenbank,
- Einrichtung initialen User zur Datenbankadministration
- Monitoring der Datenbank Performance
- Skalierung der Kapazitäten in Abhängigkeit von den Workloads und Performance oder auf Anforderungen der AG und
- Sicherstellung der Serververfügbarkeit während der Vertragslaufzeit

Im Detail übernimmt der AN folgende Leistungen:

#### Betriebsverantwortung

- Gesamte Betriebsverantwortung für DBaaS- Services
- Koordination mit Partnern der AG
- Unterstützung bei Koordinationsaufgaben der AG
- Betrieb des Betriebssystems
- Betrieb der Virtualisierungsplattform (Hypervisor)
- Anpassung von Betriebssystemparametern nach Vorgabe des Applikationsverantwortlichen
- Neustart der Server bei Störungen oder auf Anforderung des Applikationsverantwortlichen
- Erweiterung der Datenpartitionen oder Anpassung basierend auf Monitoring-Ergebnissen oder auf Anforderung des Applikationsverantwortlichen
- Dokumentation des Betriebs im Betriebshandbuch
- Patch Management
- Updates und Migrationen von Major Releases
- Einspielen von Betriebssystem-Patches
- Einspielen von Applikations-Patches
- Freigabe von Applikations-Patches nach Prüfung der Anforderungen der Fachapplikation
- Configuration Management
- Anlegen von Datenbanken
- Konfiguration von Benutzern und Rechten
- Verkleinern von Datenbankdaten

#### Lizenzierung

Die AG stellt die erforderlichen Lizenzen für MS-SQL Datenbanken zur Verfügung (BYOL).

#### Backups

- Der AN erstellt Backups aller Datenbanken gemäß den von der AG vorgegebenen Zyklen.
- Transaktionslog-Backups werden regelmäßig erstellt, um disproportionalen Wachstum der Log-Dateien vorzubeugen.

- Der AN führt regelmäßige Backup-Tests aus, um die Integrität und Funktionalität dieser sicherzustellen.

#### Administration

- Monitoring der Datenbankserver
- Monitoring der Performance der Datenbanken
- Regelmäßige Überprüfung der Statusmeldungen (Error Logs)
- Wiederherstellung erforderlicher Datenbestände

#### **4.5 Öffnungsklausel für zusätzliche XaaS-Leistungen des AN**

Die AG ist berechtigt, während der Vertragslaufzeit über die vertraglich vereinbarten XaaS-Leistungen hinaus weitere, funktional oder technisch vergleichbare Dienste aus dem Service-Portfolio des AN abzurufen, sofern diese in die bestehende Virtual Private-Cloud Umgebung integrierbar sind.

Diese Leistungen können insbesondere beinhalten:

- neue oder weiterentwickelte IaaS-Komponenten (z. B. zusätzliche Computing-, Storage- oder Netzwerkressourcen)
- ergänzende SaaS-Dienste (z. B. UCC, Groupware, Verzeichnisdienste, UCC, DevOps-Plattformen)
- Advanced Data Services wie Data Lake, KI/ML-Plattformen etc.
- Dienstleistungen im Umfeld der XaaS-Services

Die Abrufbarkeit setzt voraus, dass:

- die Leistungen den bestehenden Regelungen unterliegen, insbesondere zu Datenschutz, IT-Sicherheit, Service-Level-Agreements (SLAs) und Support,
- die Preise für die Leistungen entweder durch die bestehenden Preispositionen gedeckt sind oder nach einem Preisfindungsverfahren einvernehmlich zu vereinbaren sind.

Der Auftragnehmer verpflichtet sich, die Auftraggeberin fortlaufend über verfügbare neue oder ergänzende Leistungen aus seinem Portfolio zu informieren.

Die Abrechnung erfolgt auf Basis der vertraglich vereinbarten Abrechnungsmodalitäten.

## 5 Bezug von Public Cloud Services

Für die AG besteht perspektivisch Bedarf, Cloud Services von Hyperscalern und von Sovereign Cloud Providern (Superscalern) zu definierten Konditionen direkt über den AN beziehen zu können und fachliche Unterstützung in der Nutzung dieser Services vom AN abrufen zu können.

Zu den für die AG interessanten Cloud Anbietern zählen folgende Hyperscaler:

- Microsoft Azure
- Amazon Web Services (AWS)
- Google Cloud Platform (GCP)

und folgende Sovereign Cloud Provider:

- OVH
- STACKIT
- IONOS
- OTC

aber auch weitere EU-DSGVO konforme Cloud-Anbieter oder Derivate der Hyperscaler können angeboten werden.

Der AN soll für die abrufbaren Public Cloud Services folgende Leistungen zur fachlichen Unterstützung anbieten können:

- Management des Tenants des Public Cloud Providers
  - Erfassung der abgerufenen Cloud-Ressourcen
  - Kostenkontrolle und Abrechnung der abgerufenen Cloud-Ressourcen
- Produktkompetenz für die jeweiligen Public Cloud Provider und Technologieberatung in den Produktkategorien:
  - Compute
  - Storage
  - Network
  - Datenbanken
  - Security
  - Identity & Access Management
  - Kubernetes
  - Collaboration & Messaging

Zur Bewertung der Leistungen in Bezug auf Public Cloud Services muss der Bieter im „**Kriterienkatalog**“ Angaben machen, von welchen Hyperscalern und Sovereign-Cloud-Anbietern der vollständige Service Katalog in den oben genannten Produktkategorien direkt über den AN zu dessen Konditionen bezogen werden kann und fachliche Unterstützung im oben aufgeführten Leistungsumfang erbracht werden kann.

Zur wirtschaftlichen Bewertung muss der Bieter im „**Preisblatt**“ für die o. g. zur Bewertung ausgewählten Hyperscaler und Sovereign-Cloud-Anbieter in den ausgewählten Preisgruppen die jeweiligen Rabattsätze eintragen. Die Preisgruppen sind so gewählt, dass sie sich in vergleichbarer Form auf die ausgewählten Cloud Provider anwenden lassen, auch wenn sie in der Bezeichnung und den Katalogen nicht identisch sind.

Die anzugebenden Rabattsätze beziehen sich auf die Referenzpreise gemäß der nachfolgend aufgeführten, öffentlich zugänglichen Preiskalkulatoren/Preislisten in ihrer jeweils aktuellen gültigen Fassung:

**Microsoft AZURE:**

Sämtliche Leistungen, die über den Azure Preisrechner verfügbar sind:

<https://azure.microsoft.com/de-de/pricing/calculator/>

**Amazon AWS:**

Sämtliche Leistungen, die über den AWS Calculator verfügbar sind:

<https://calculator.aws/#/>

**Google GCP:**

Sämtliche Leistungen, die über den Google Cloud Platform Calculator verfügbar sind:

<https://cloud.google.com/products/calculator?hl=de> (mit Ausnahme der Committed Use Discounts)

**OVH Cloud:**

Sämtliche Leistungen, die über die aktuelle Preisübersicht verfügbar sind:

<https://www.ovhcloud.com/de/public-cloud/prices/>

**STACKIT:**

Sämtliche Leistungen, die über die aktuelle Preisliste verfügbar sind:

[https://www.stackit.de/wp-content/uploads/2025/11/STACKIT\\_Preisliste.pdf](https://www.stackit.de/wp-content/uploads/2025/11/STACKIT_Preisliste.pdf) aktuelle Version 1.0.32 vom 14.11.2025"

## 6 Professional Services

Für Leistungen, die nicht über die Servicepauschalen abgegolten werden, bietet der AN Professional Services für technische, organisatorische und strategische Themen mit qualifizierten Mitarbeitern in verschiedenen Qualifikationsprofilen an, die nach Bedarf durch die AG abgerufen werden können.

Insbesondere wird von der AG ein Beratungsservice beim Aufbau einer sicheren und skalierbaren Cloud-Landing-Zone zur Nutzung von IaaS-Diensten durch Experten des AN benötigt. Unterstützung bei der Migration von Fachanwendungen muss durch den AN gegeben sein. Ein wesentlicher Anteil der Professional Services wird daher für die Unterstützung zur Migration der Bestandssysteme erwartet.

Für das IT-Personal der AG und dessen Partner muss die Möglichkeit eines Onboardings und weiterer Bildungsangebote durch den AN gegeben sein.

Der AN soll Cloud-, RZ- und IT-Strategie unterstützen können.

Für die angebotenen Professional Services soll vom AN ein Kernteam definiert werden, um eine Kontinuität der Beratung gesamtheitlich und über die Länge der Vertragslaufzeit sicher zu stellen.

Dazu soll der AN Qualifikationsprofile anbieten, über die alle Aufwandsleistungen zu den jeweiligen Tagessätzen über die Vertragslaufzeit abgerechnet werden. Die Qualifikationsprofile sollen entsprechend der Qualifikation, Zertifizierung und Berufserfahrung in bis zu drei Qualifikationslevels: Junior/Senior/Expert angeboten werden.

### Junior-Level:

Mitarbeitende mit grundlegender Berufserfahrung und Fachkenntnis, die unter Anleitung arbeiten und Aufgaben mit überschaubarem Schwierigkeitsgrad übernehmen, mit folgenden Merkmalen:

- Bis 3 Jahre relevante Berufserfahrung
- Grundkenntnisse in den eingesetzten Technologien / Tools
- Zertifizierung in den eingesetzten Technologien auf Foundation-Niveau
- Eingeschränkte Eigenverantwortung
- Einarbeitung in komplexere Themen möglich

### Senior-Level:

Mitarbeitende mit umfassender Berufserfahrung, die Aufgaben eigenständig und lösungsorientiert übernehmen und Verantwortung in Teilprojekten oder Teams tragen können, mit folgenden Eigenschaften:

- Mindestens 3 – 7 Jahre relevante Berufserfahrung
- Fundierte Fach- und Technologiekenntnisse
- Zertifizierung in den eingesetzten Technologien auf Practitioner-/Associate-/ Professional-Niveau
- Selbstständige Planung und Umsetzung von Arbeitspaketen
- Analyse, Beratung und Lösung komplexer Anforderungen
- Unterstützung und fachliche Anleitung von Juniors

### Expert-Level:

Hochqualifizierte Fachpersonen mit überdurchschnittlicher Erfahrung und/oder Spezialisierung, die strategische Verantwortung übernehmen und Wissensträger in ihrem Fachgebiet sind, mit folgenden Merkmalen:

- 7 – über 10 Jahre einschlägige Erfahrung
- Tiefgehendes Spezialwissen
- Erfahrung in Architektur, Strategie oder Innovationsthemen
- Höchste Zertifizierung in den eingesetzten Technologien (Expert/Spezialist)
- Fachliche Führungsrolle, methodische Beratung, Coaching von Teams

Folgende Qualifikationsprofile sollen angeboten werden:

- Berater (Junior / Senior / Expert)
  - IT-Servicemanagement,
  - Lizenz- und Vertragsmanagement,
  - Informationssicherheit
  - Change- und Projektmanagement
- Spezialist (Junior / Senior / Expert)
  - für IaaS- und SaaS-Dienste
  - für IT-Security
  - für Netzwerk
- IT-Architekt (Junior / Senior / Expert)
  - Anwendungsarchitektur
  - Systemarchitektur
  - Sicherheitsarchitektur
  - Netzwerkarchitektur
- Systemspezialist (Junior / Senior)
- Techniker
- Technische Hilfskraft